# 🌐 Module 03: Open Source Intelligence (OSINT) and Attack Surface Mapping

```
# Exercise 4: Collecting OSINT using Automation Tools
```

### Scenario

This lab covers gathering OSINT using automation tools to streamline data collection and analysis. It allows penetration testers to efficiently extract information such as domain details, IP addresses, employee profiles, technologies in use, and exposed services, enabling faster identification of potential vulnerabilities and attack surfaces.

### Objective

The objective of this lab is to help students learn how to gather OSINT using automation tools:
- Gather Open Source Intelligence on a Target using Maltego
- Gather Open Source Intelligence on a Target using SpiderFoot
- Perform Web Reconnaissance using reNgine

---

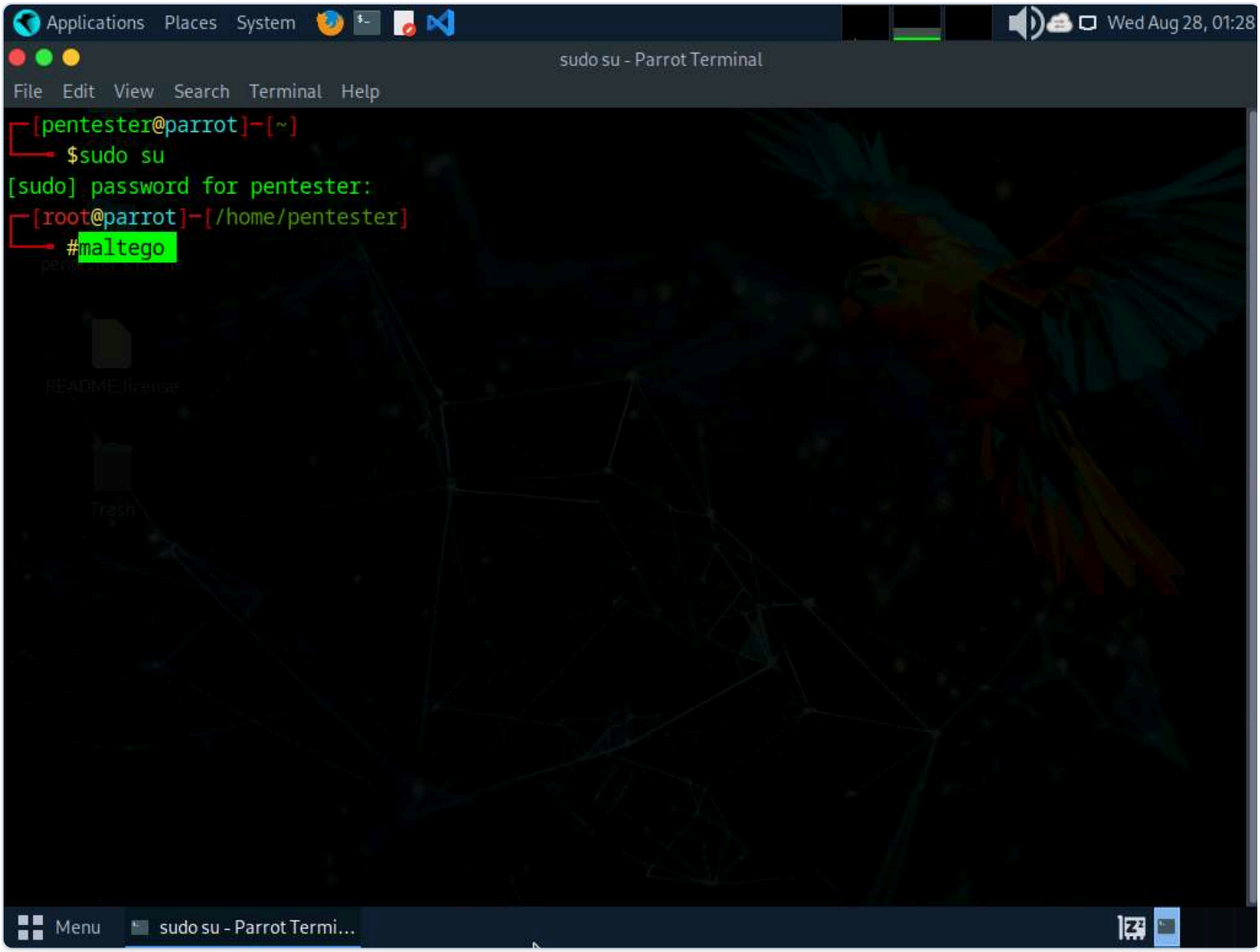
## Task 1: Gathering Open Source Intelligence on a Target using Maltego

Maltego is a footprinting tool used to gather maximum information for ethical hacking, computer forensics, and pentesting. It provides a library of transforms to discover data from open sources and visualizes that information in a graph format, suitable for link analysis and data mining. Maltego provides you with a graphical interface that makes seeing these relationships instant and accurate and even makes it possible to see hidden connections.

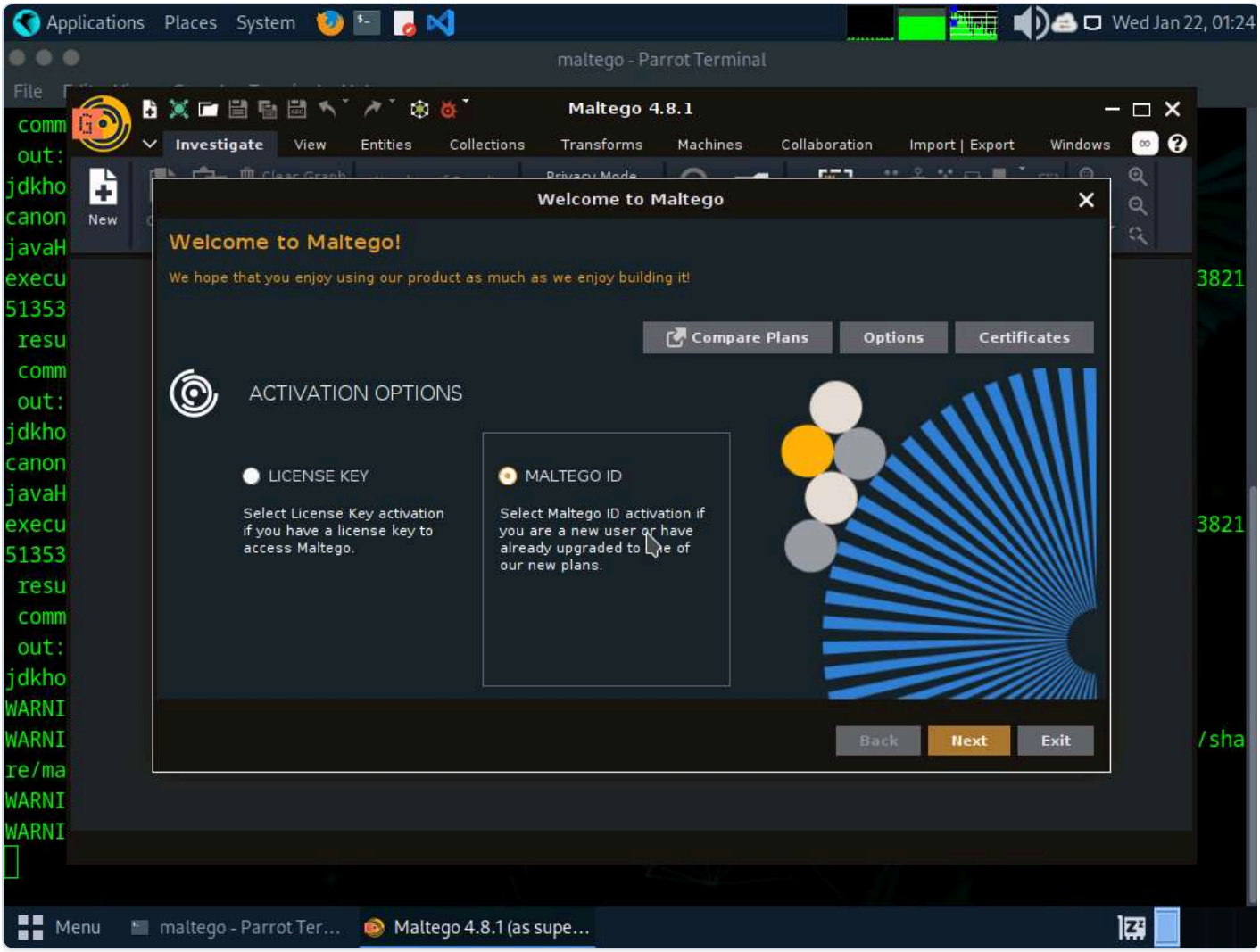
Here, we will gather a variety of information about the target organization using Maltego.
*(The screenshots will differ while performing the lab tasks.)*

### Lab Tasks

1. Click **Parrot Security** machine. Type **toor** in the Password field and press Enter.
2. Launch a terminal and acquire root privileges by executing **sudo su** command. (When prompted for the password, type **toor**). Run **maltego** to launch Maltego.

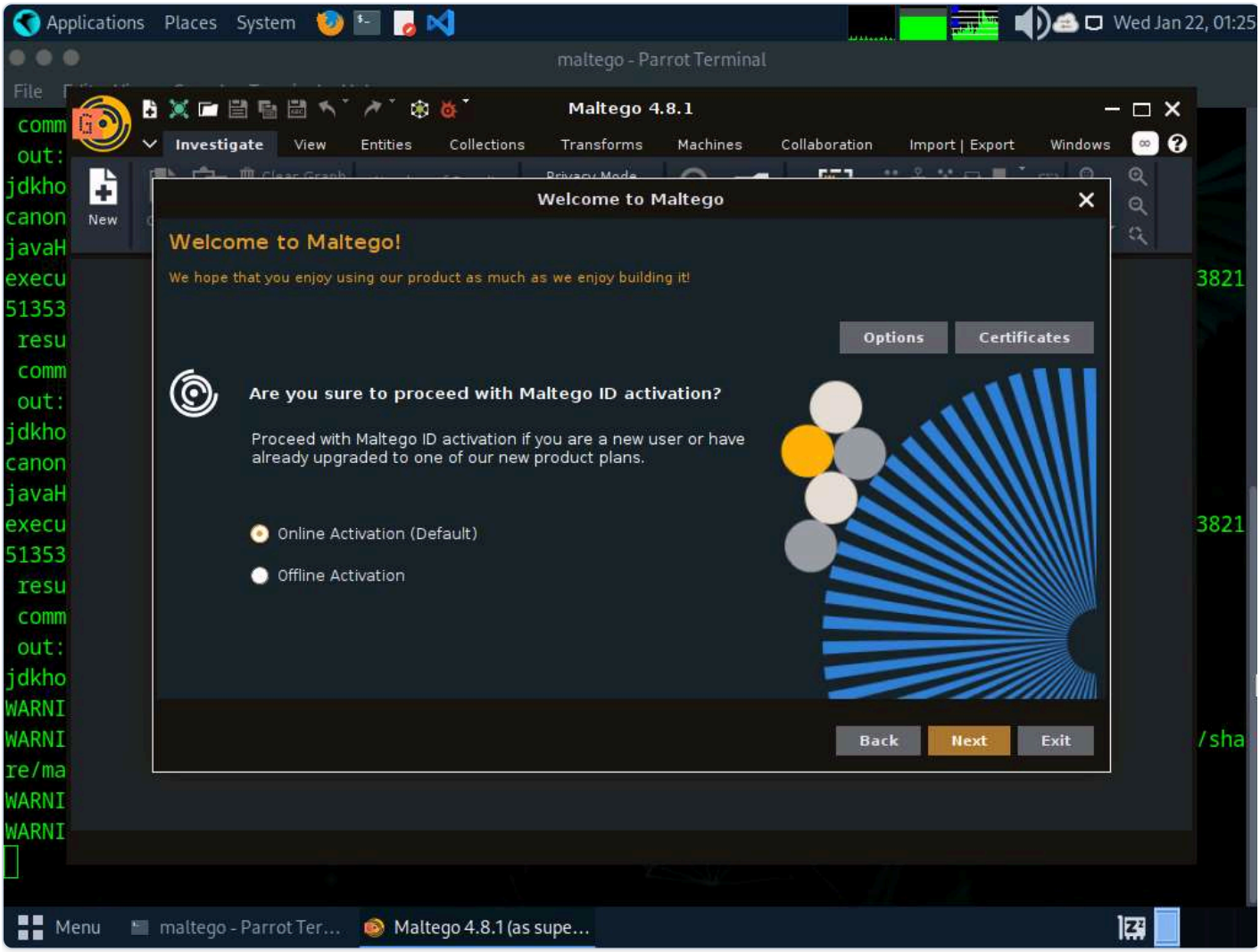



1. Welcome to Maltego window appears, select **Maltego ID** under the **ACTIVATION OPTIONS** section and click **Next**.

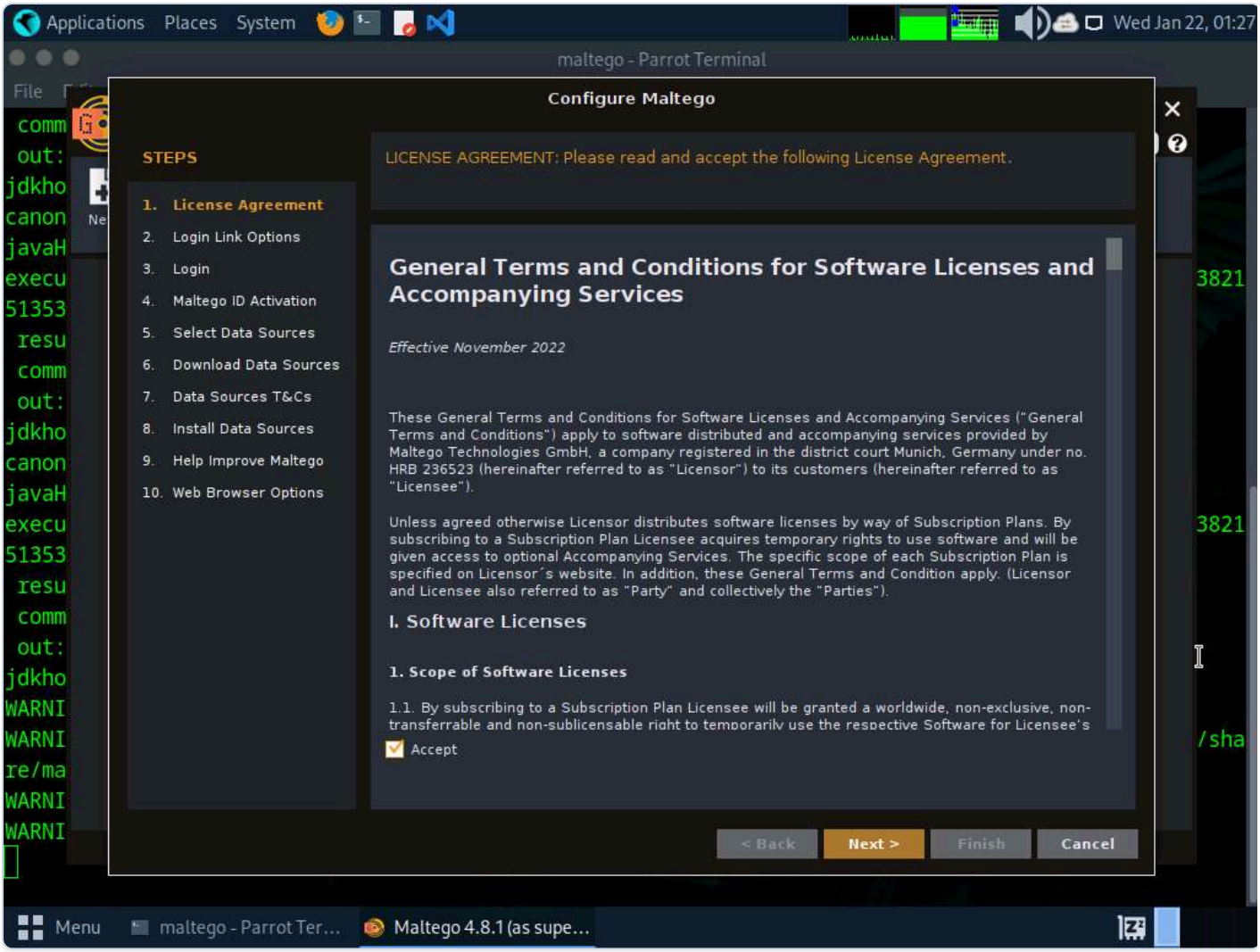



*(If the Memory Settings Optimized pop-up appears, click Restart Now.)*

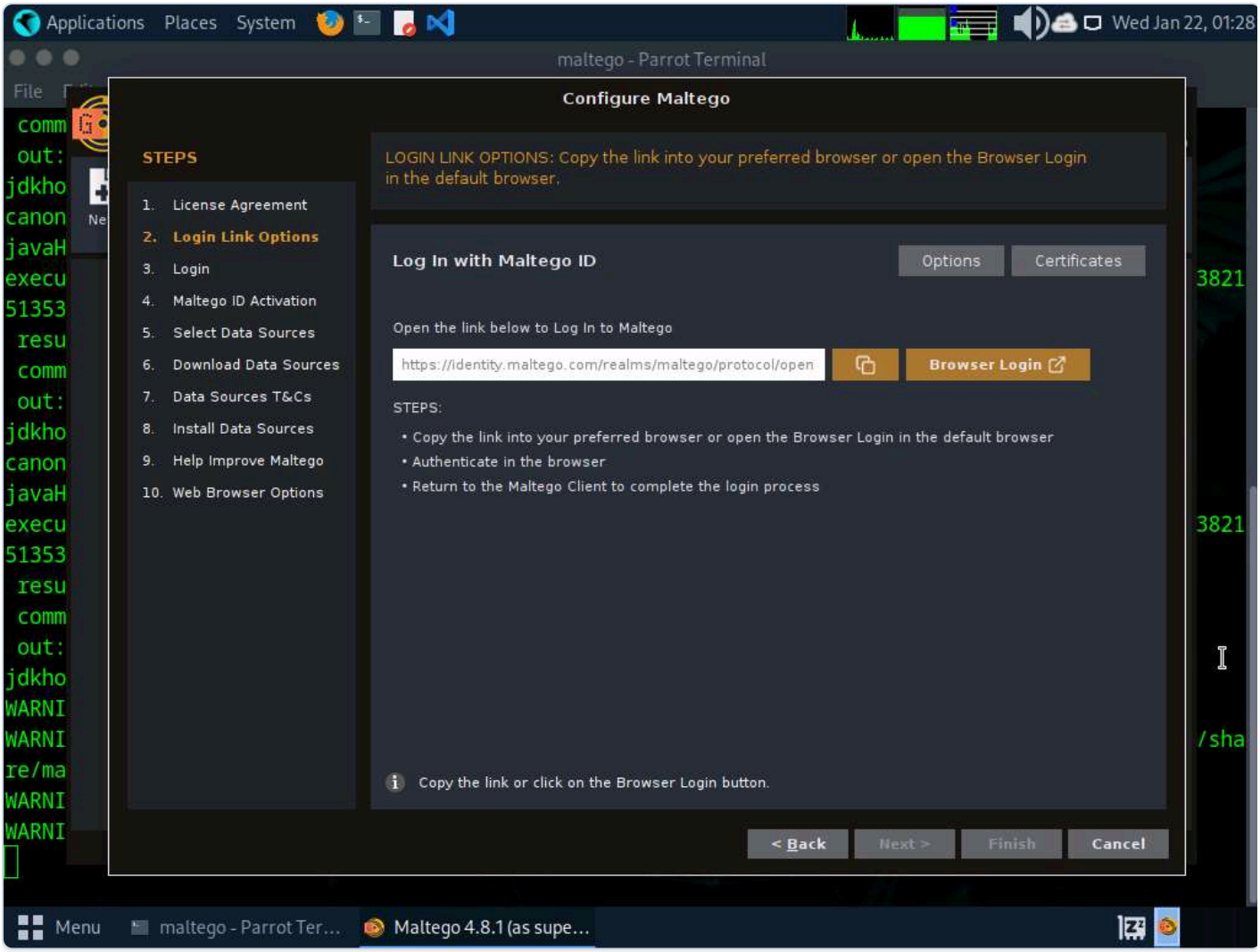
1. In the next window select **Online Activation** radio button and click **Next**.



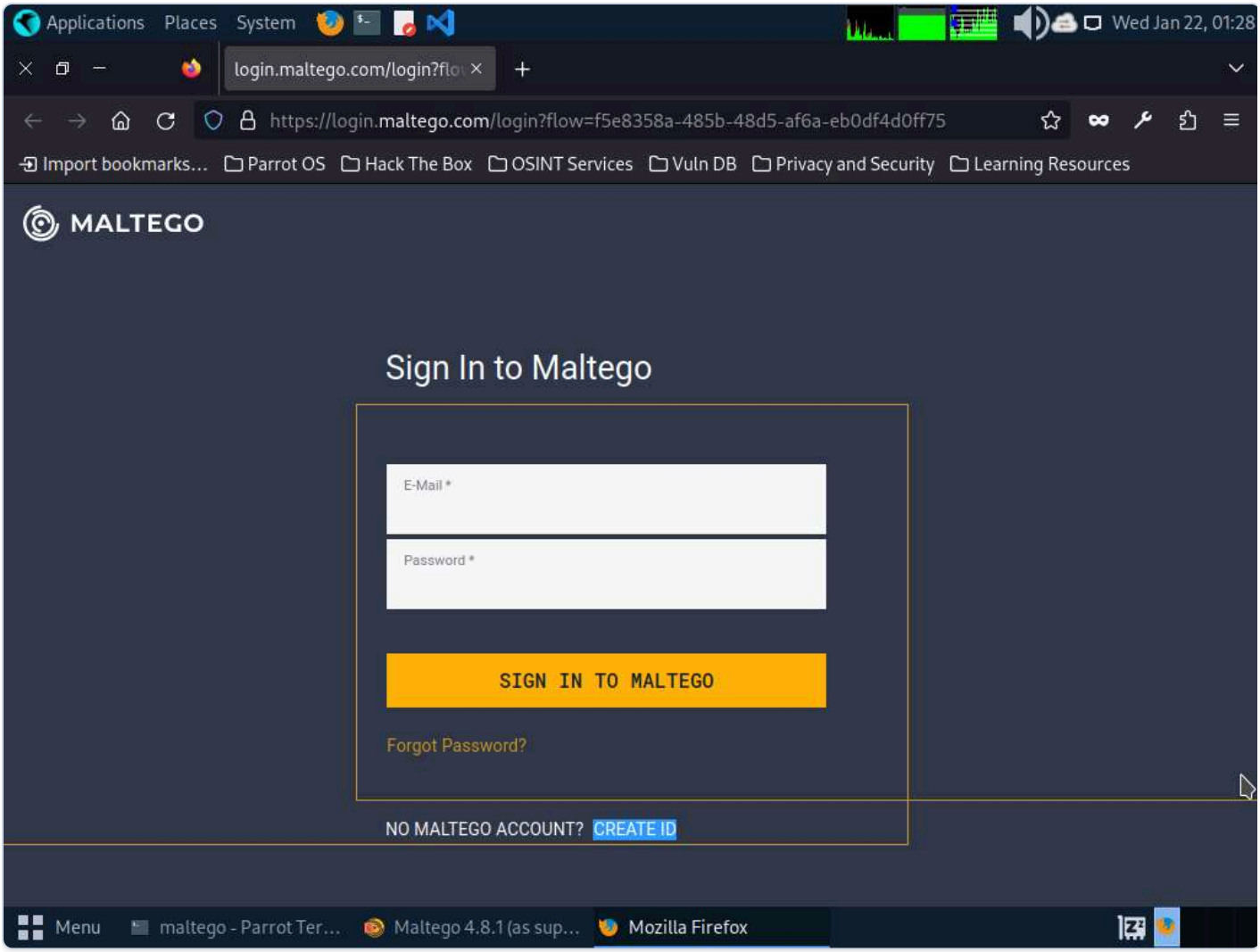

1. As the Configure Maltego window appears along with a **LICENSE AGREEMENT** form, check the **Accept** checkbox and click **Next**.

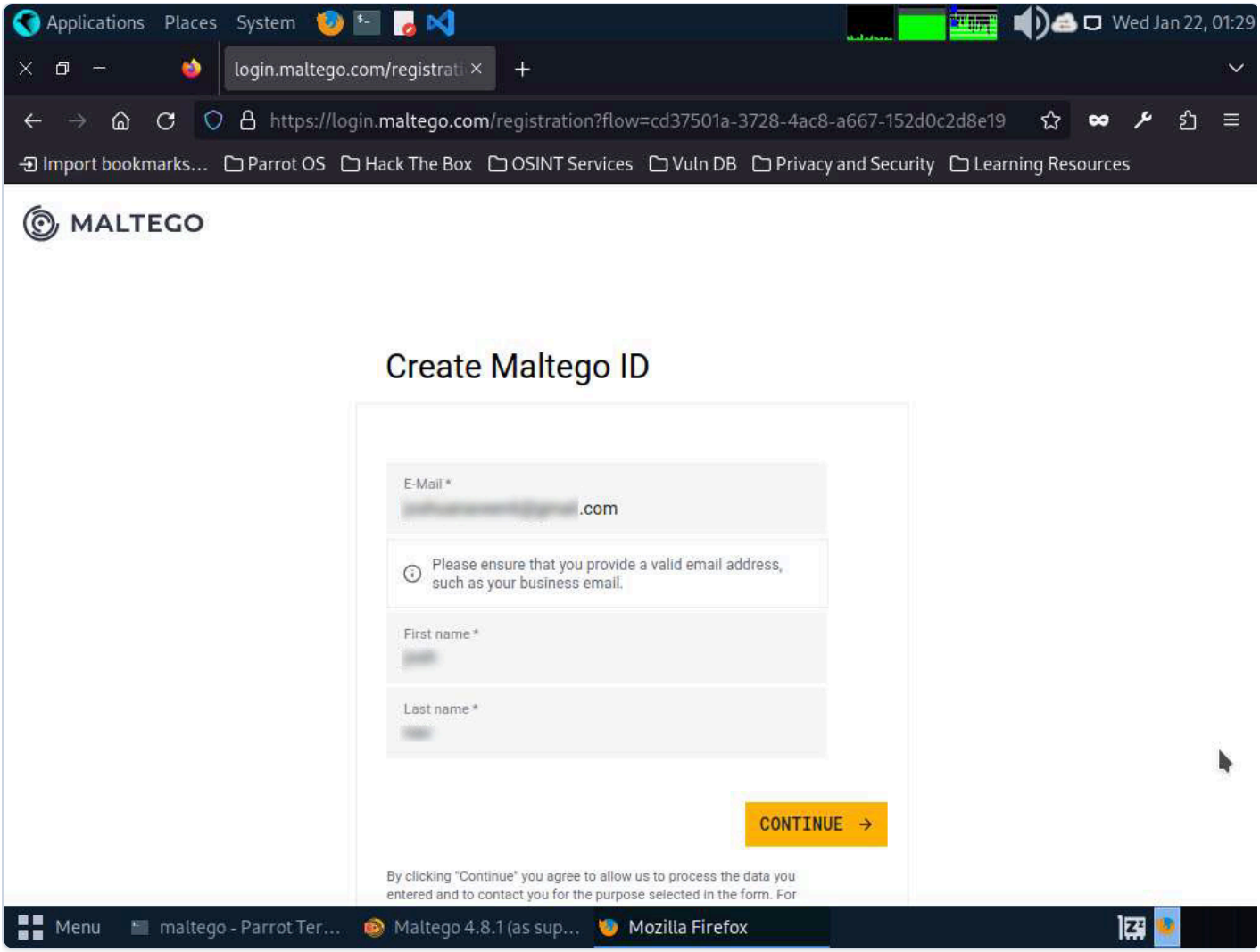



1. You will be redirected to the Login Link Options section; as shown in the screenshot.

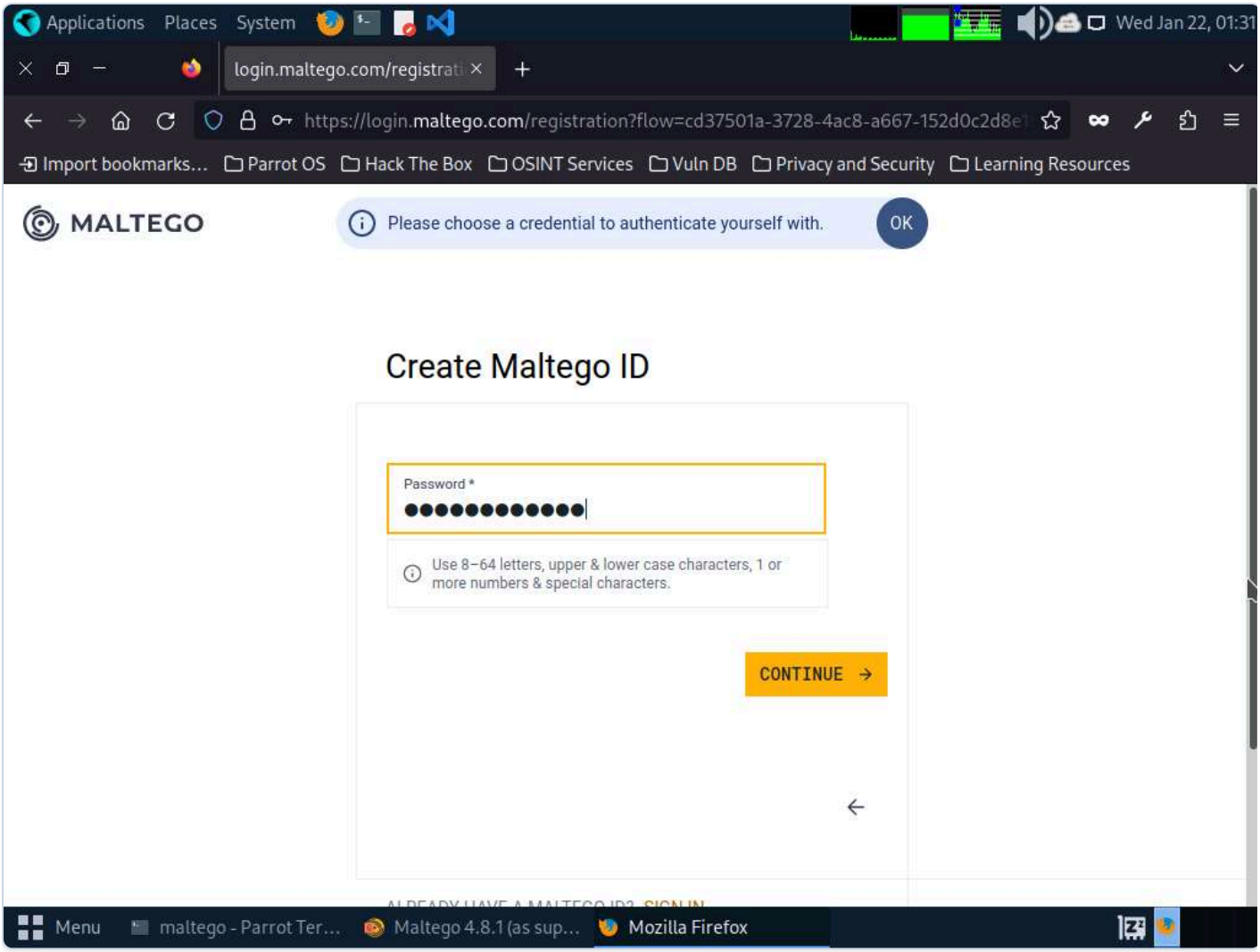



1. Click on the copy button to copy the link. Now, open a browser, paste the copied link in the address bar, and press Enter. **Sign In to Maltego** page appears, click on **CREATE ID**. **Create Maltego ID** page appears enter your details and click the **CONTINUE** button.
2. *(If cookie notification appears in the lower section of the browser, click Accept.)*

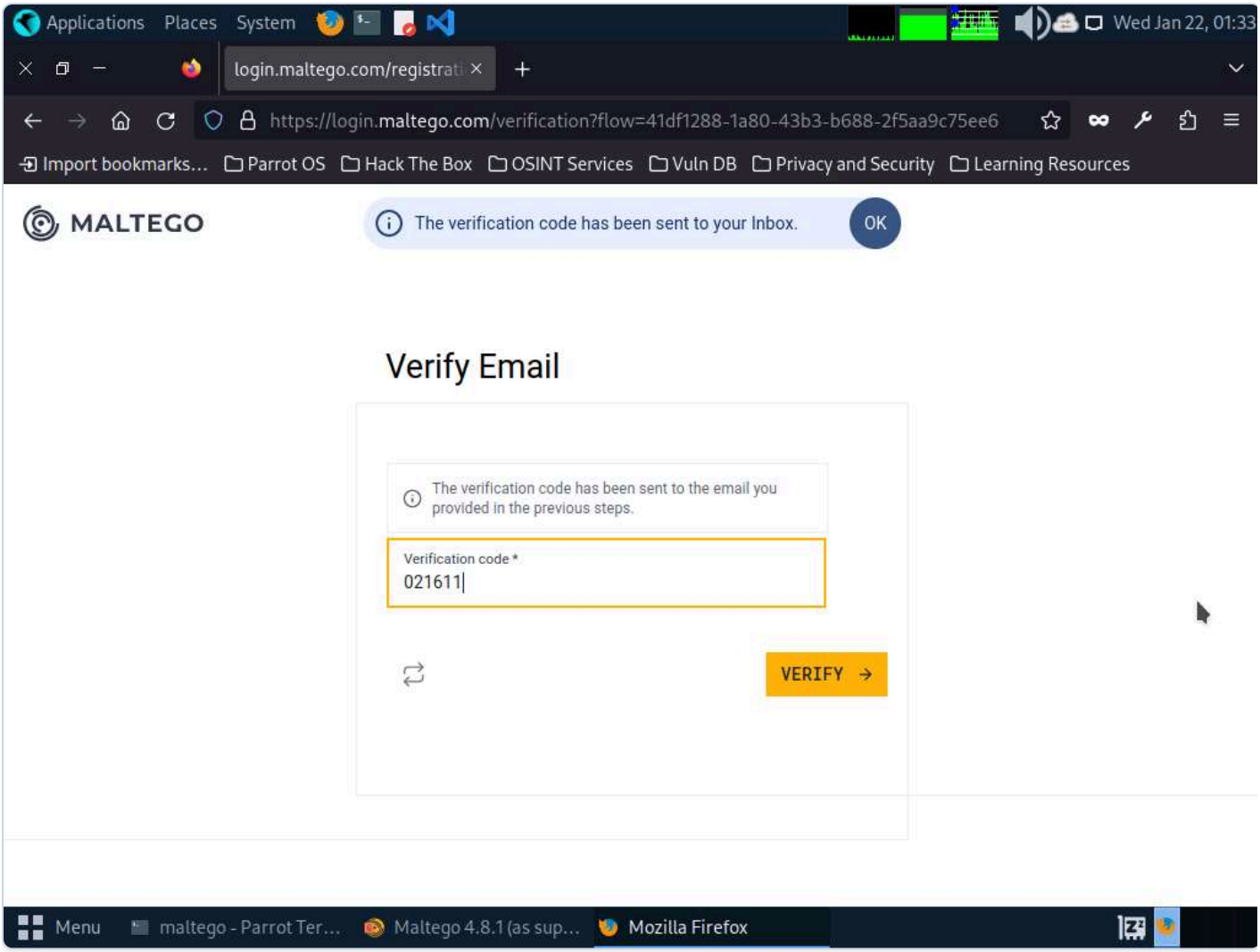

Applications
Places
System
Wed Jan 22, 01:28
login.maltego.com/login?flo
https://login.maltego.com/login?flow=f5e8358a-485b-48d5-af6a-eb0df4d0ff75
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
MALTEGO
Sign In to Maltego
E-Mail *
Password *
SIGN IN TO MALTEGO
Forgot Password?
NO MALTEGO ACCOUNT? CREATE ID
Menu
maltego - Parrot Ter...
Maltego 4.8.1 (as sup...
Mozilla Firefox



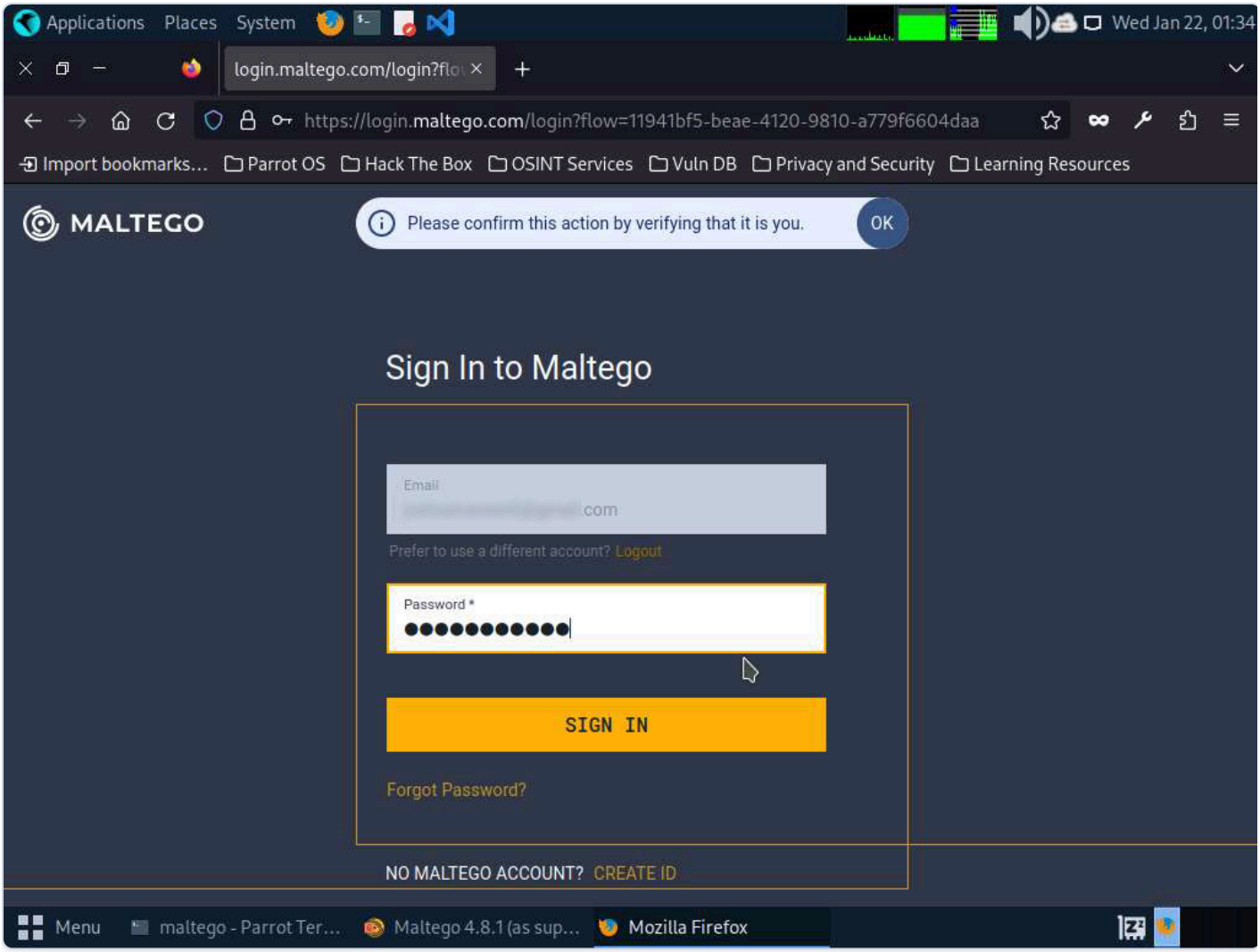

1. In the next page, enter your details and click **Continue**. In the next page, create a new password and click **CONTINUE**.



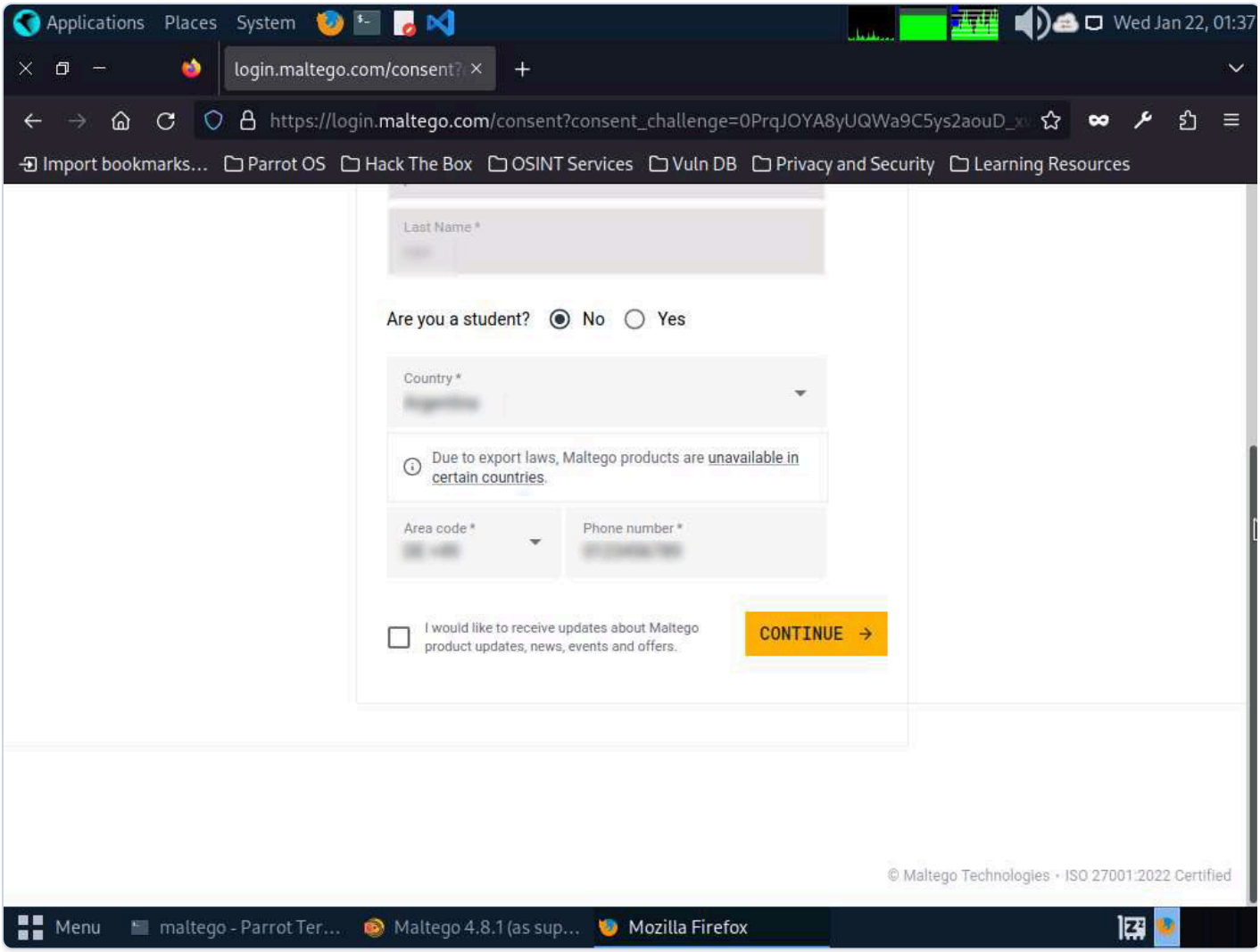

1. In the Verify Email window enter the code that is sent to the email and click **Verify**.

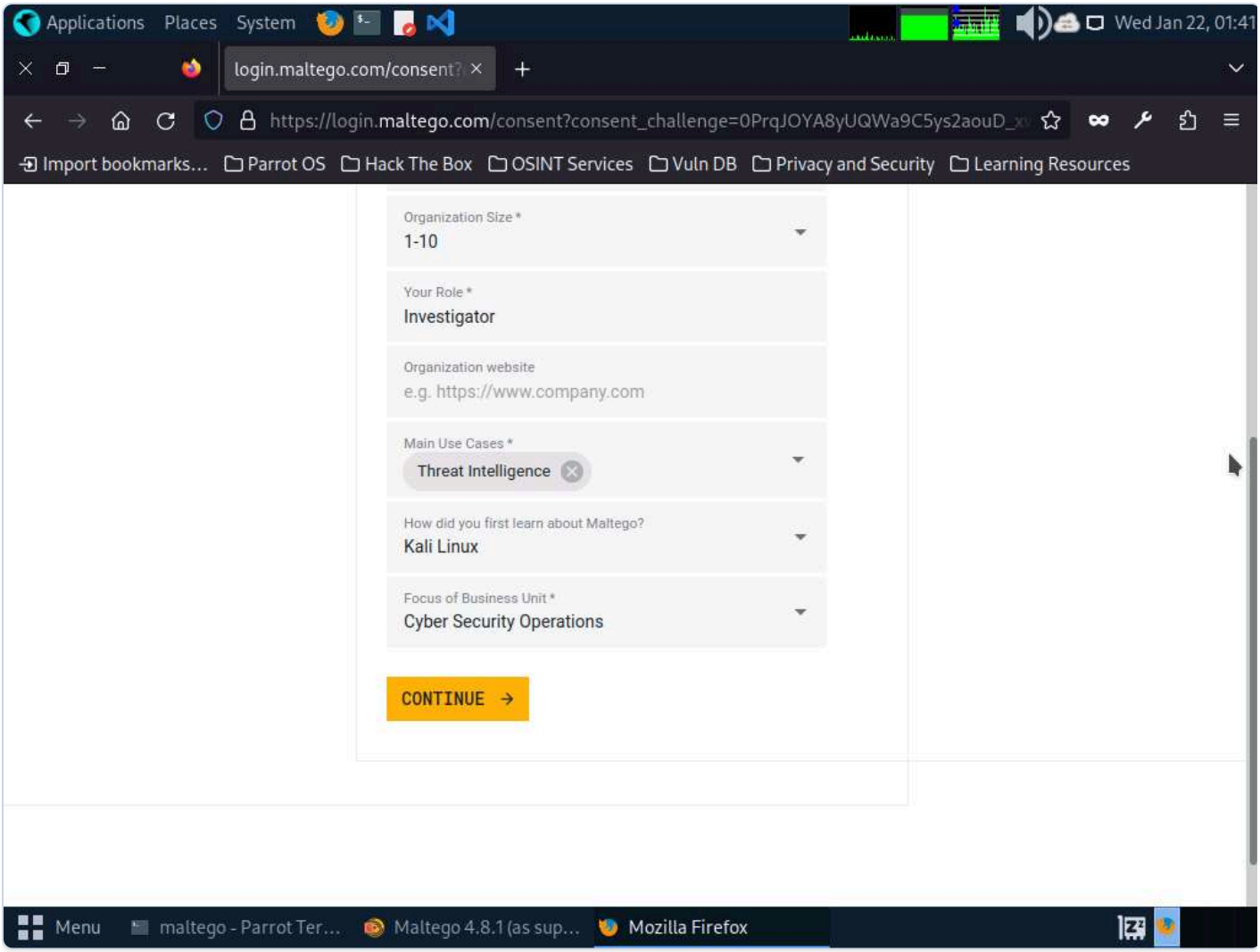



1. Sign In to Maltego window appears, enter the password, and sign in.

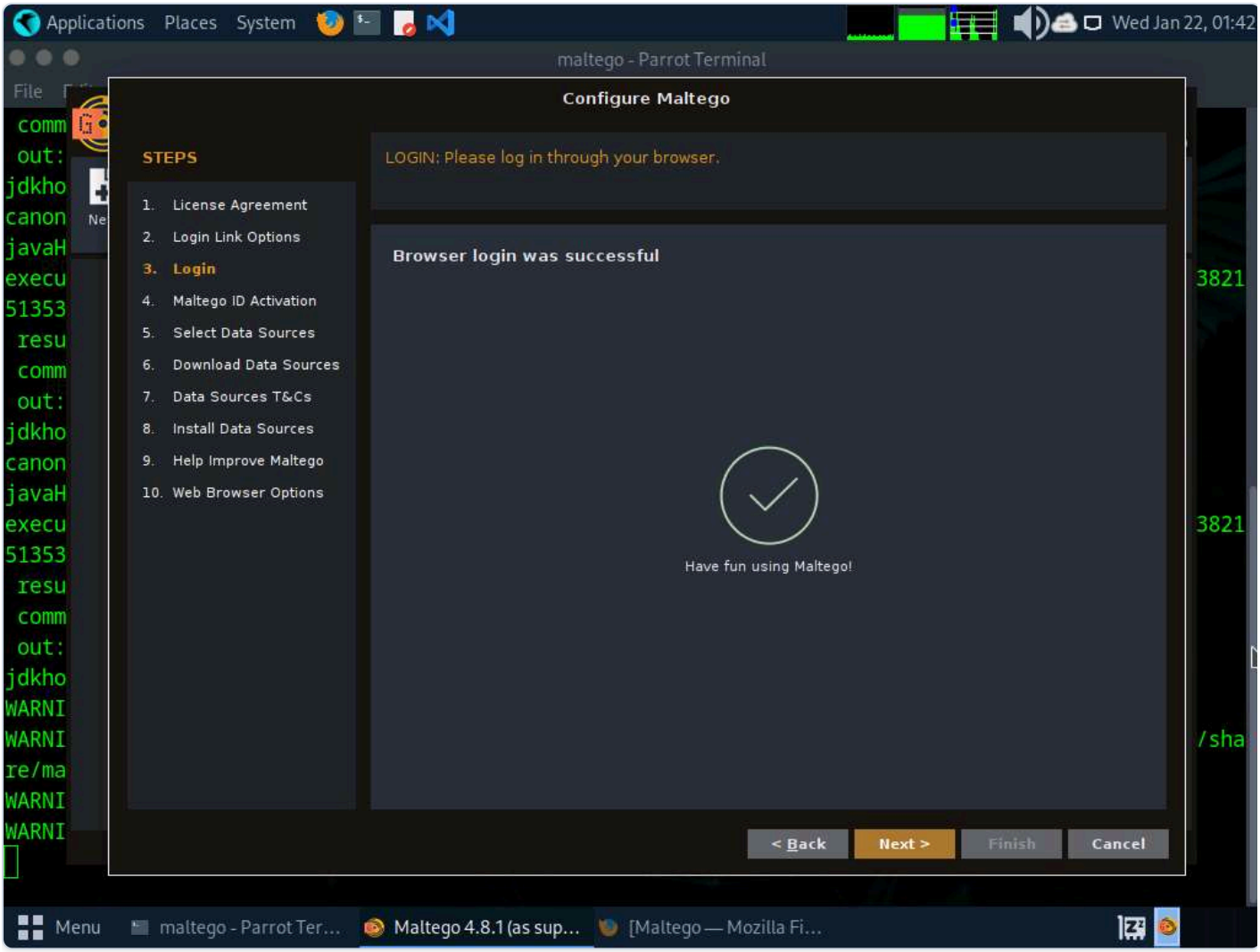



1. In the Complete Your Profile window enter the details and click **Continue**.

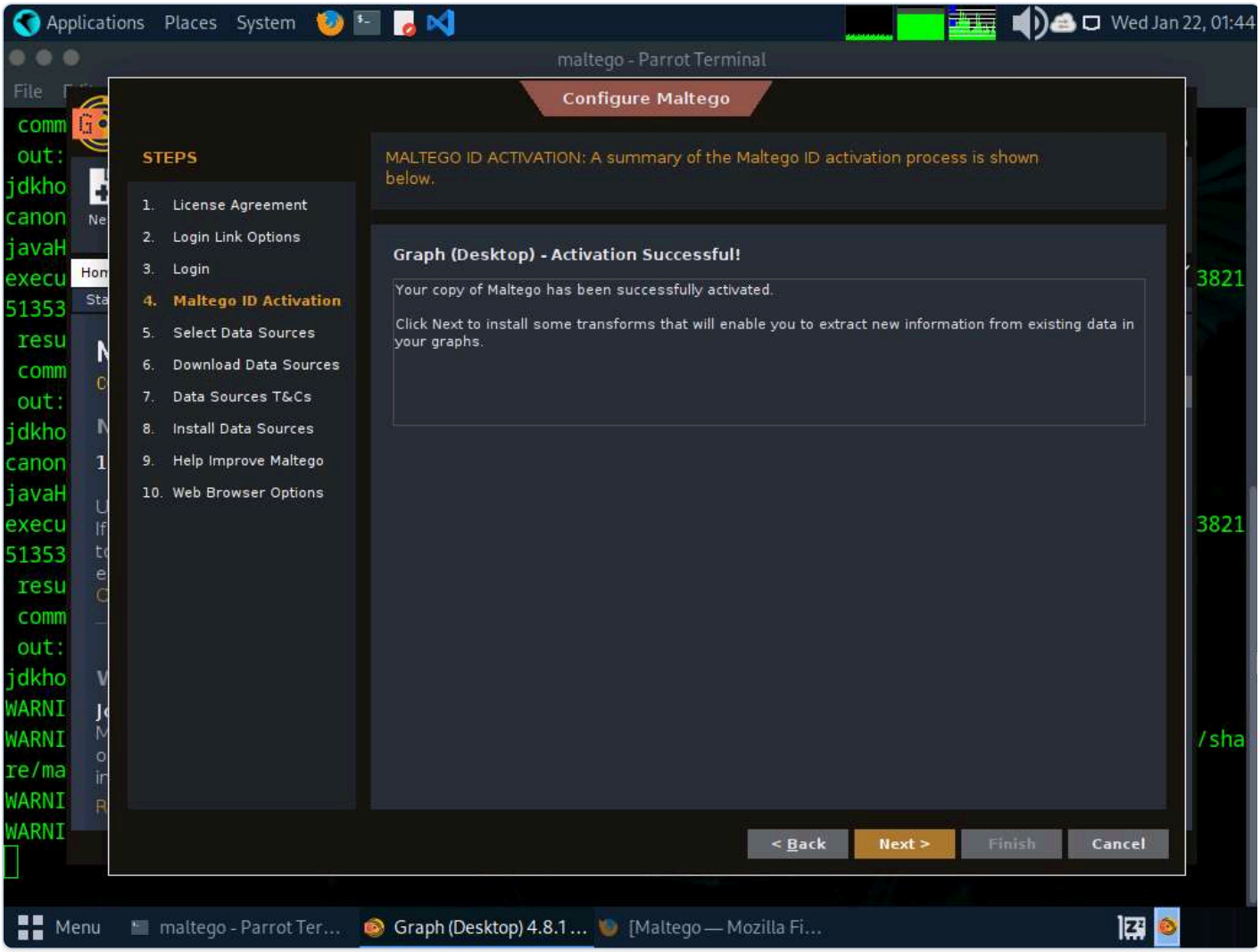

Applications Places System
Wed Jan 22, 01:37
login.maltego.com/consent?
https://login.maltego.com/consent?consent_challenge=0PrqJOYA8yUQWa9C5ys2aouD_x
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
Last Name *
Are you a student?
No
Yes
Country *
Due to export laws, Maltego products are unavailable in certain countries.
Area code *
Phone number *
I would like to receive updates about Maltego product updates, news, events and offers.
CONTINUE
© Maltego Technologies · ISO 27001:2022 Certified
Menu
maltego - Parrot Ter...
Maltego 4.8.1 (as sup...
Mozilla Firefox



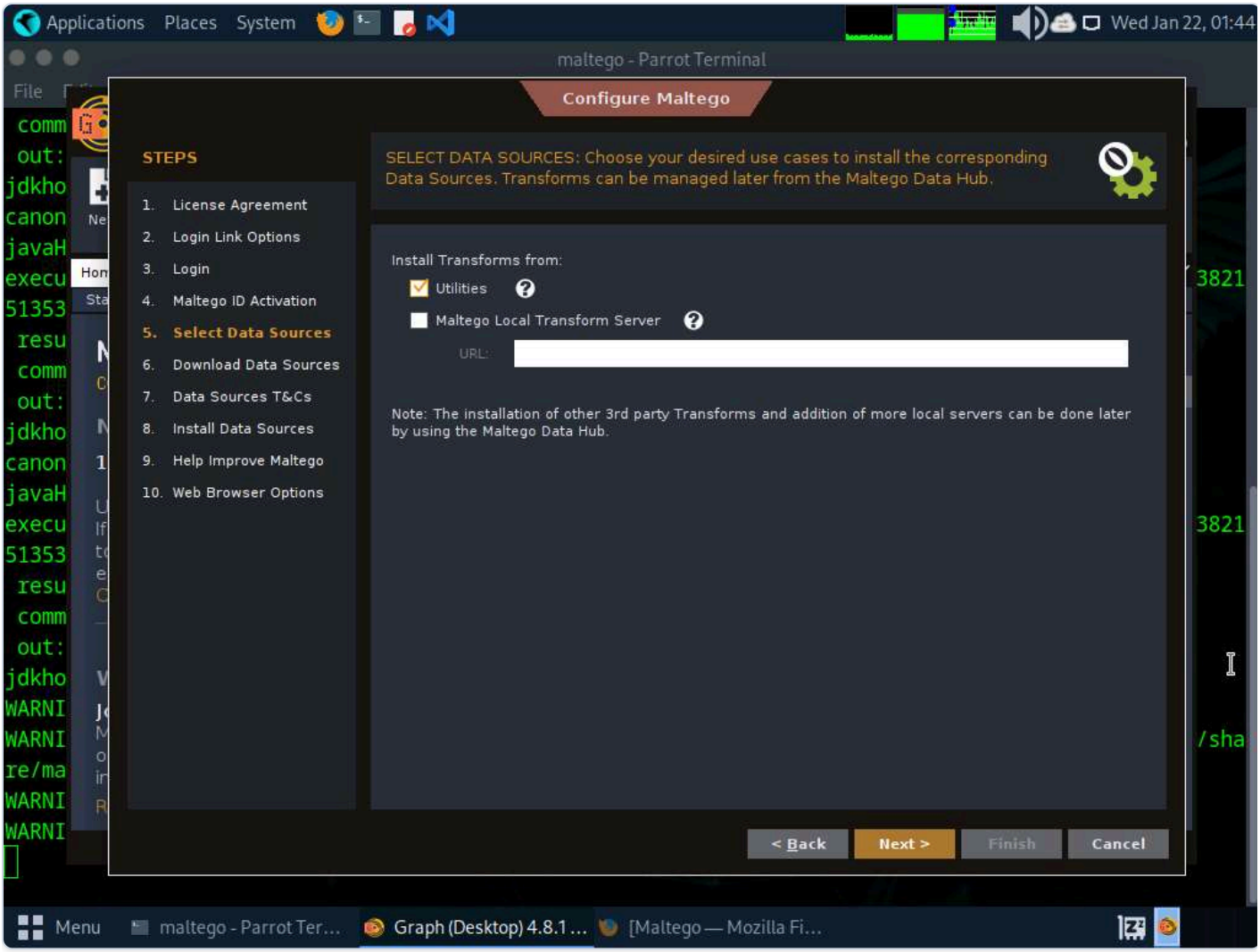

1. Authentication Complete window appears. Minimize the web browser, go back to the setup wizard, and click **Next** in the Login section.



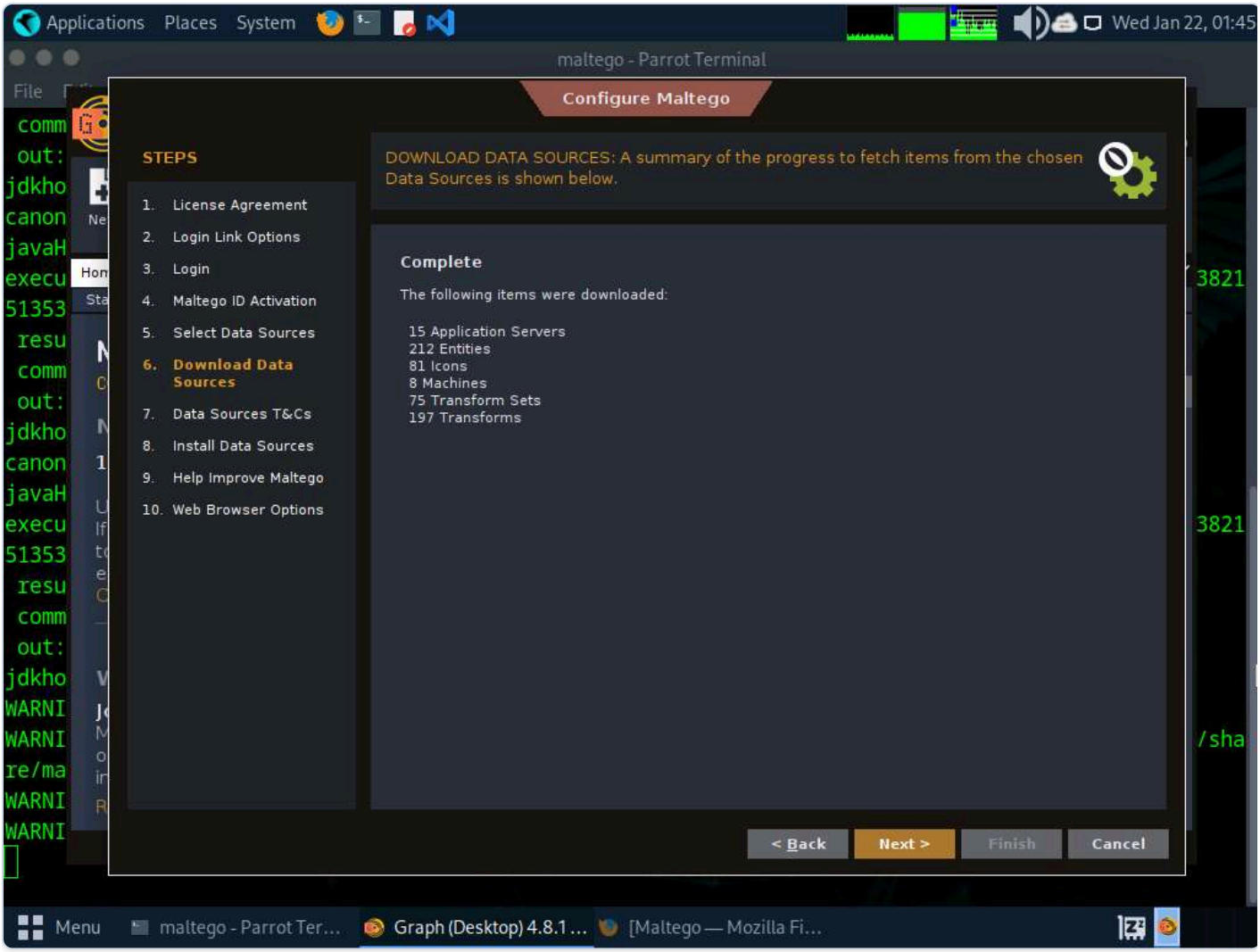

1. In the Maltego ID Activation window, click **Next**.



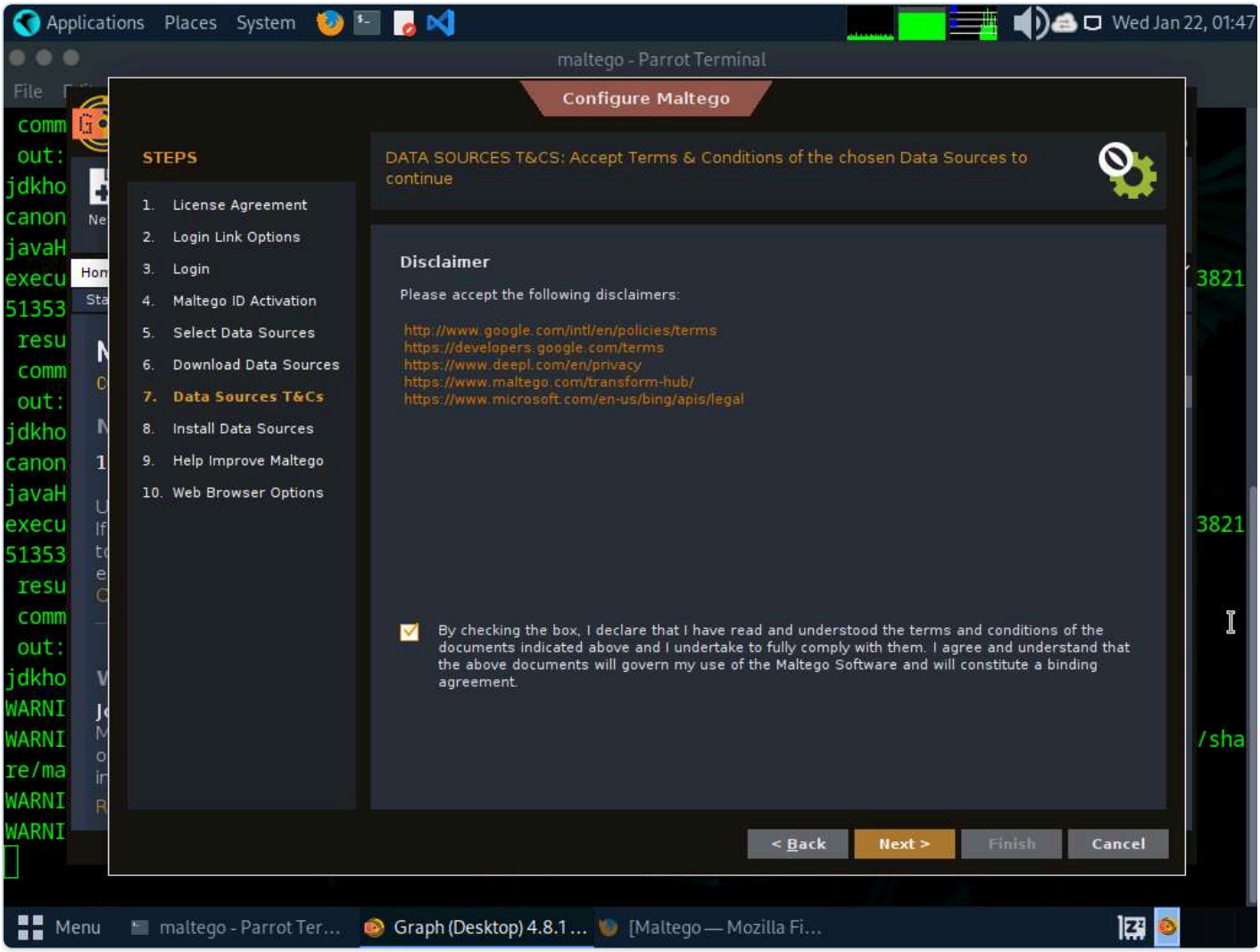

1. The Select Data Sources section appears, check the checkbox before **Utilities**; click **Next**.



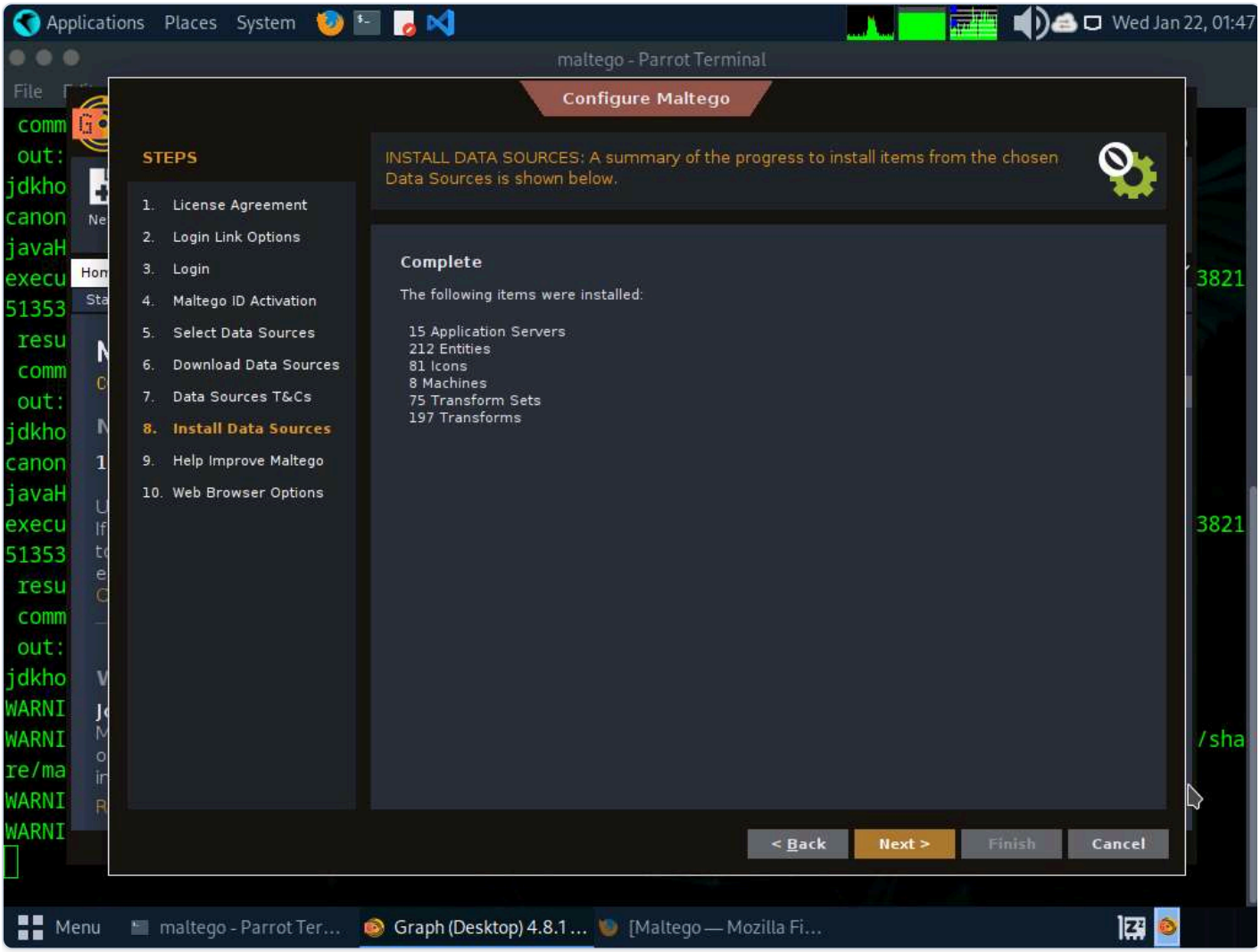

1. In the Download Data Sources window click **Next**.
    - *(If any connection issue error appears, change the system proxy to No Proxy and try again.)*



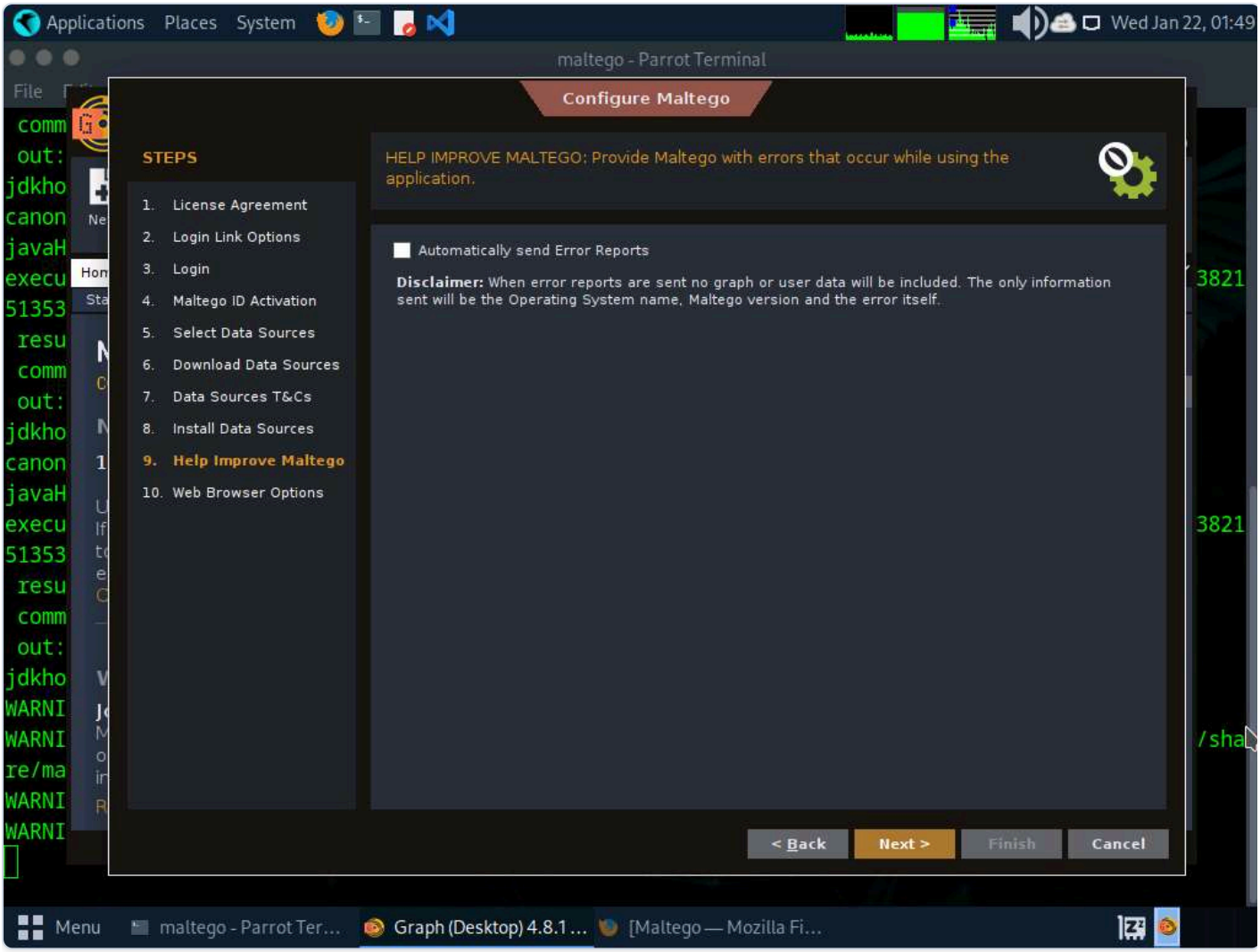

1. In the Data Sources T&C check the checkbox to accept terms and conditions and click **Next**.



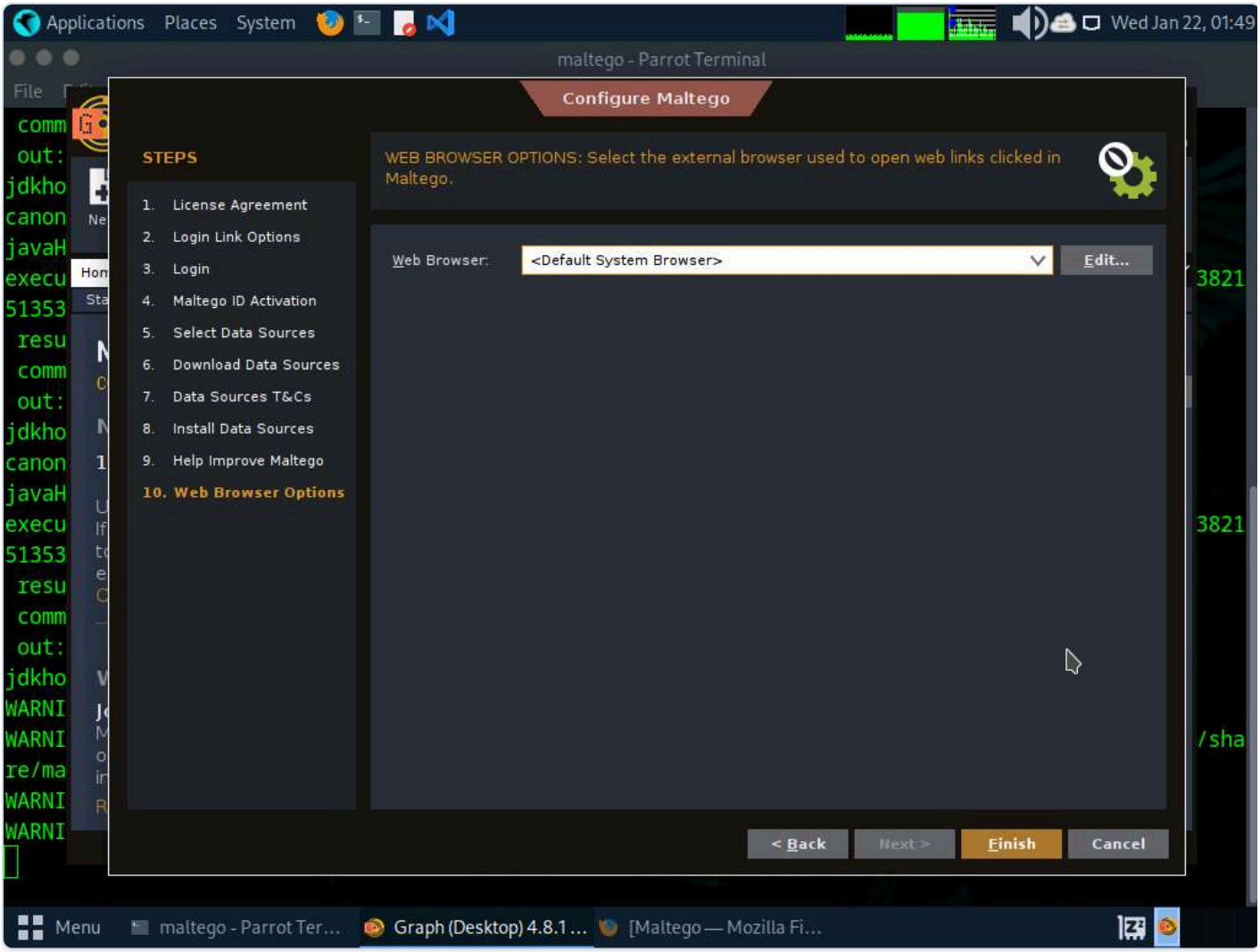

1. The Install Data Sources section appears, which will download items from the chosen transform server; click **Next**.



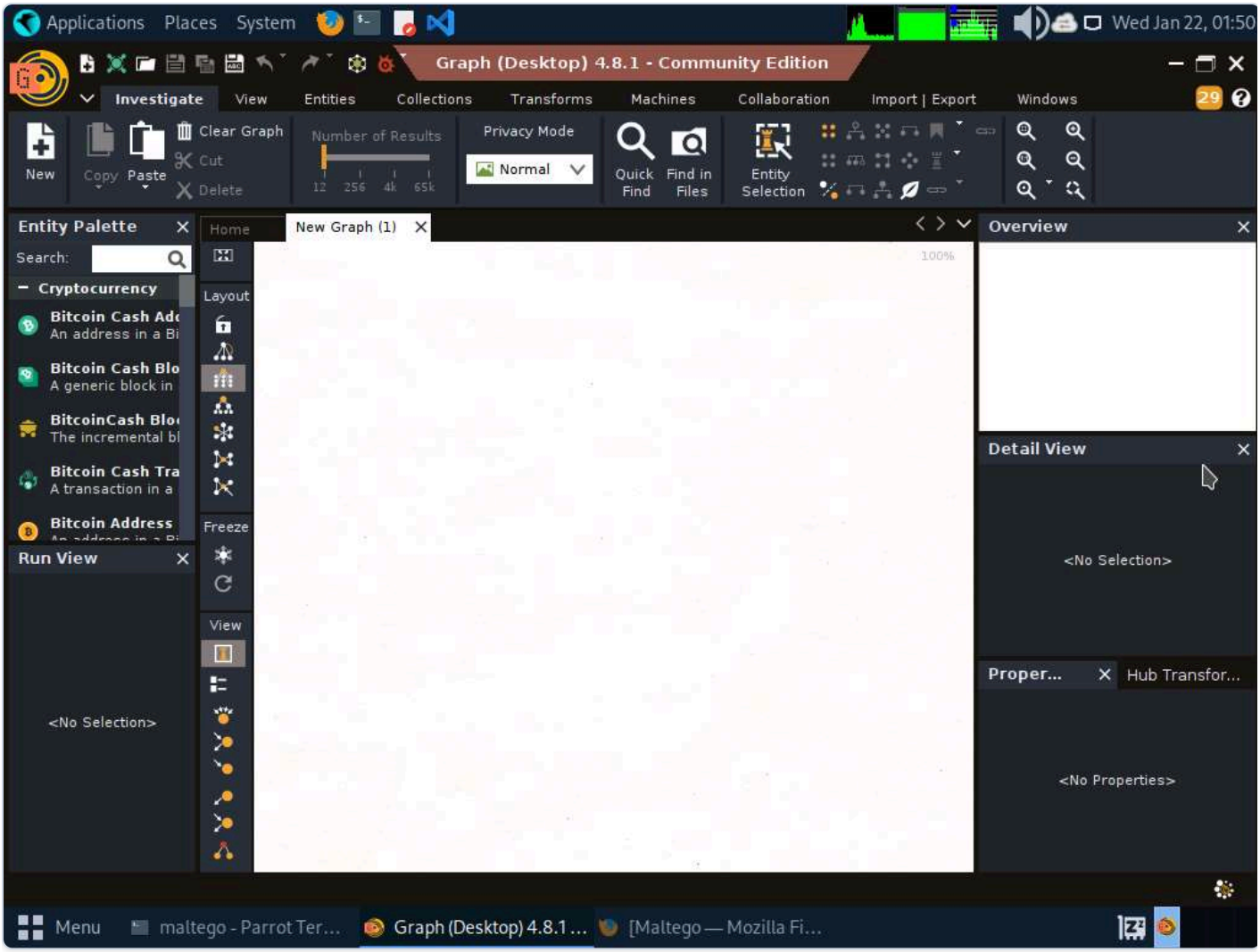

1. The Help Improve Maltego section appears. Leave the options set to default and click **Next**.



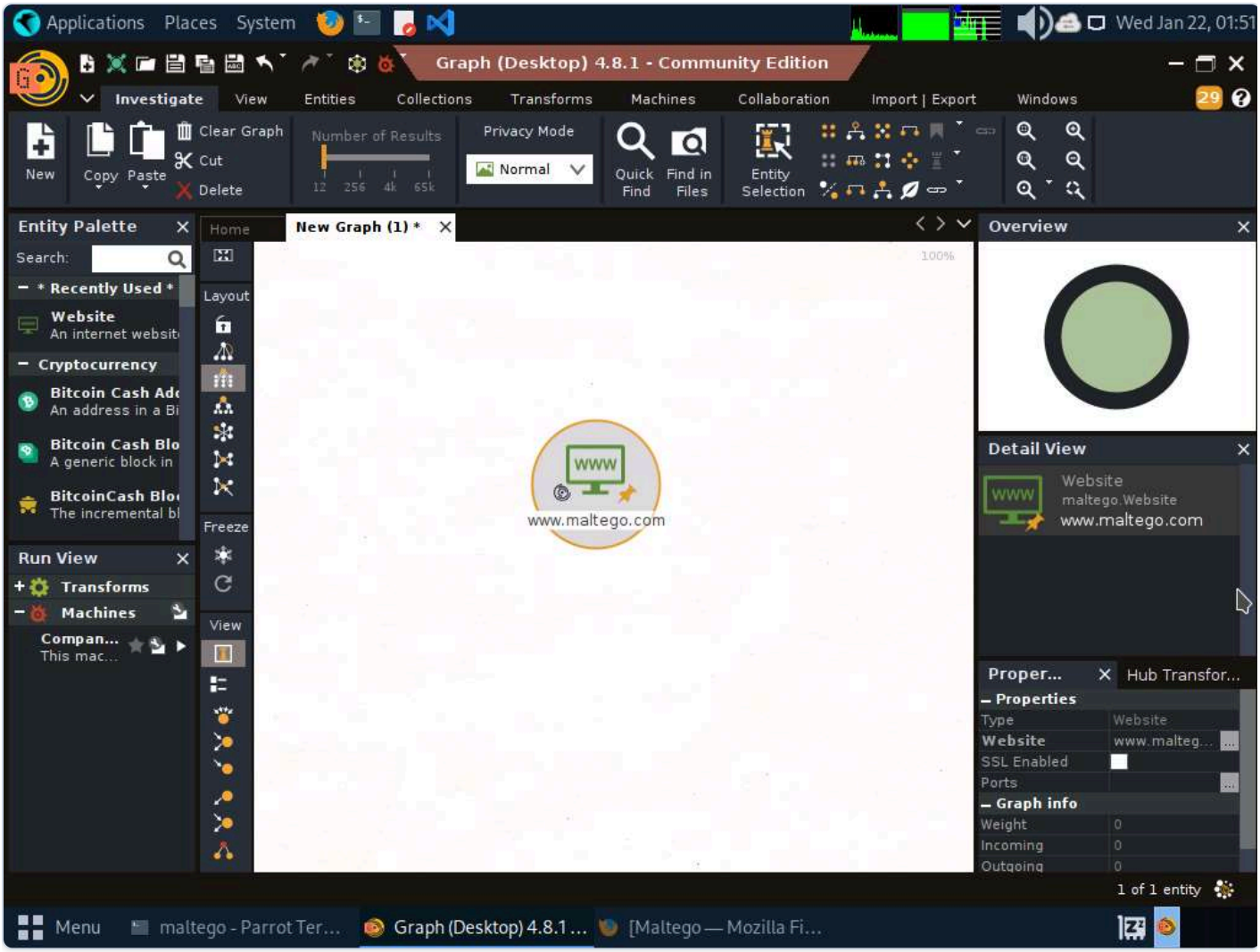

1. In Web Browser Options click **Next** and then in the Privacy Mode Options section appears. Leave the options set to default and click **Finish**.



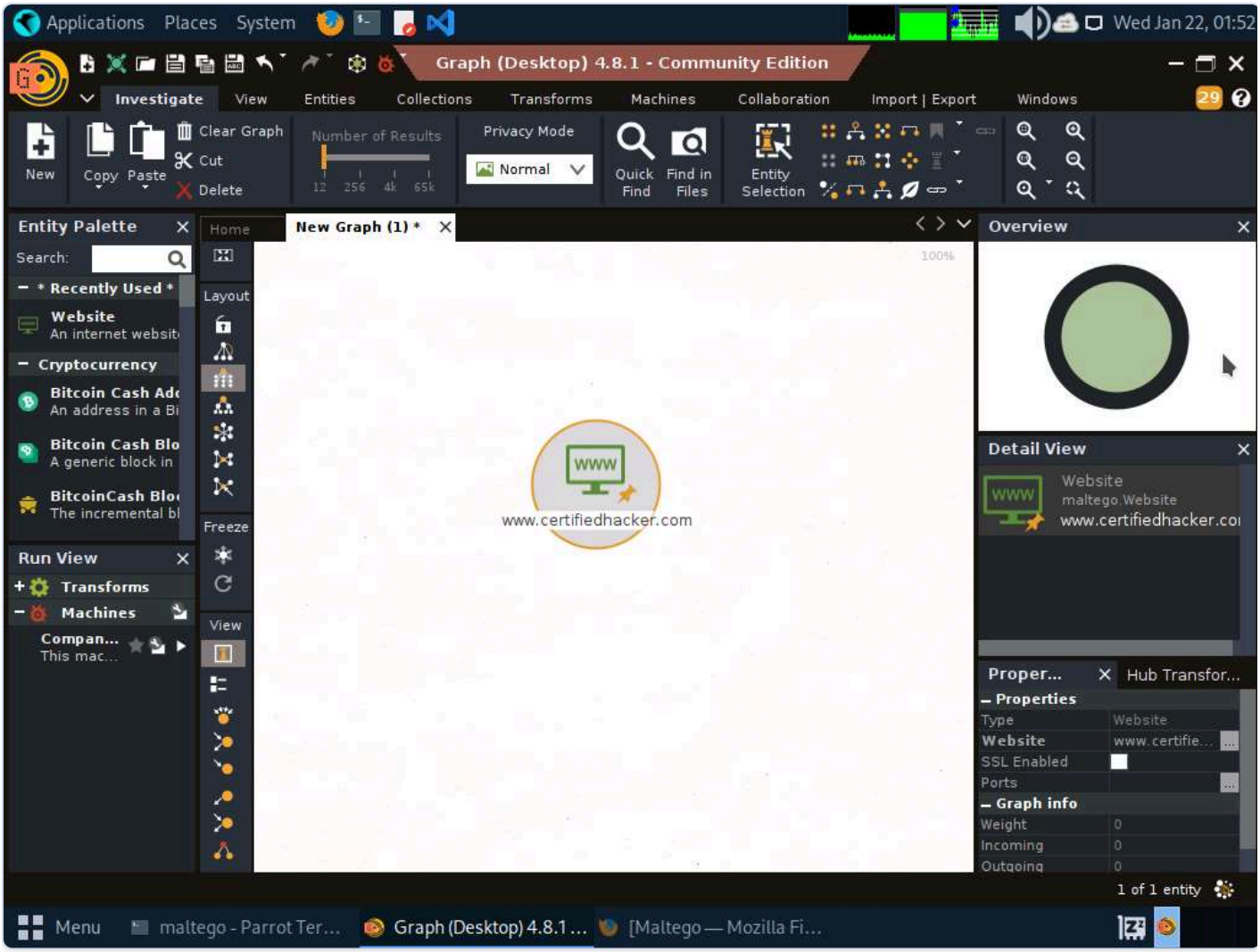

1. The Maltego Community Edition GUI appears, and the **New Graph (1)** window will be automatically launched, as shown in the screenshot.
   - *(If the New Graph (1) window does not open automatically, click the Create a new graph icon located at the top-left corner of the GUI in the toolbar to start a new graph.)*
   - *(If Privacy Notice pop-up displayed, click on Acknowledge and then I Understand. Previous Configuration Found pop-up appears, click No.)*



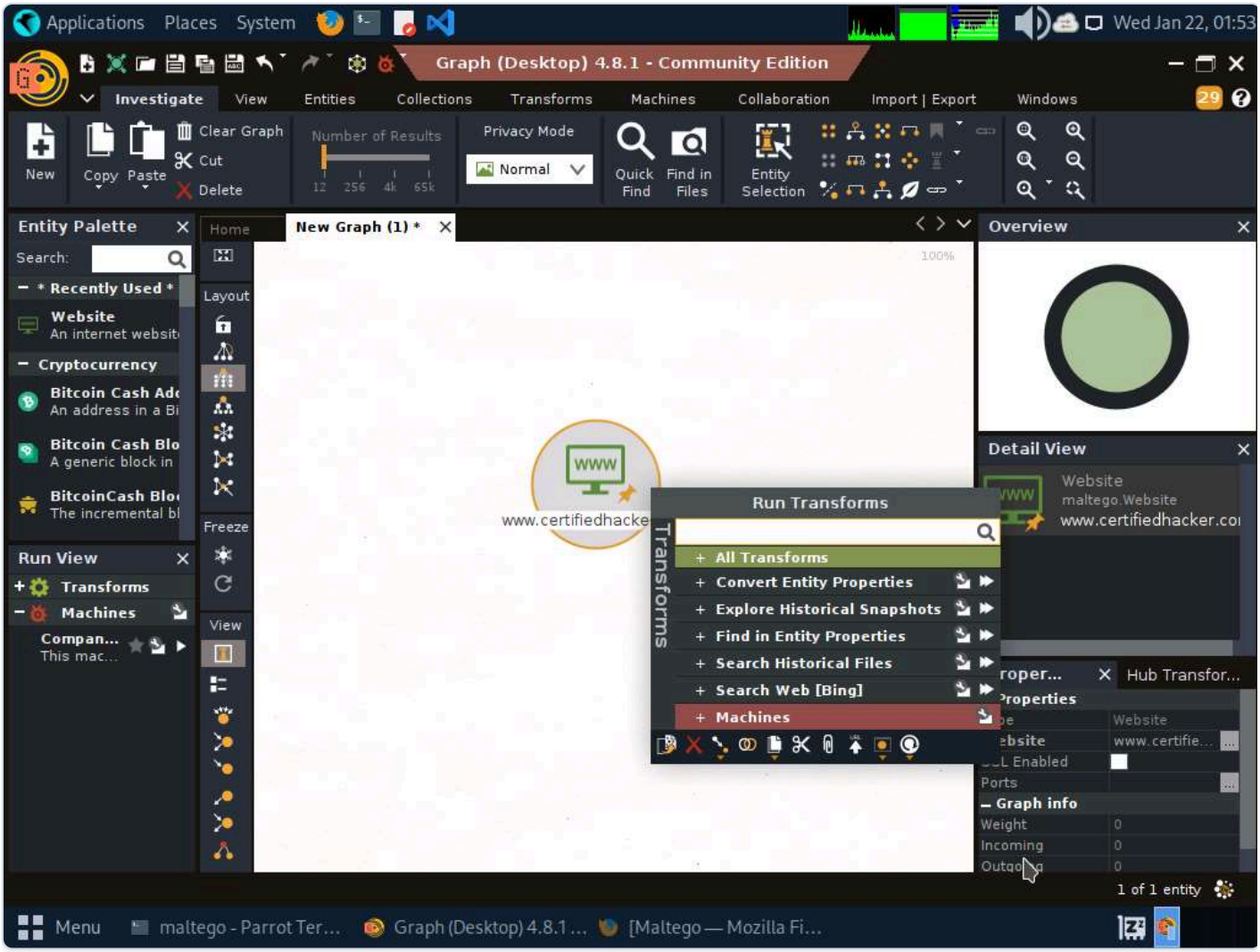

1. In the left pane of Maltego GUI, you can find the **Entity Palette** box, which contains a list of default built-in transforms. In the Infrastructure node under Entity Palette, observe a list of entities such as AS, DNS Name, Domain, IPv4 Address, URL, Website, etc.
2. Drag the **Website** entity onto the **New Graph (1)** window.
3. The entity appears on the new graph, with the **www.maltego.com** URL selected by default.
   - *(If you are not able to view the entity as shown in the screenshot, click in the New Graph (1) window and scroll up, which will increase the size of the entity.)*



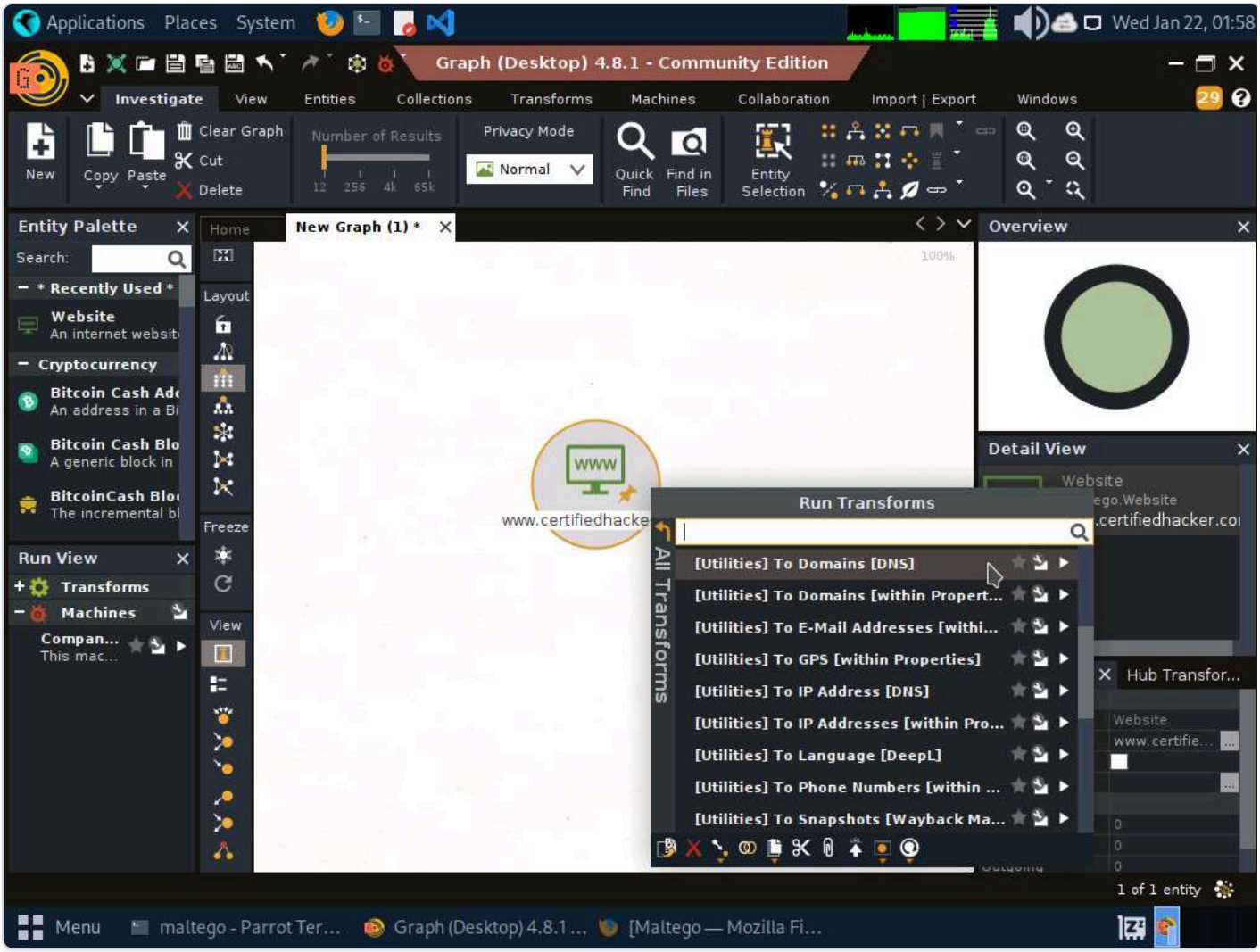

1. Double-click the name **www.maltego.com** and change the domain name to **www.certifiedhacker.com** press Enter.



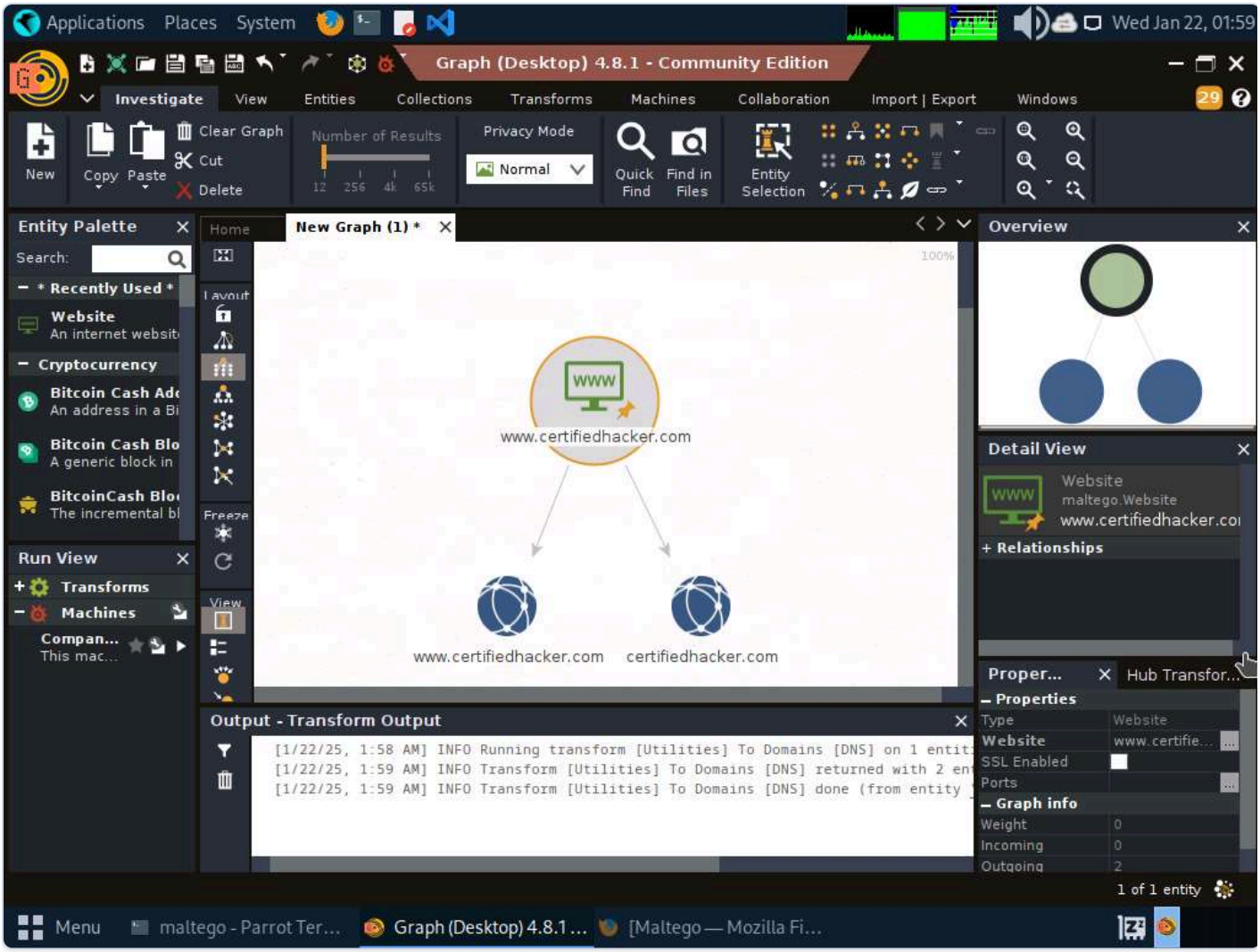

1. Right-click the **www.certifiedhacker.com** entity and select **All Transforms**.



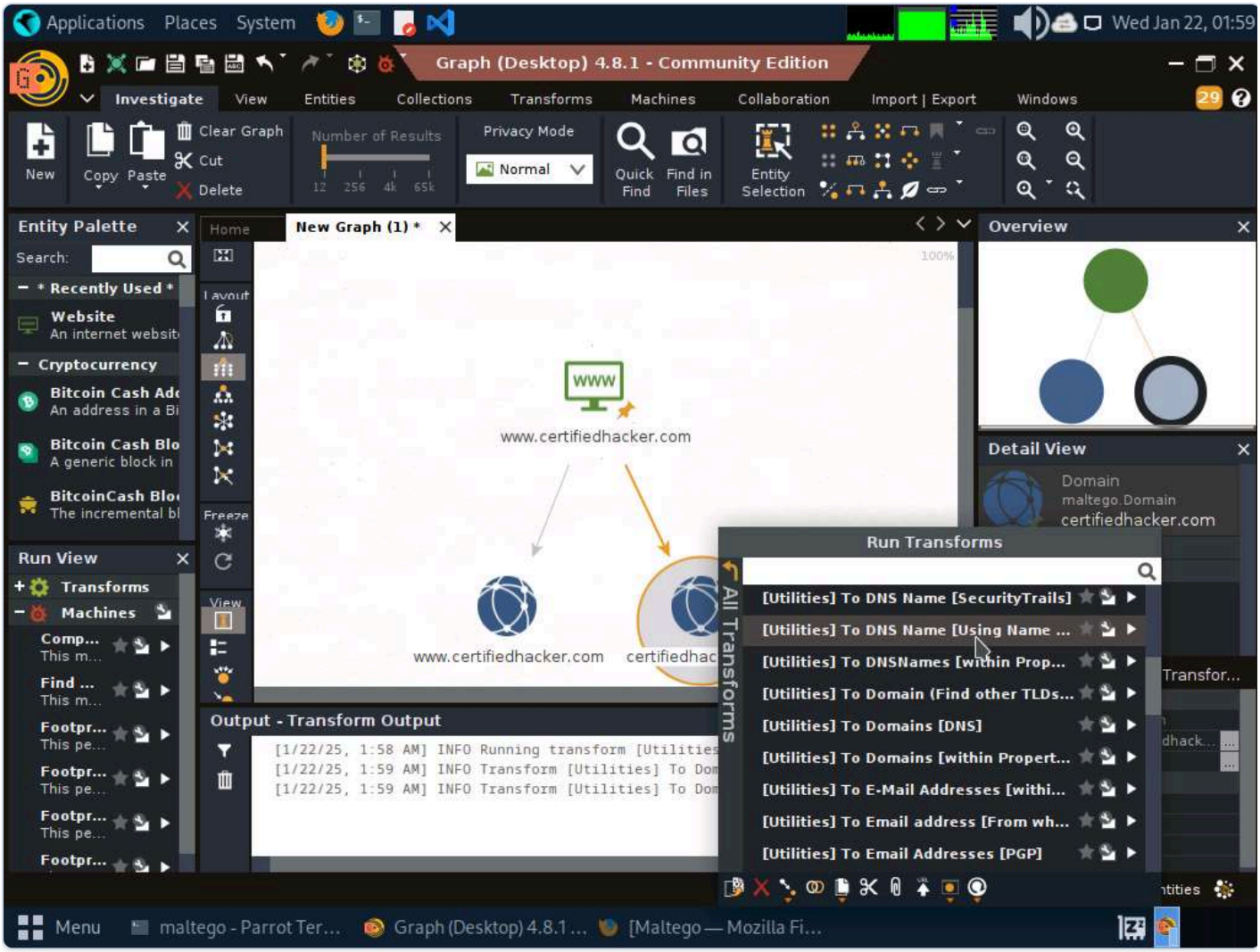

1. Now, click on **To Domains [DNS]**.



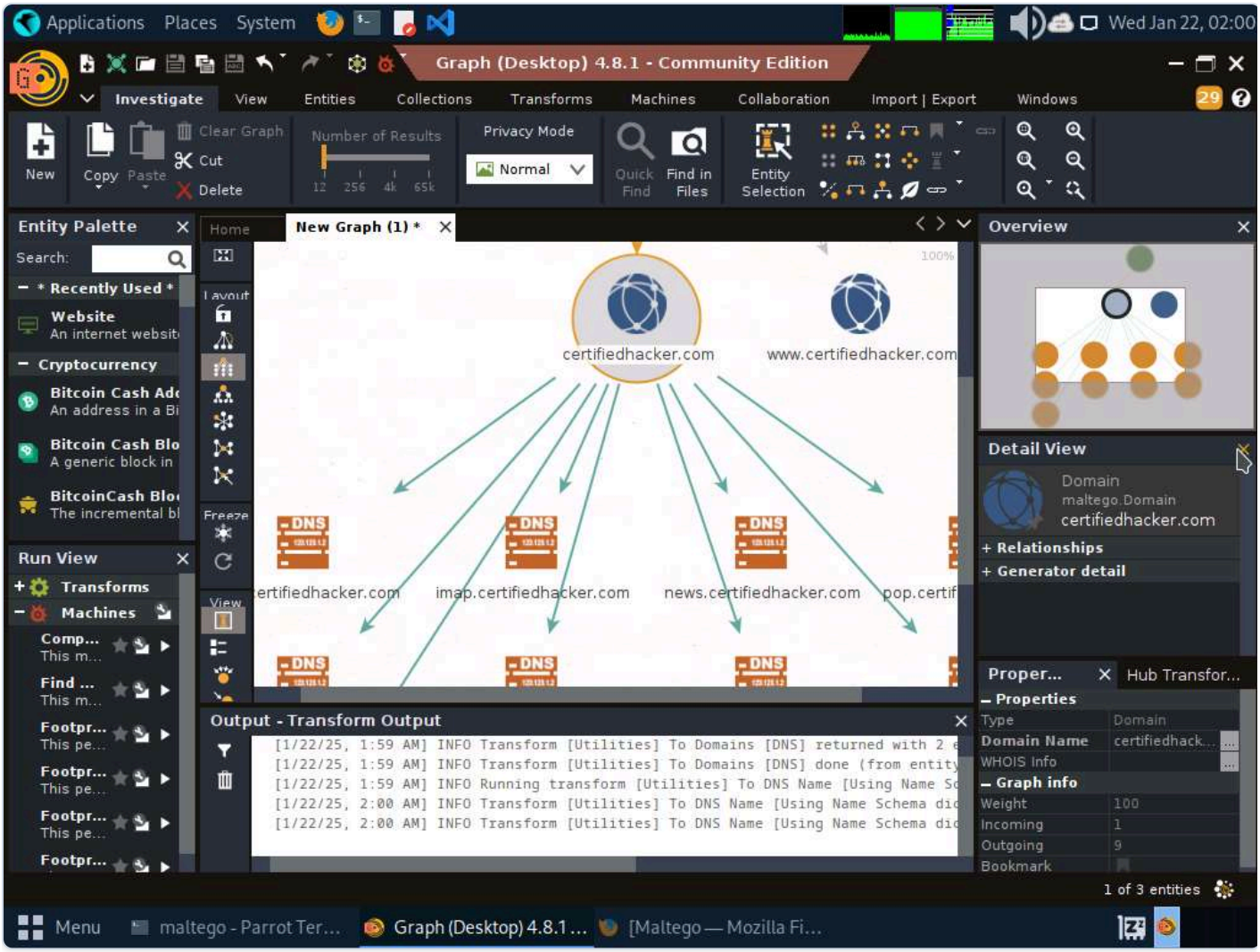

1. The domain corresponding to the website displays, as shown in the following screenshot.




1. Right-click the **certifiedhacker.com** entity from the results and select **To DNS Name [Using Name Schema dictionary]**.

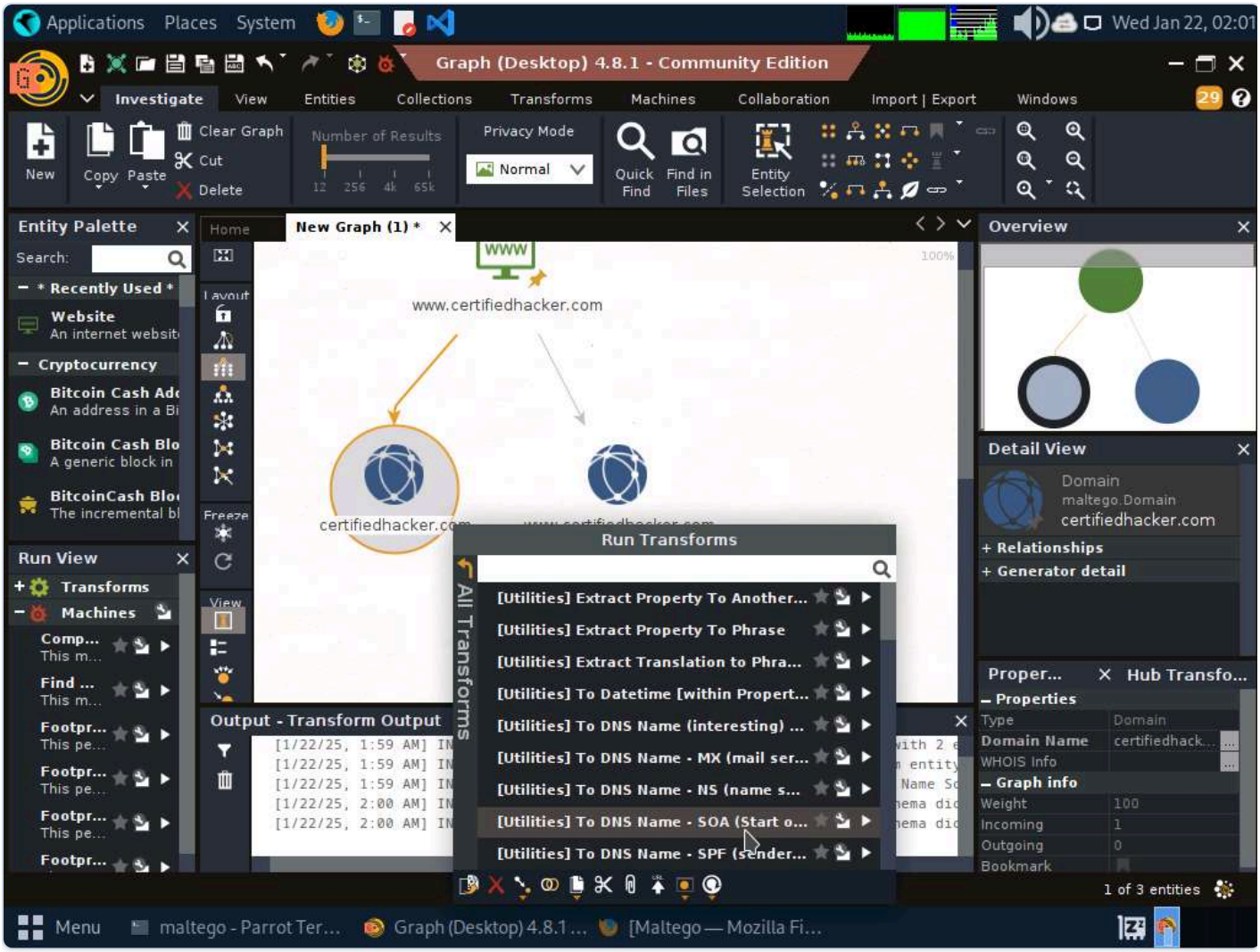



1. Observe the status in the progress bar. This transform will attempt to test various name schemas against a domain and try to identify a specific name schema for the domain, as shown in the following screenshot.

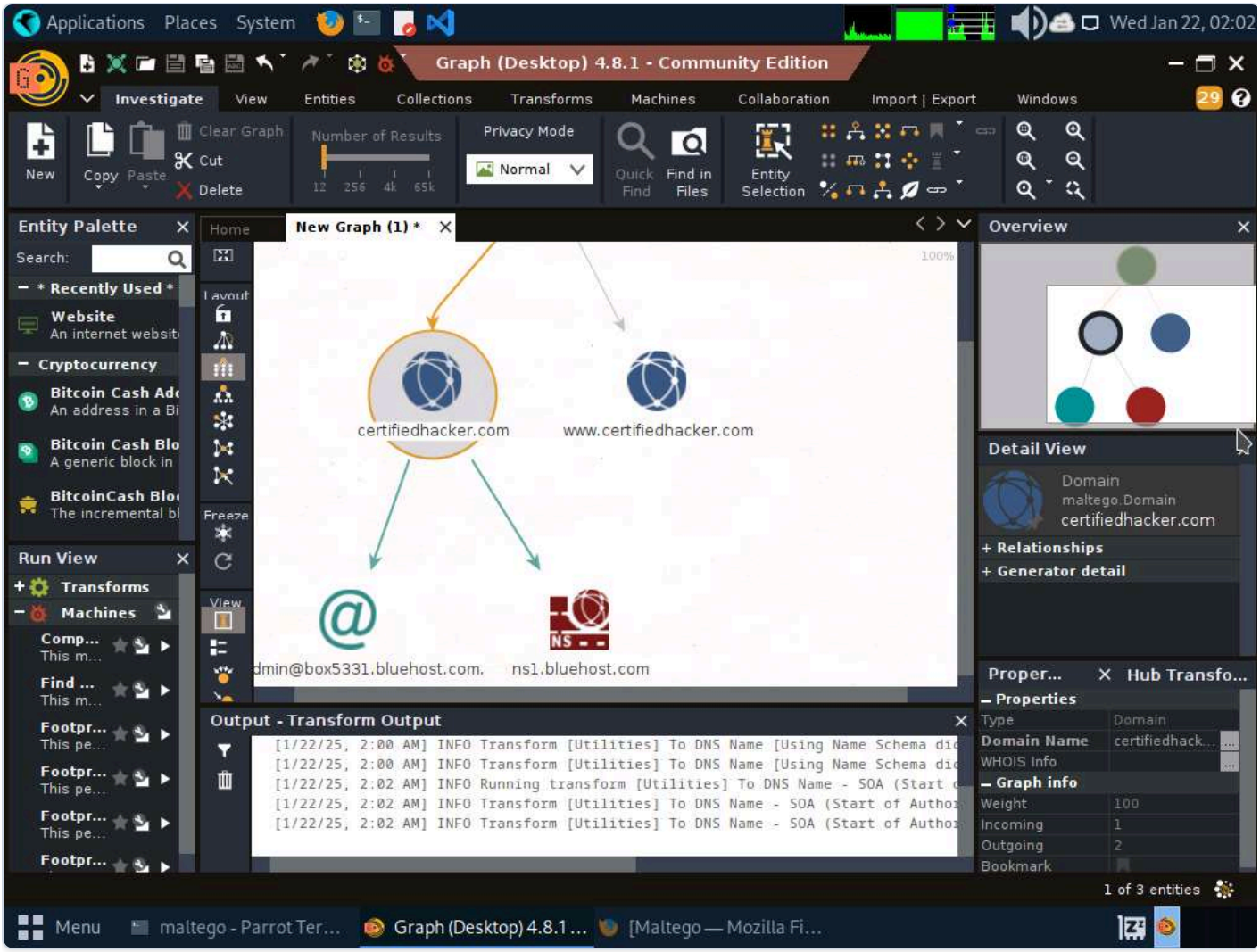



After identifying the name schema, attackers attempt to simulate various exploitation techniques to gain sensitive information related to the resultant name schemas. For example, an attacker may implement a brute-force or dictionary attack to log in to **ftp.certifiedhacker.com** and gain confidential information.

1. Select only the name schemas and delete all by selecting them.
2. Right-click the **certifiedhacker.com** entity and select **All Transforms** --> **To DNS Name - SOA (Start of Authority)**.

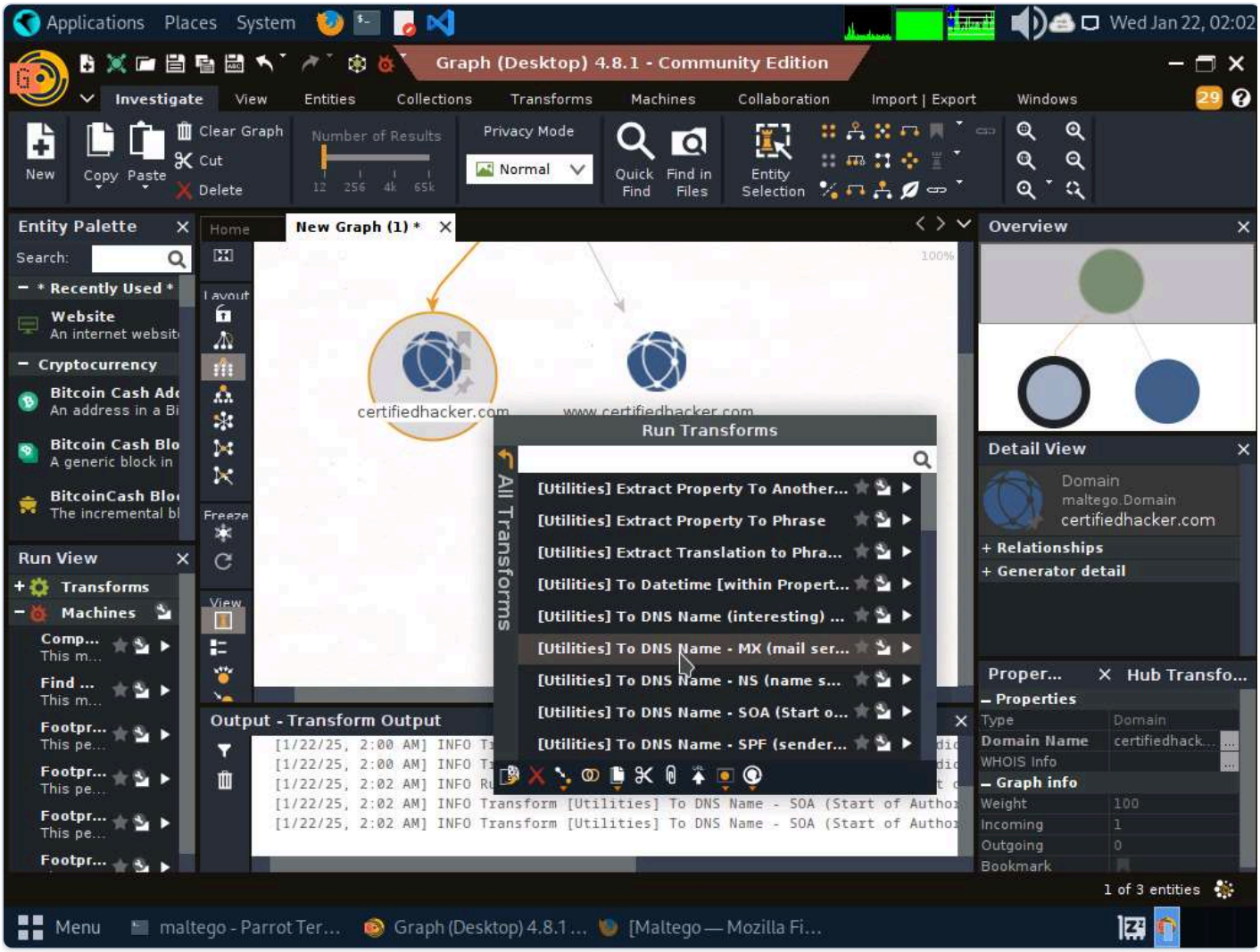



1. This returns the primary name server and the email of the domain administrator, as shown in the following screenshot.

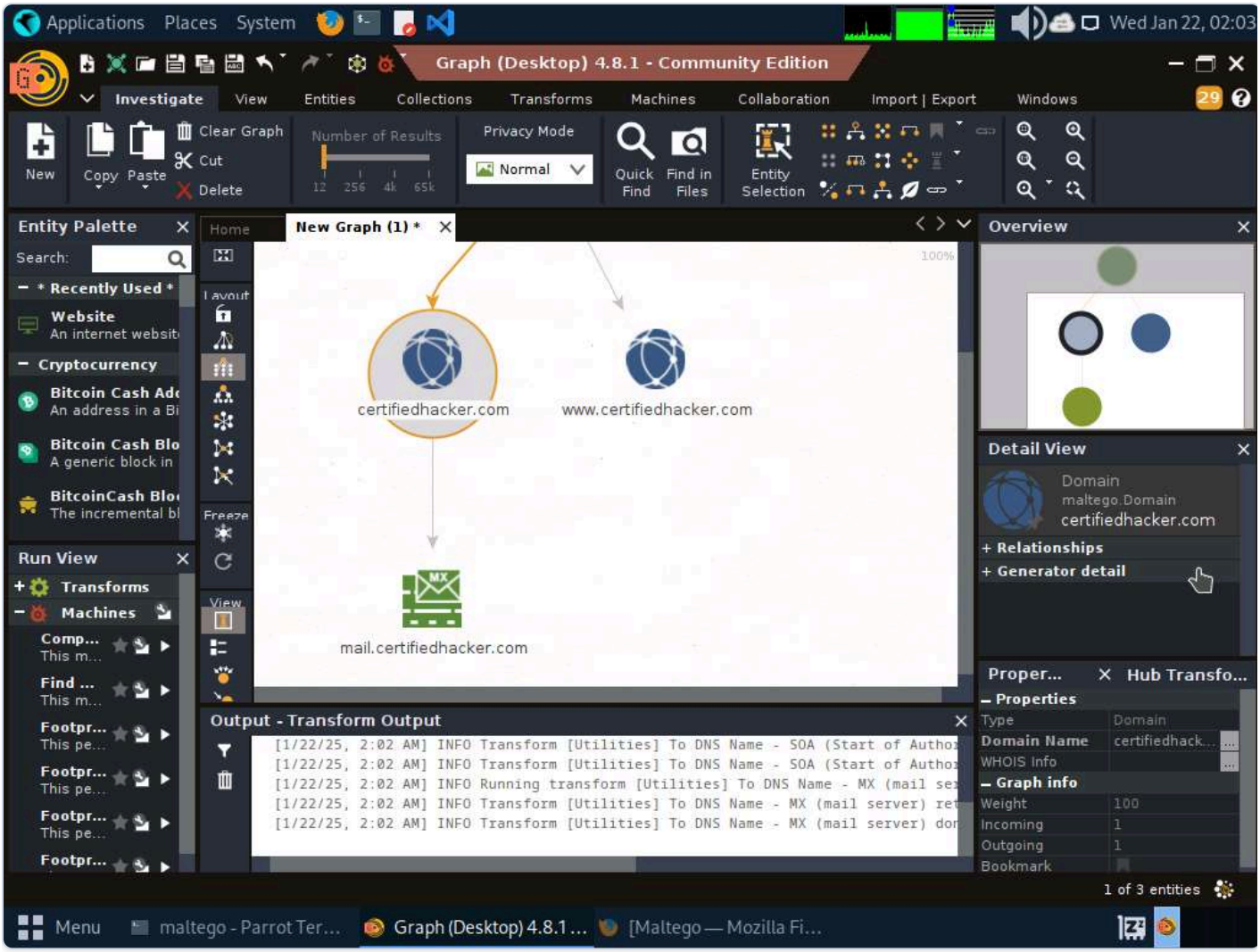



By extracting SOA-related information, attackers attempt to find vulnerabilities in their services and architectures and exploit them.

1. Select both the name server and the email and delete them.
2. Right-click the **certifiedhacker.com** entity and select **All Transforms** --> **To DNS Name - MX (mail server)**.

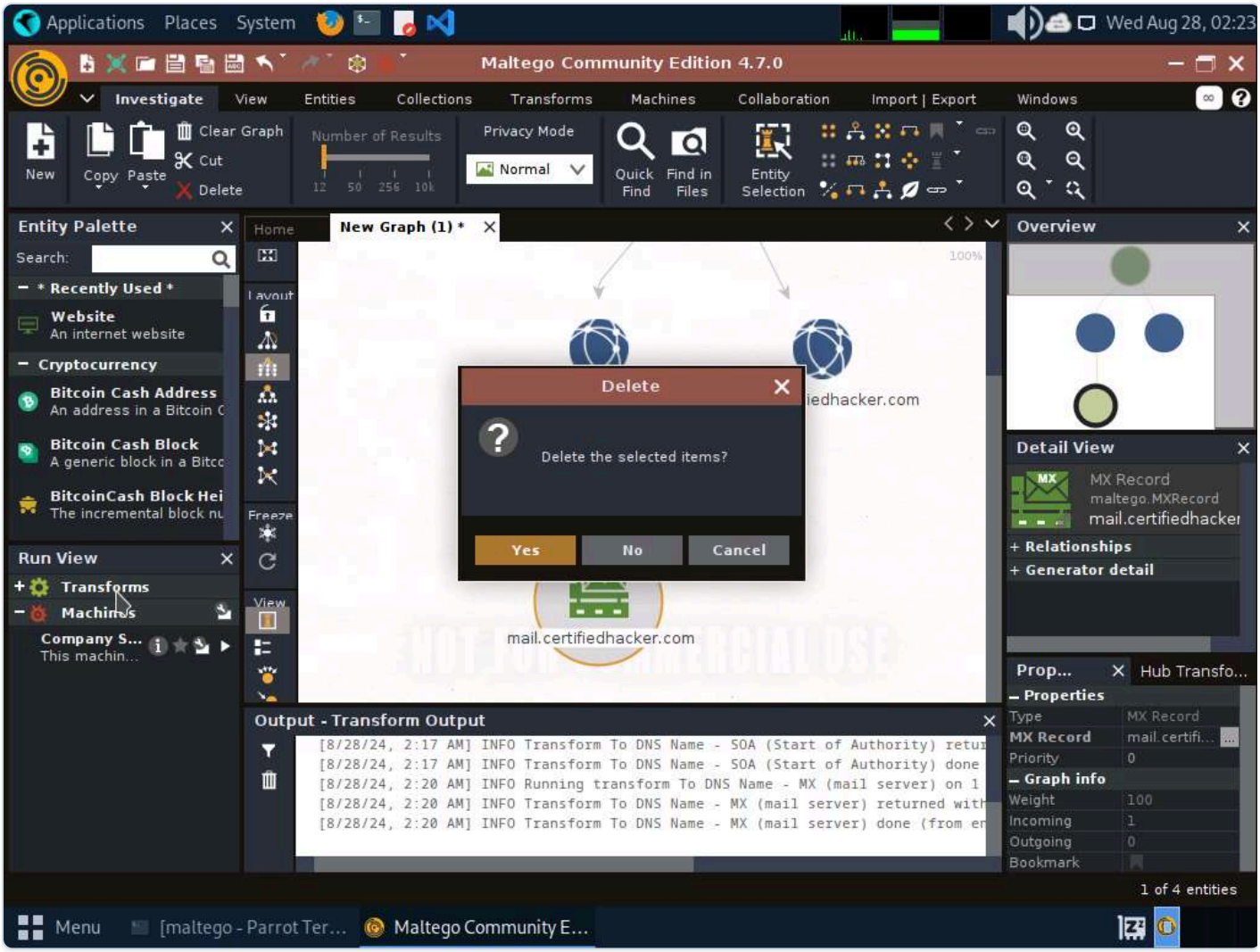



1. This transform returns the mail server associated with the **certifiedhacker.com** domain, as shown in the following screenshot.

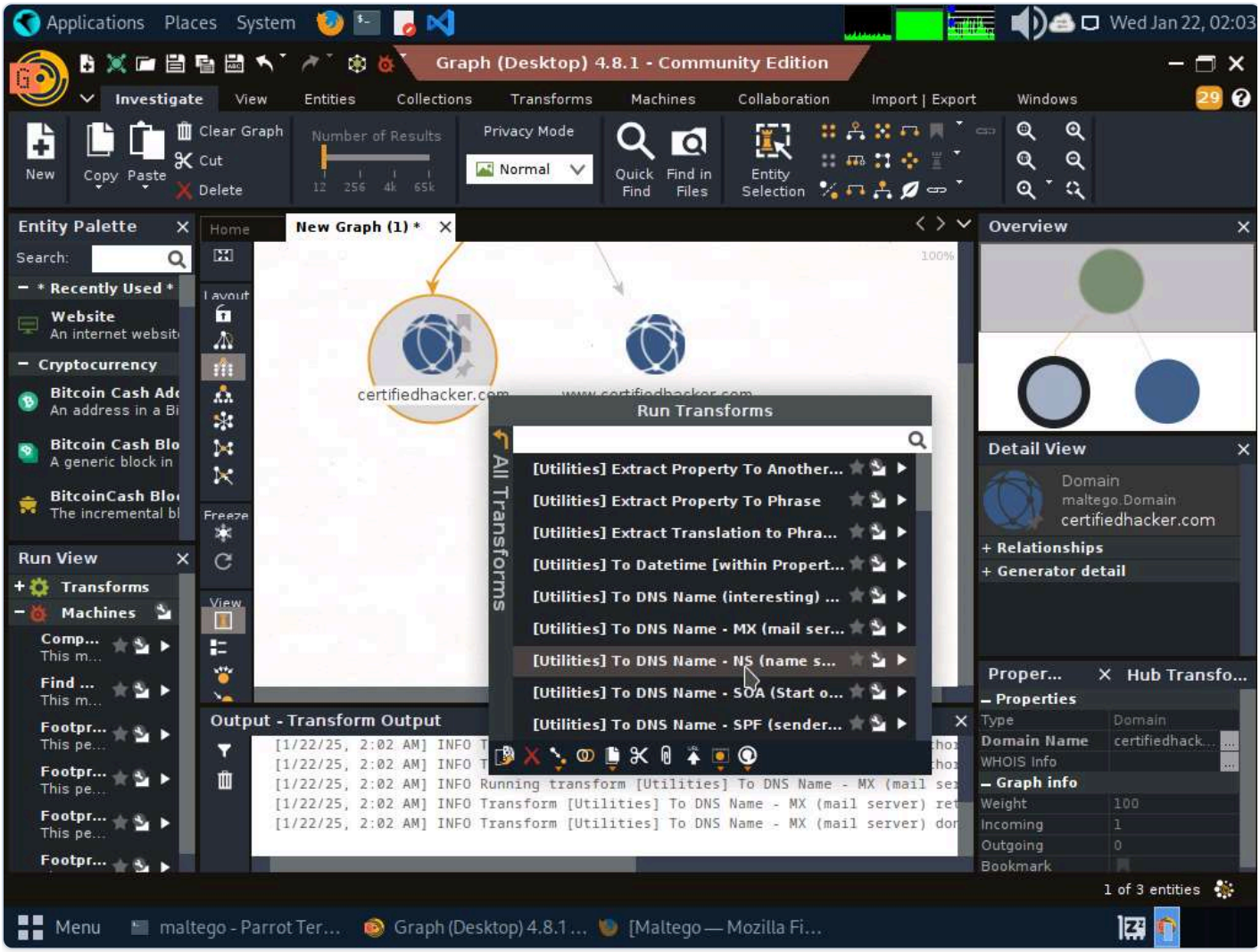



By identifying the mail exchanger server, attackers attempt to exploit the vulnerabilities in the server and, thereby, use it to perform malicious activities such as sending spam e-mails.

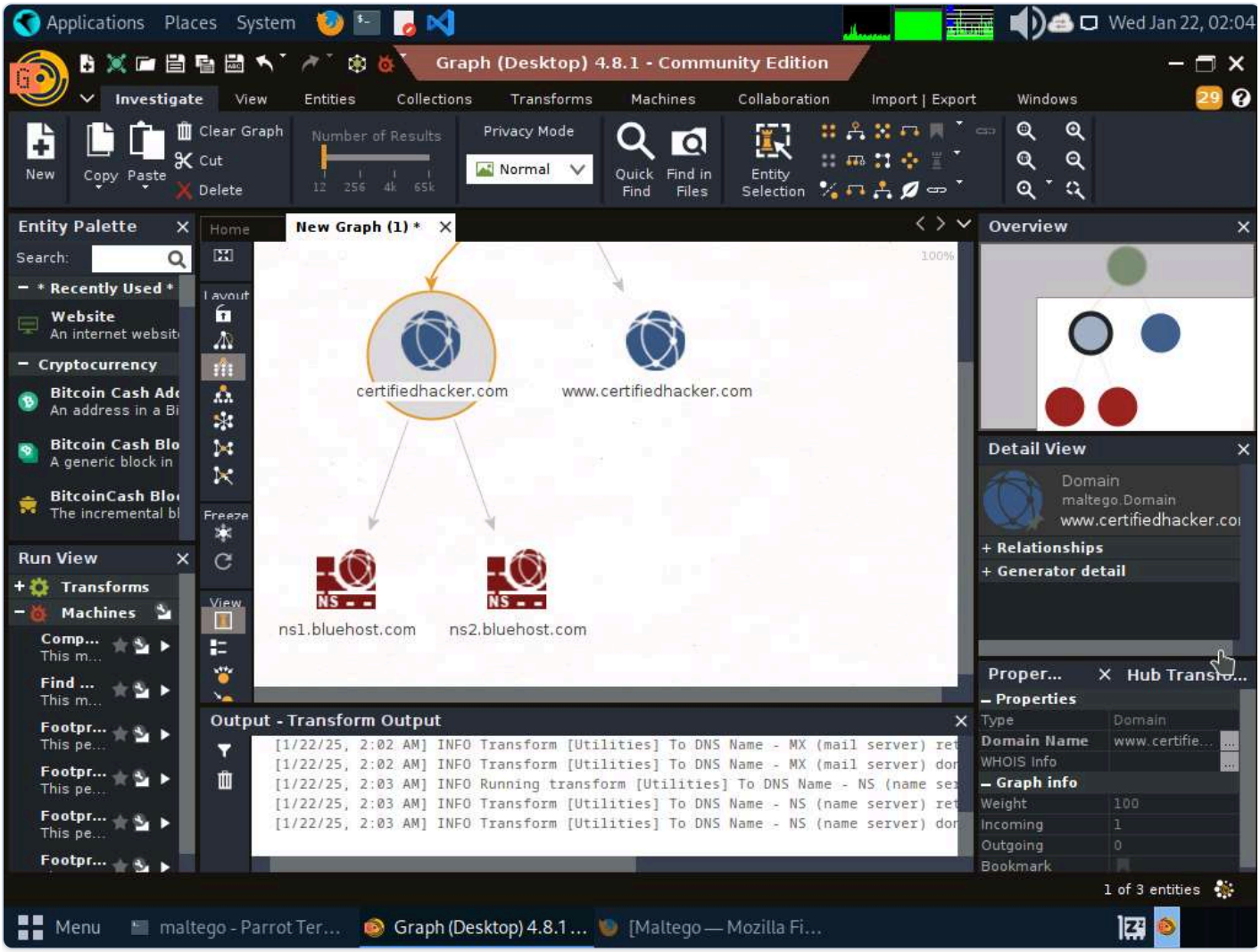
1. Select only the mail server and delete it.




1. Right-click the **certifiedhacker.com** entity and select **All Transforms** --> **To DNS Name - NS (name server)**.

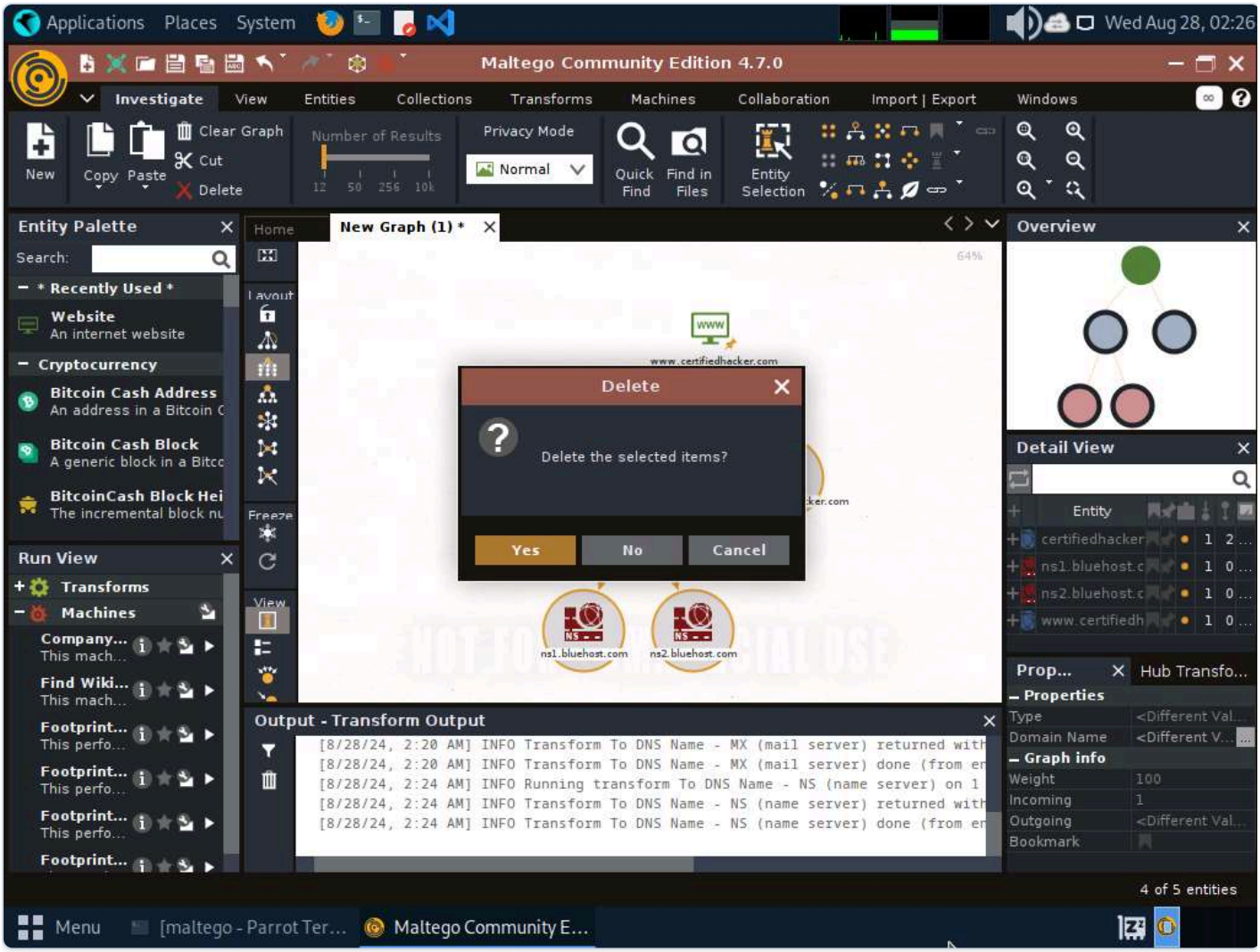



1. This returns the name servers associated with the domain, as shown in the following screenshot.

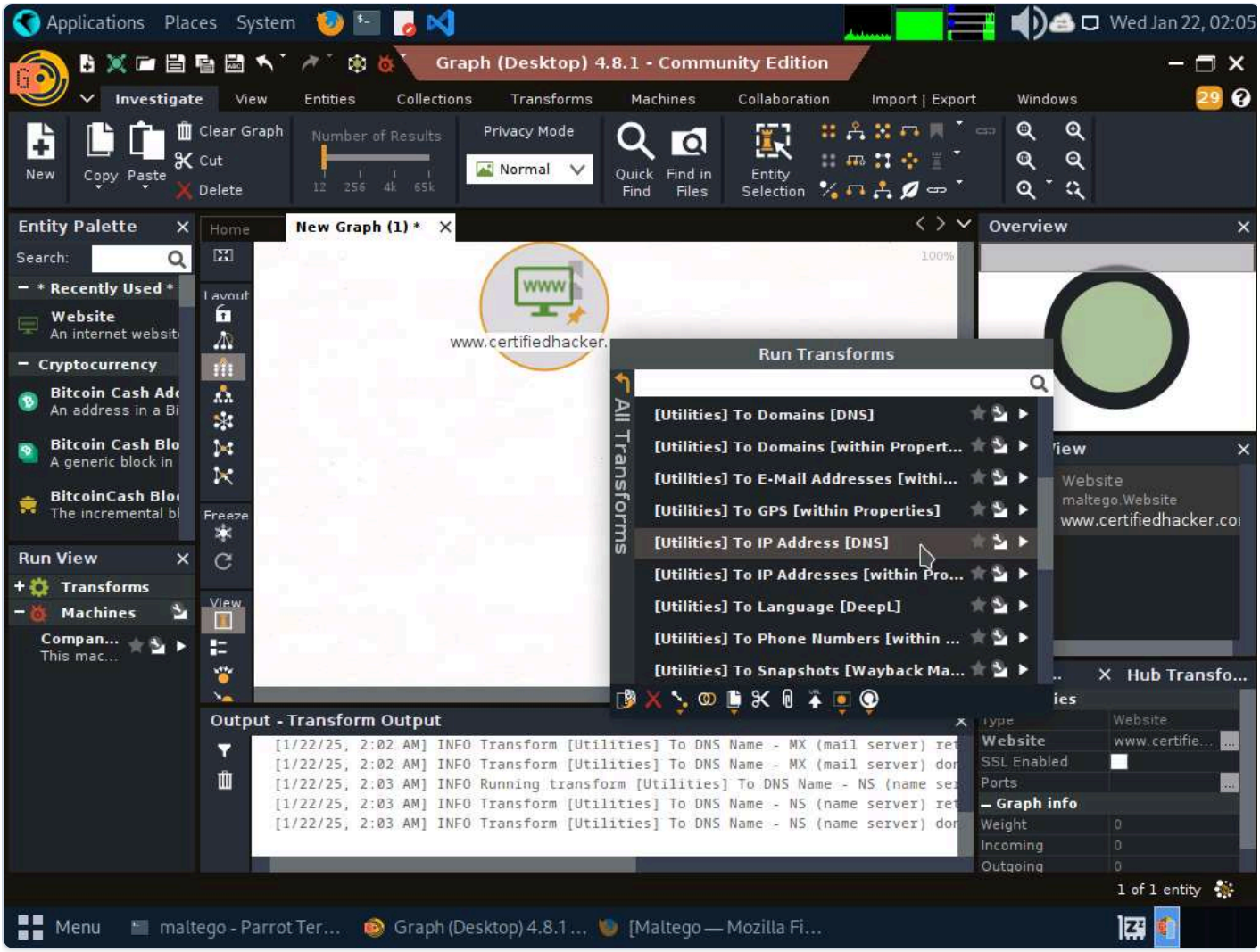



By identifying the primary name server, an attacker can implement various techniques to exploit the server and thereby perform malicious activities such as DNS Hijacking and URL redirection.

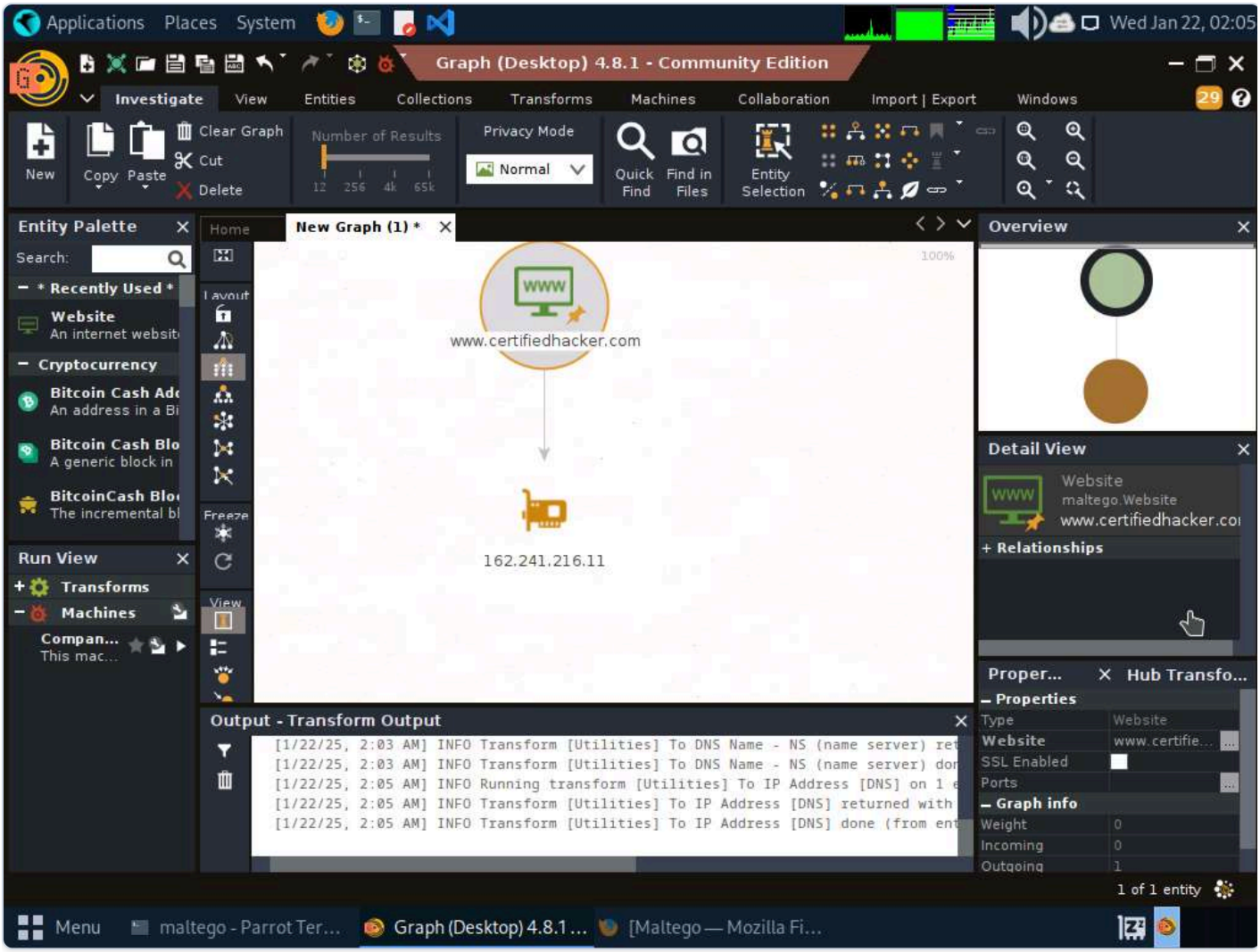
1. Select both the domain and the name server and delete them. In the same way delete **certifiedhacker.com** and **www.certifiedhacker.com** entities.




1. Right-click the entity and select **All Transforms** --> **To IP Address [DNS]**.

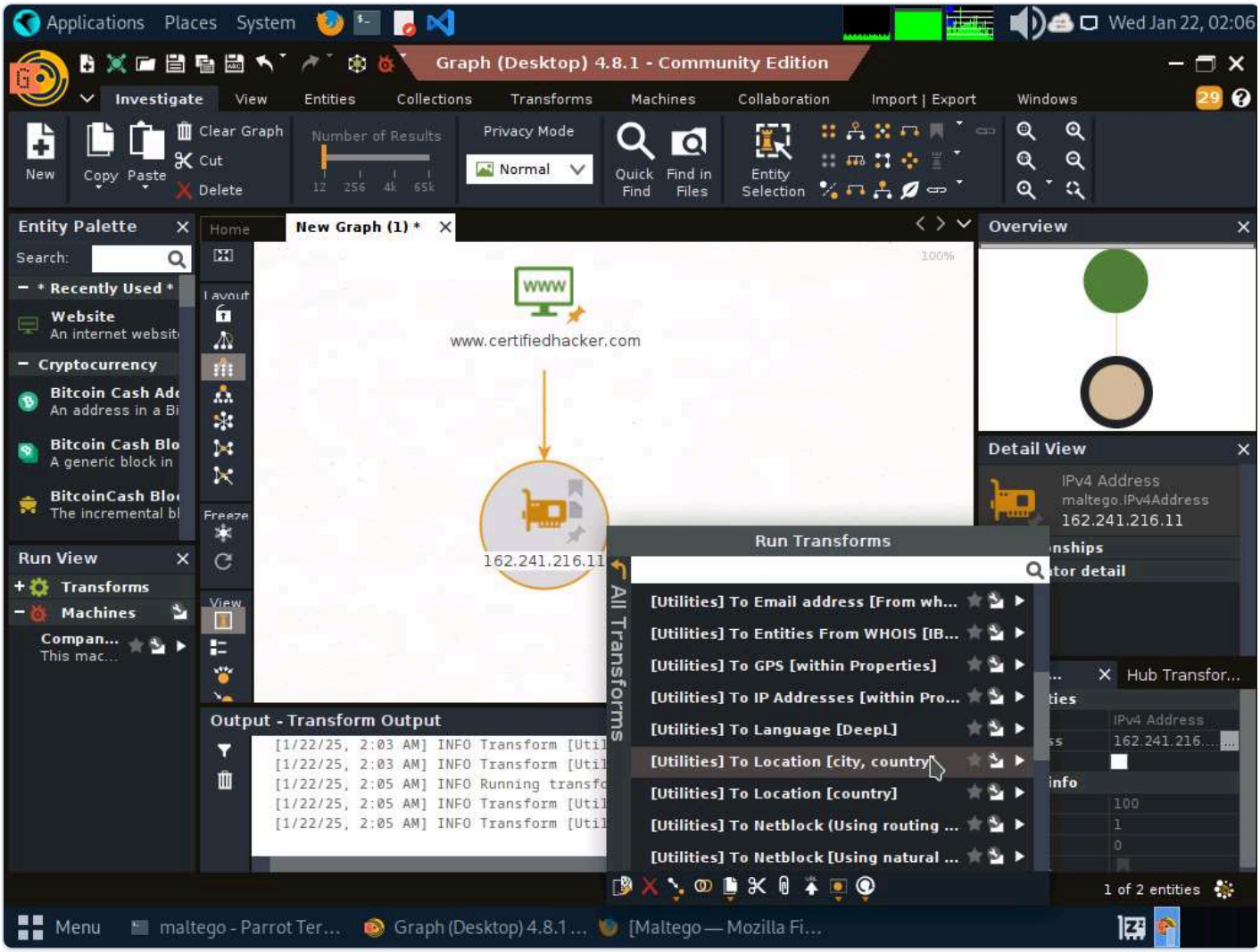



1. This displays the IP address of the website, as shown in the following screenshot.

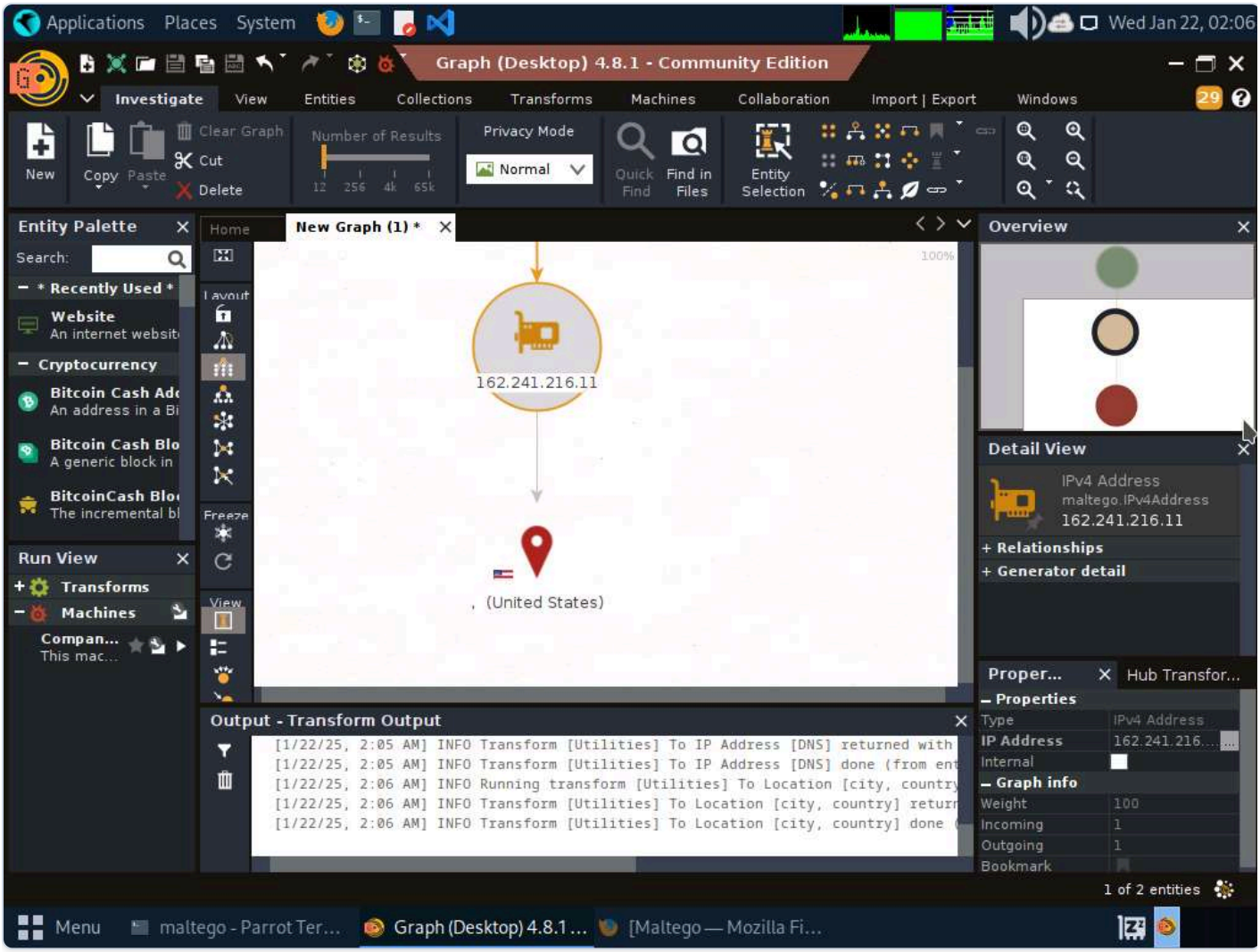



By obtaining the IP address of the website, an attacker can simulate various scanning techniques to find open ports and vulnerabilities and, thereby, attempt to intrude into the network and exploit them.

1. Right-click the IP address entity and select **All Transforms** --> **To Location [city, country]**.

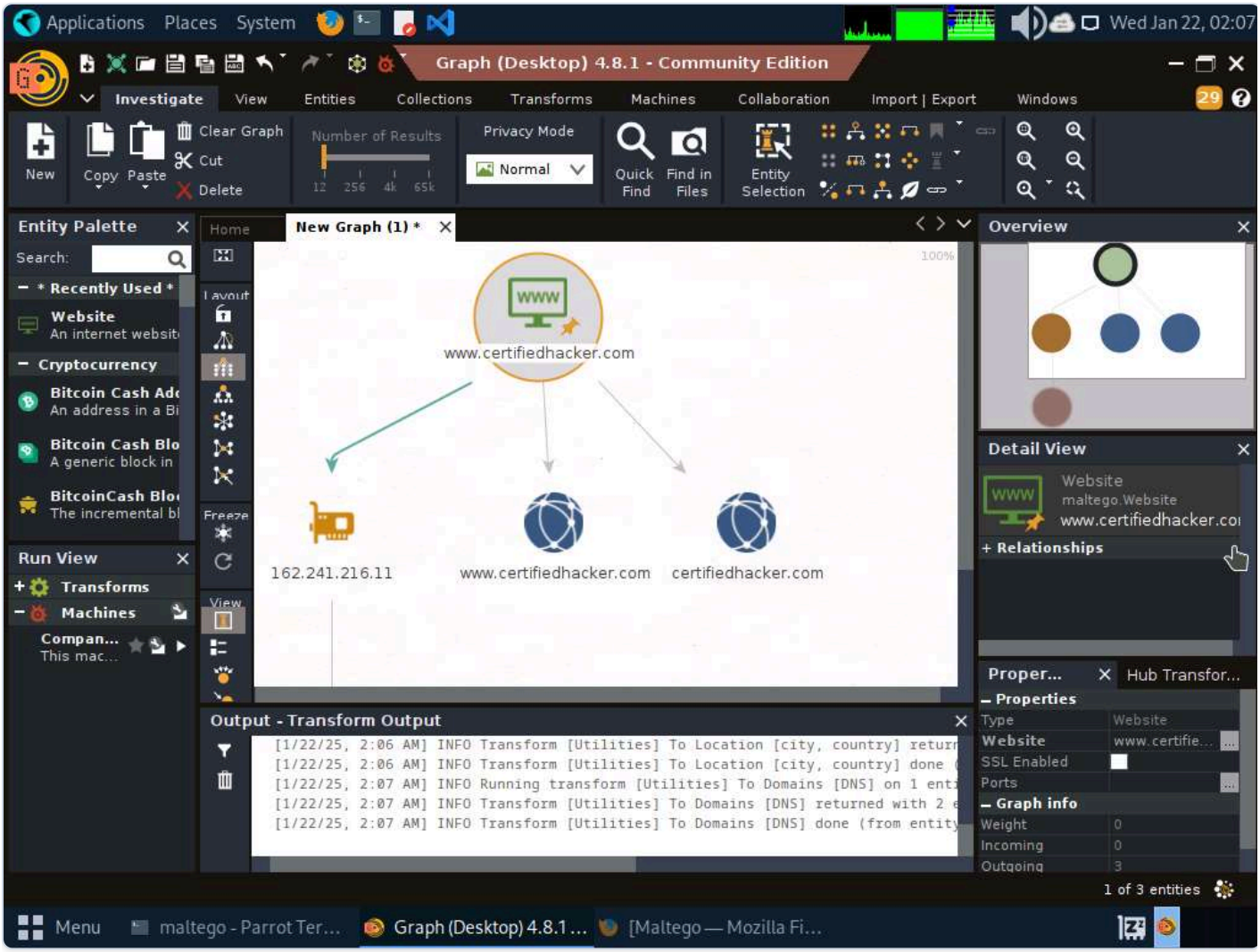



1. This transform identifies the geographical location of the IP address, as shown in the following screenshot.

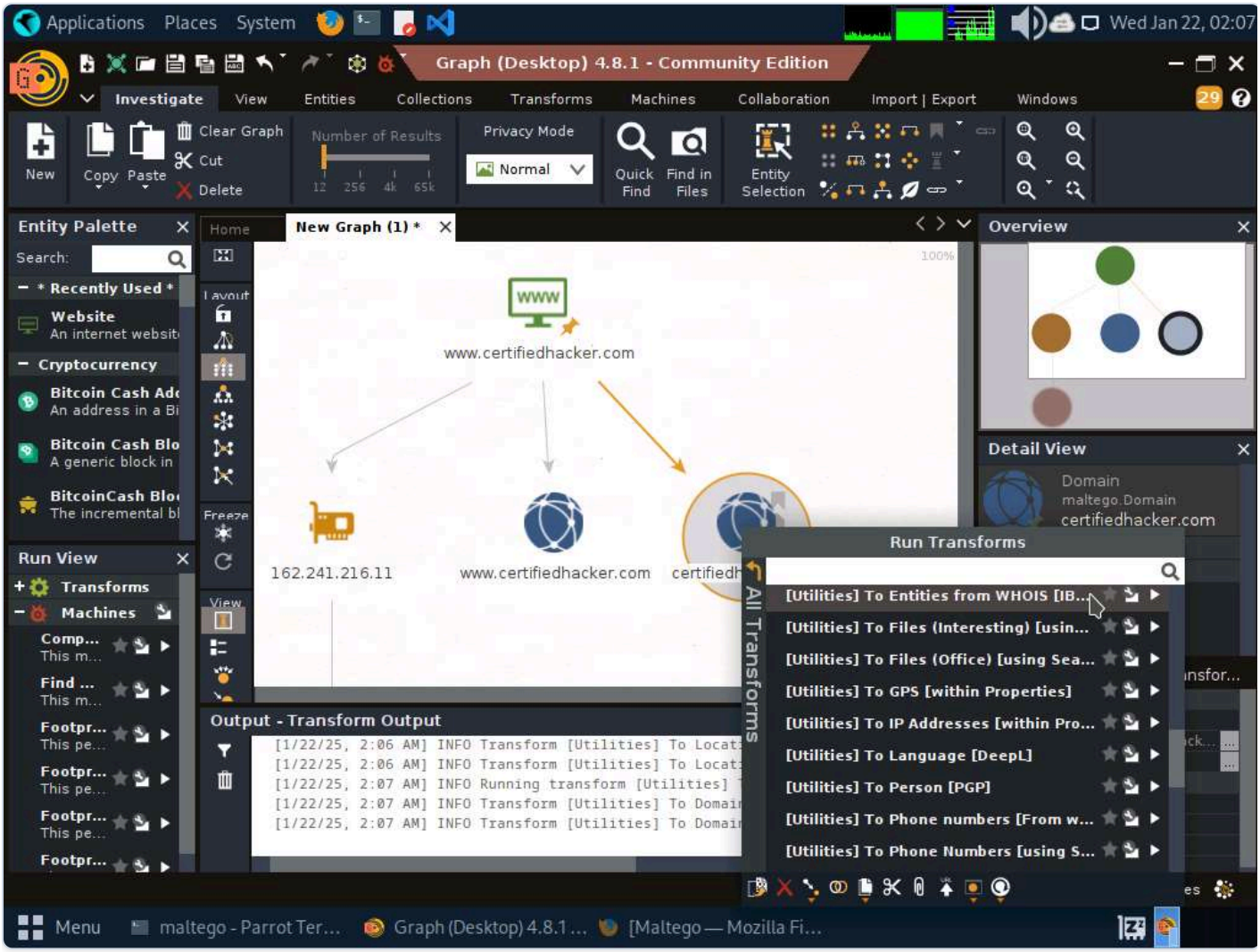



By obtaining the information related to geographical location, attackers can perform social engineering attacks by making voice calls (vishing) to an individual in an attempt to leverage sensitive information.

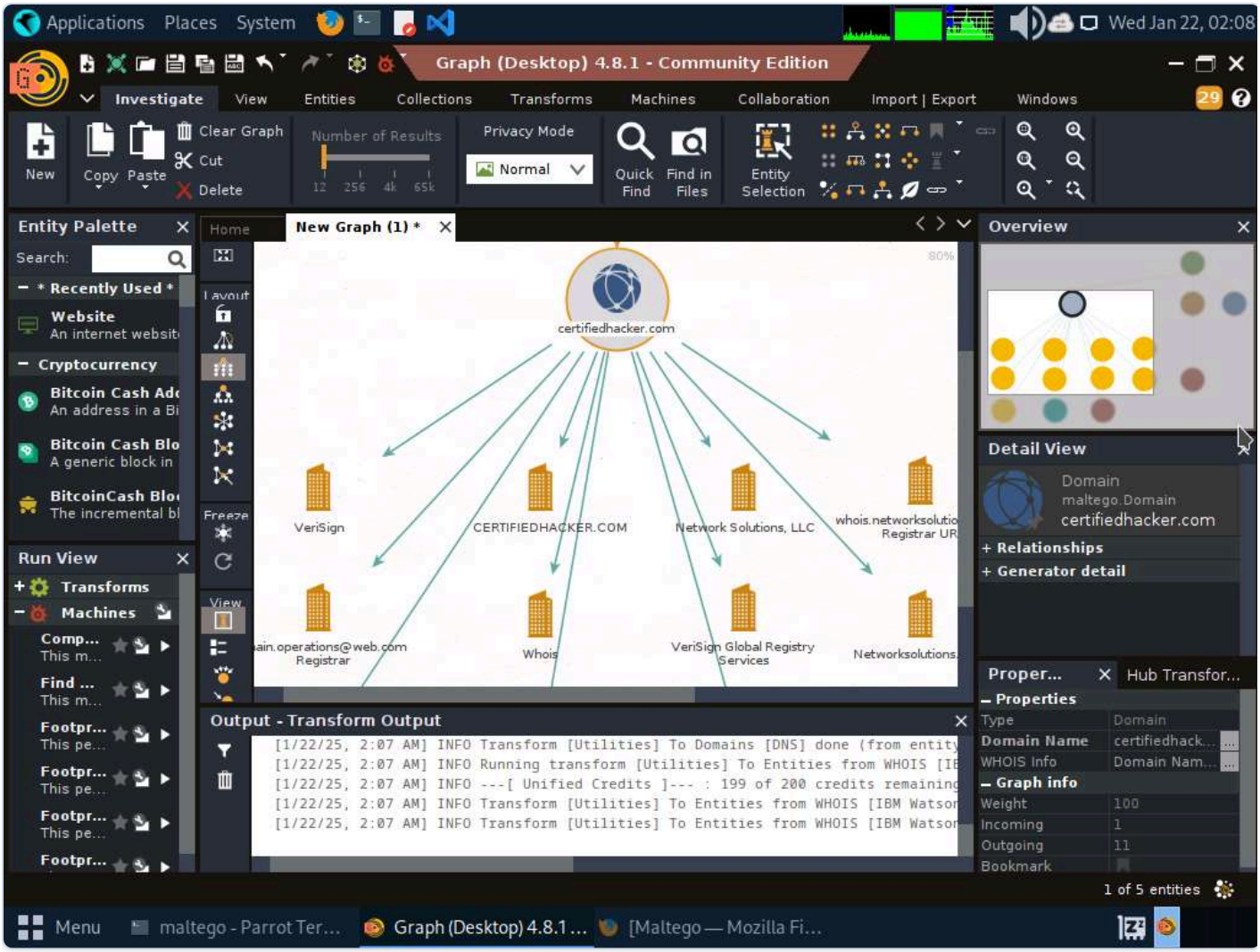
1. Now, right-click the **www.certifiedhacker.com** website entity and select **All Transforms** --> **To Domains [DNS]**. The domains corresponding to the website will be displayed as shown in the screenshot below.




1. Right-click the domain entity (**certifiedhacker.com**) and select **All Transform** --> **To Entities from WHOIS [IBM Watson]**.



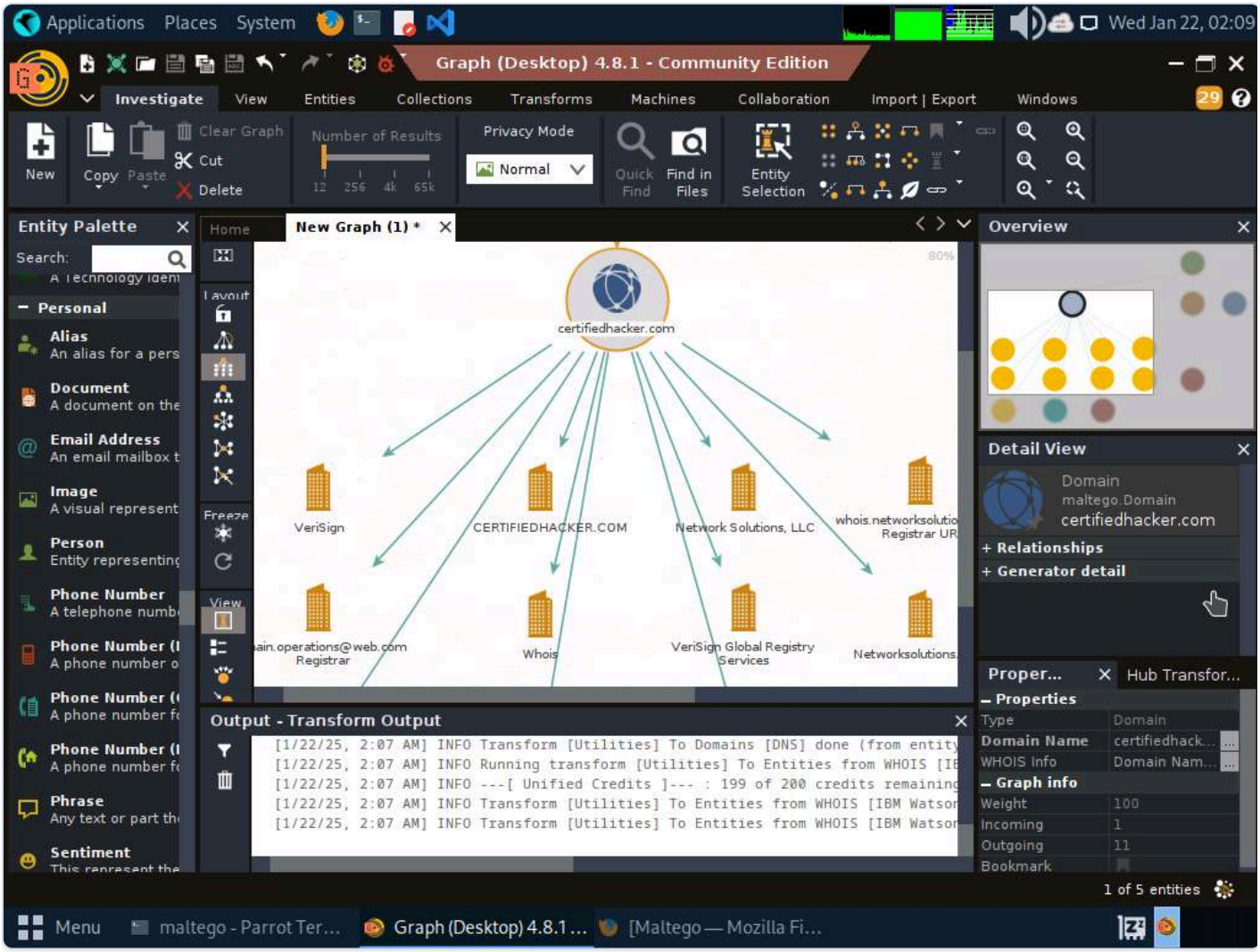

1. This transform returns the entities pertaining to the owner of the domain, as shown in the following screenshot.




By obtaining this information, you can exploit the servers displayed in the result or simulate a brute force attack or any other technique to hack into the admin mail account and send phishing emails to the contacts in that account.

Apart from the aforementioned methods, you can perform footprinting on the critical employee from the target organization to gather additional personal information such as email addresses, phone numbers, personal information, images, aliases, phrases, etc.

In the left pane of the Maltego GUI, click the **Personal** node under **Entity Palette** to observe a list of entities such as Email Address, Phone Numbers, Image, Alias, Phrase, etc.




Apart from the transformations mentioned above, other transforms can track the accounts and conversations of individuals who are registered on social networking sites such as Twitter. Extract all possible information.

By extracting all this information, you can simulate actions such as enumeration, web application hacking, social engineering, etc., which may allow you access to a system or network, gain credentials, etc.

This concludes the demonstration of footprinting a target using Maltego. Close all open windows and document all the acquired information.

---

> **IMPORTANT:** ❓ **Question 3.4.1.1** On the Parrot Security machine, use Maltego to gather information about **certifiedhacker.com**. Identify the number of name servers associated with **certifiedhacker.com** using the 'To DNS Name - NS (Name Server)' transform and record the result. [!SUCCESS] ✅ **Answer:** **2**

---

> **IMPORTANT:** ❓ **Question 3.4.1.2** On the Parrot Security machine, use Maltego to gather information about the **certifiedhacker.com** website. Record the IP address of **certifiedhacker.com** obtained from the 'To IP Address [DNS]' transform. [!SUCCESS] ✅ **Answer:** **162.241.216.11**

---

## Task 2: Gathering Open Source Intelligence on a Target using SpiderFoot

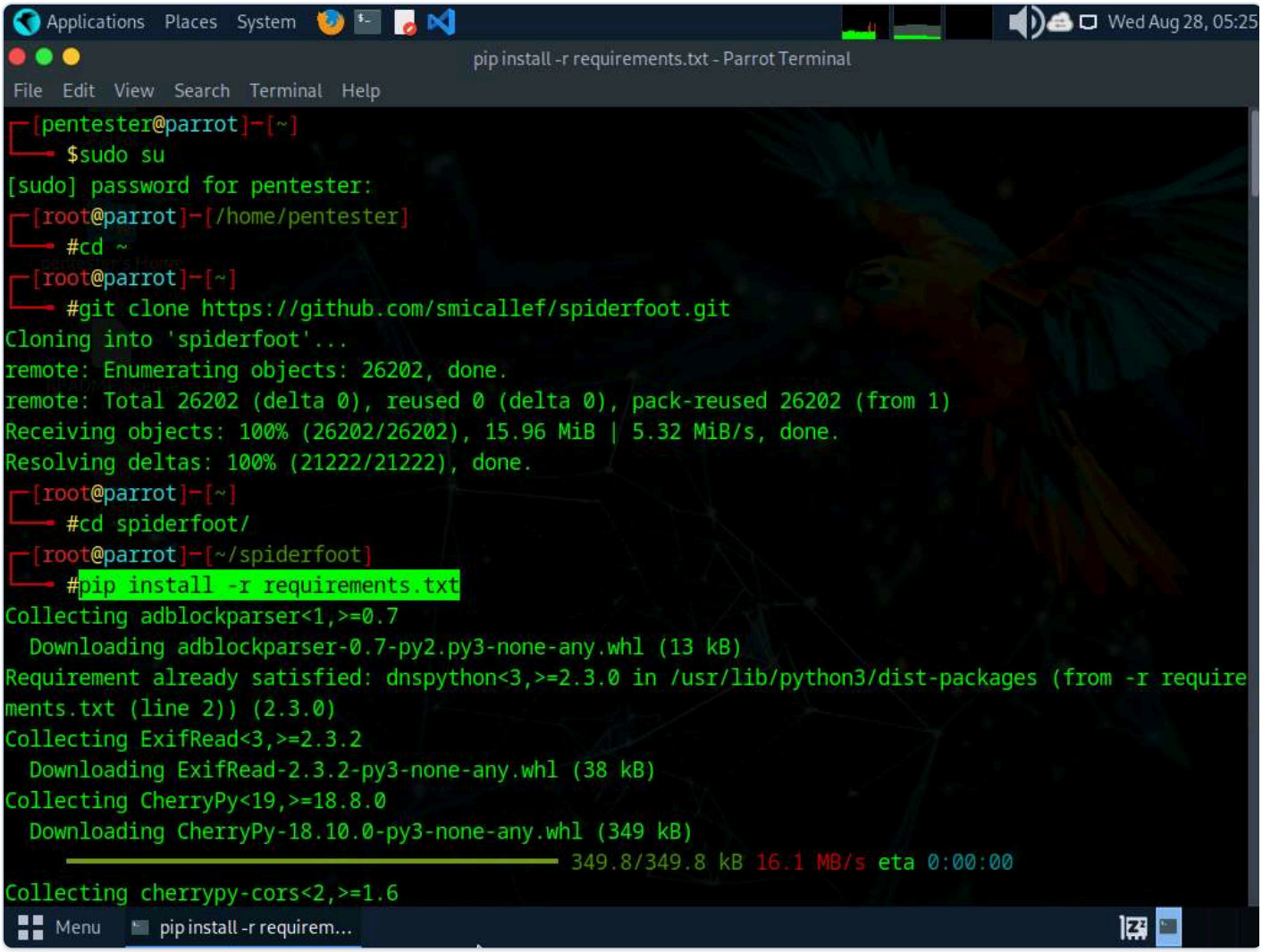
SpiderFoot is an open-source intelligence (OSINT) automation tool. It integrates with just about every data source available and utilizes a range of methods for data analysis, making that data easy to navigate. SpiderFoot has an embedded web server for providing a clean and intuitive web-based interface but can also be used completely via the command line. It's written in Python 3 and MIT-licensed.

*Source:* **https://github.com/smicallef/spiderfoot**

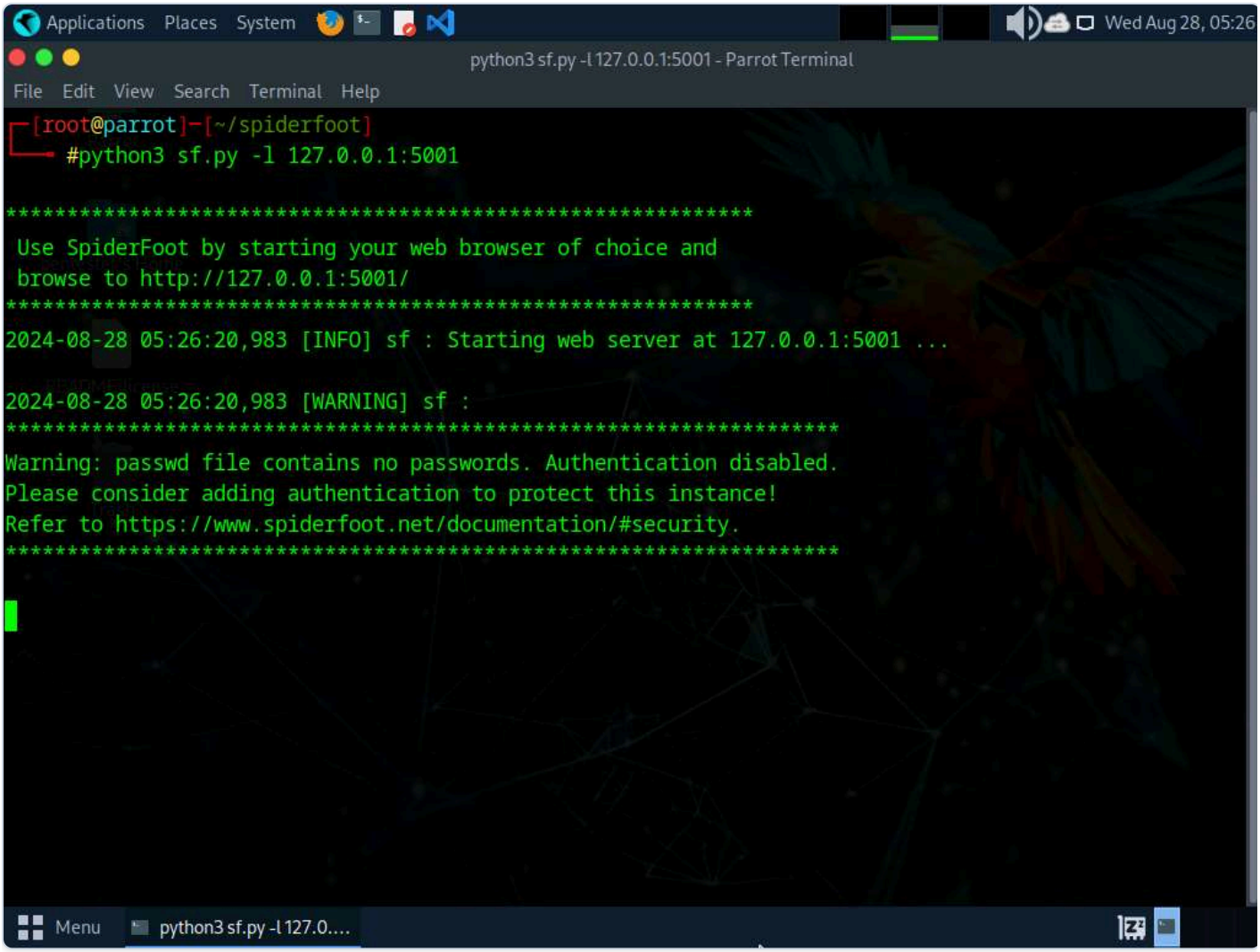
## Lab Tasks

Let us now take a look at SpiderFoot. There are some challenges in getting this setup, but again we want to show different ways of doing different things. Being a penetration tester is all about working with the process and finding the tools that assist us in this process. The first thing we need to do is clone the repository, and enter the following commands:

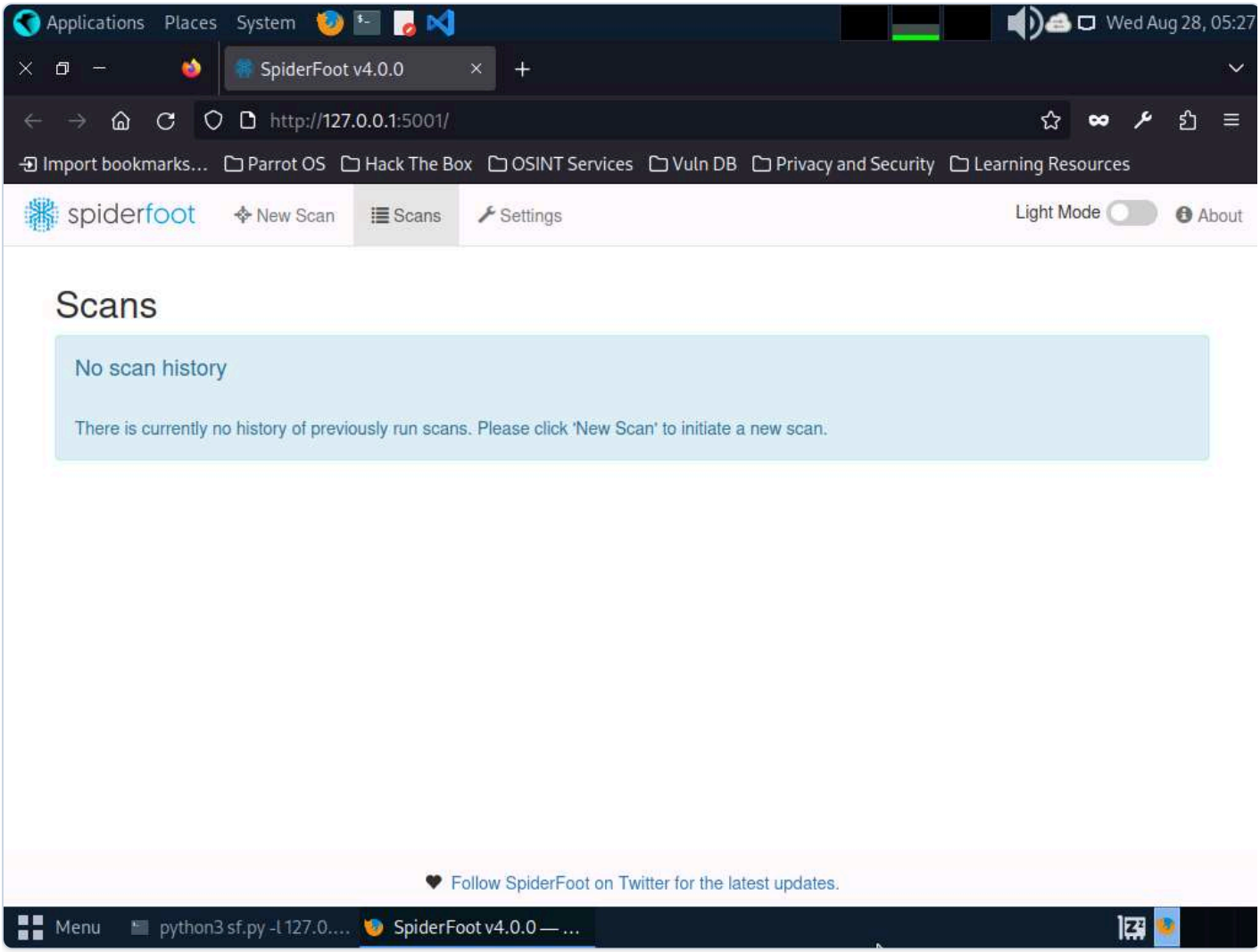
1. In terminal, navigate to home and clone repository:
2. **cd ~**
3. **git clone https://github.com/smicallef/spiderfoot.git**
4. **cd spiderfoot**
5. **pip install -r requirements.txt**
6. *(You will get some error messages, but the tool will still be operational.)*



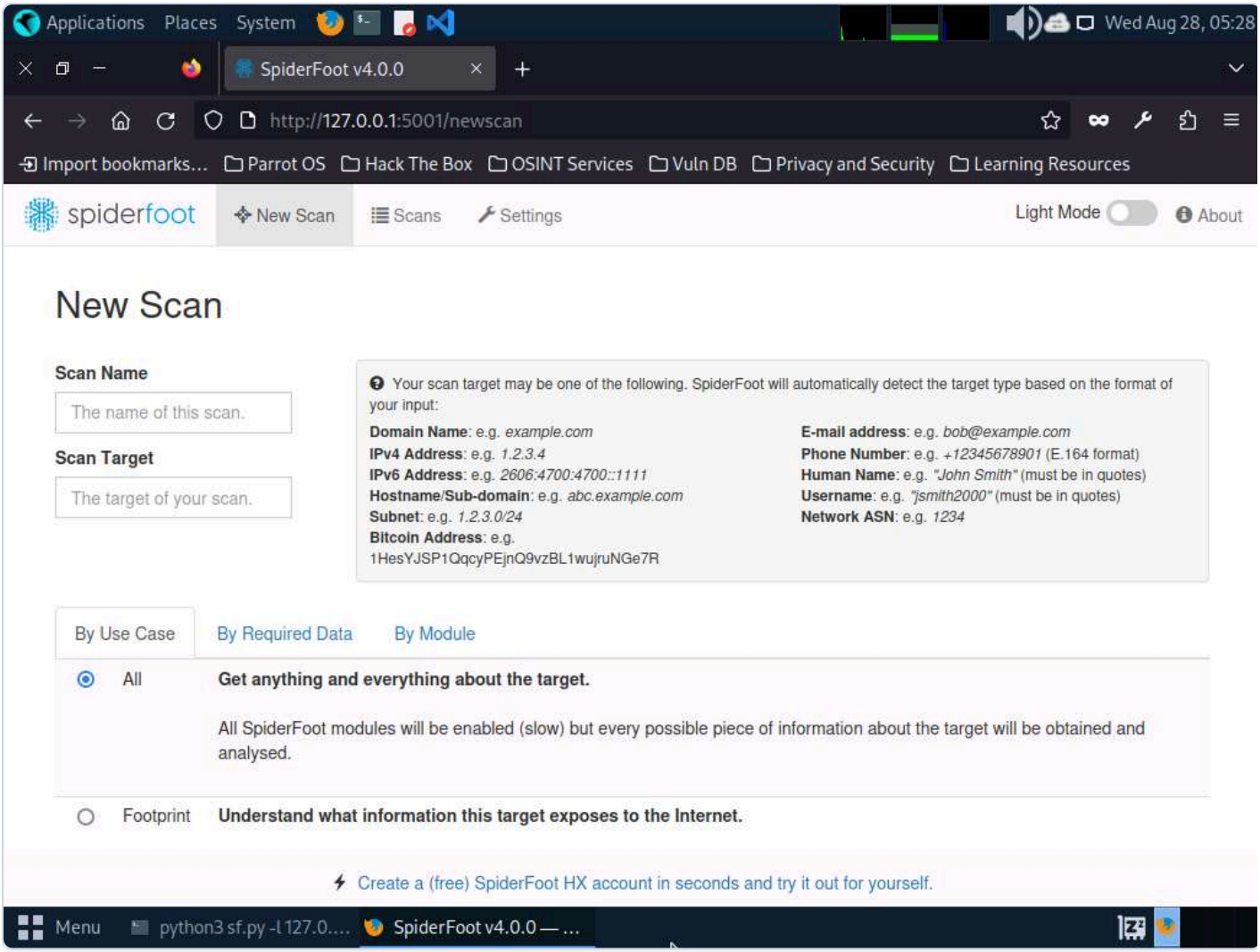

1. Now we want to run the tool, enter **python3 sf.py -l 127.0.0.1:5001**



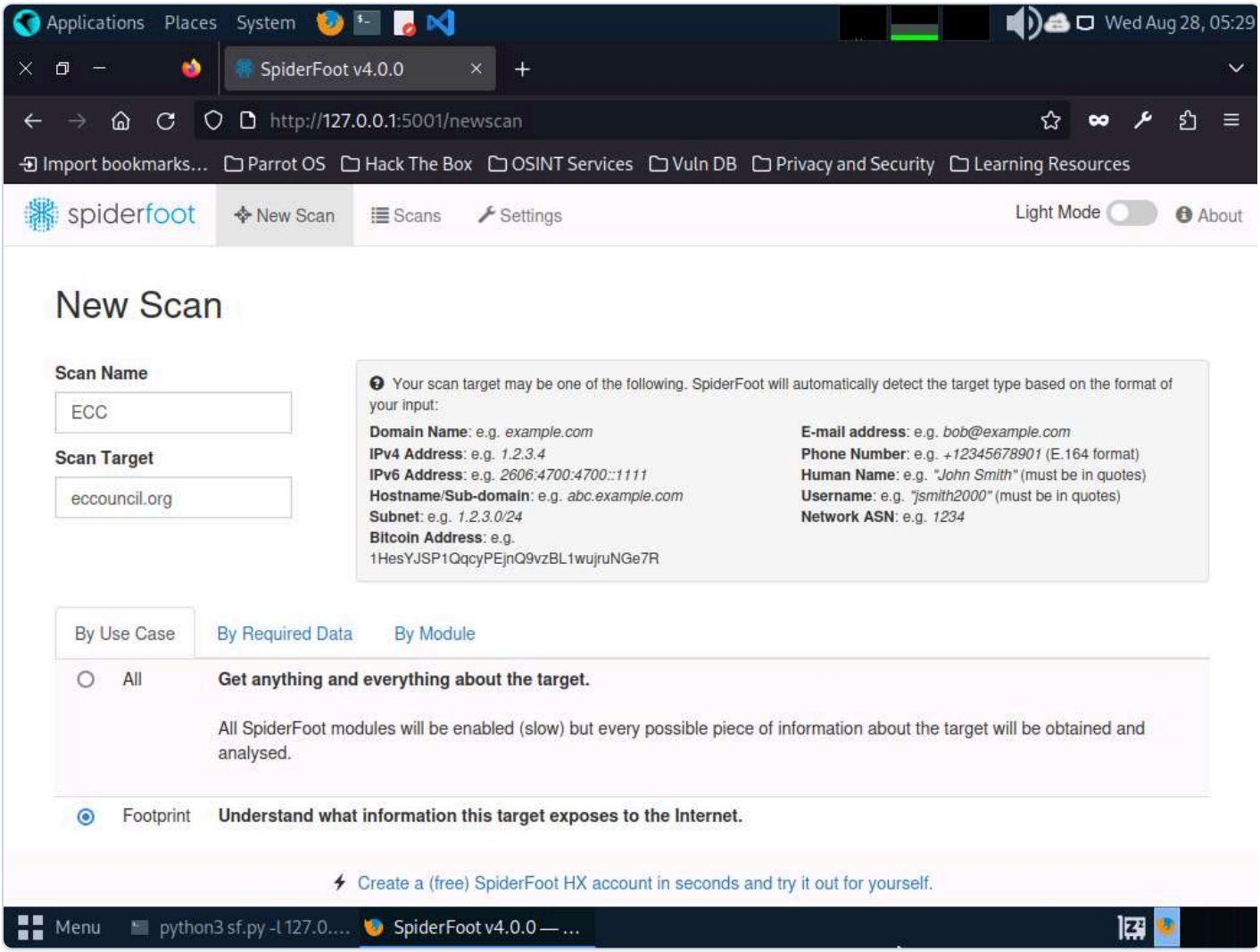

1. The next thing you want to do is open the browser and enter **http://127.0.0.1:5001**.



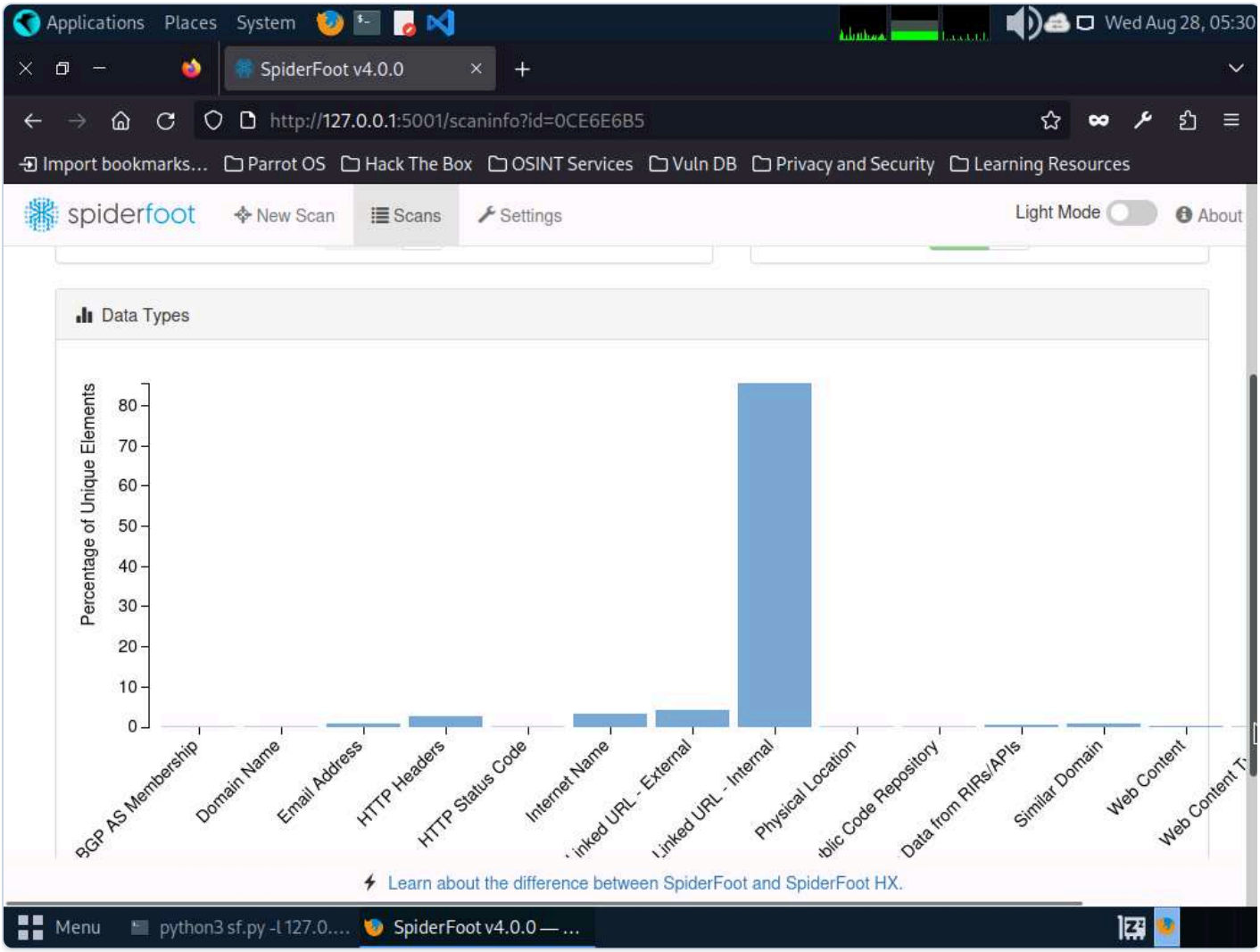

1. We want to run a scan, click on **New Scan**.



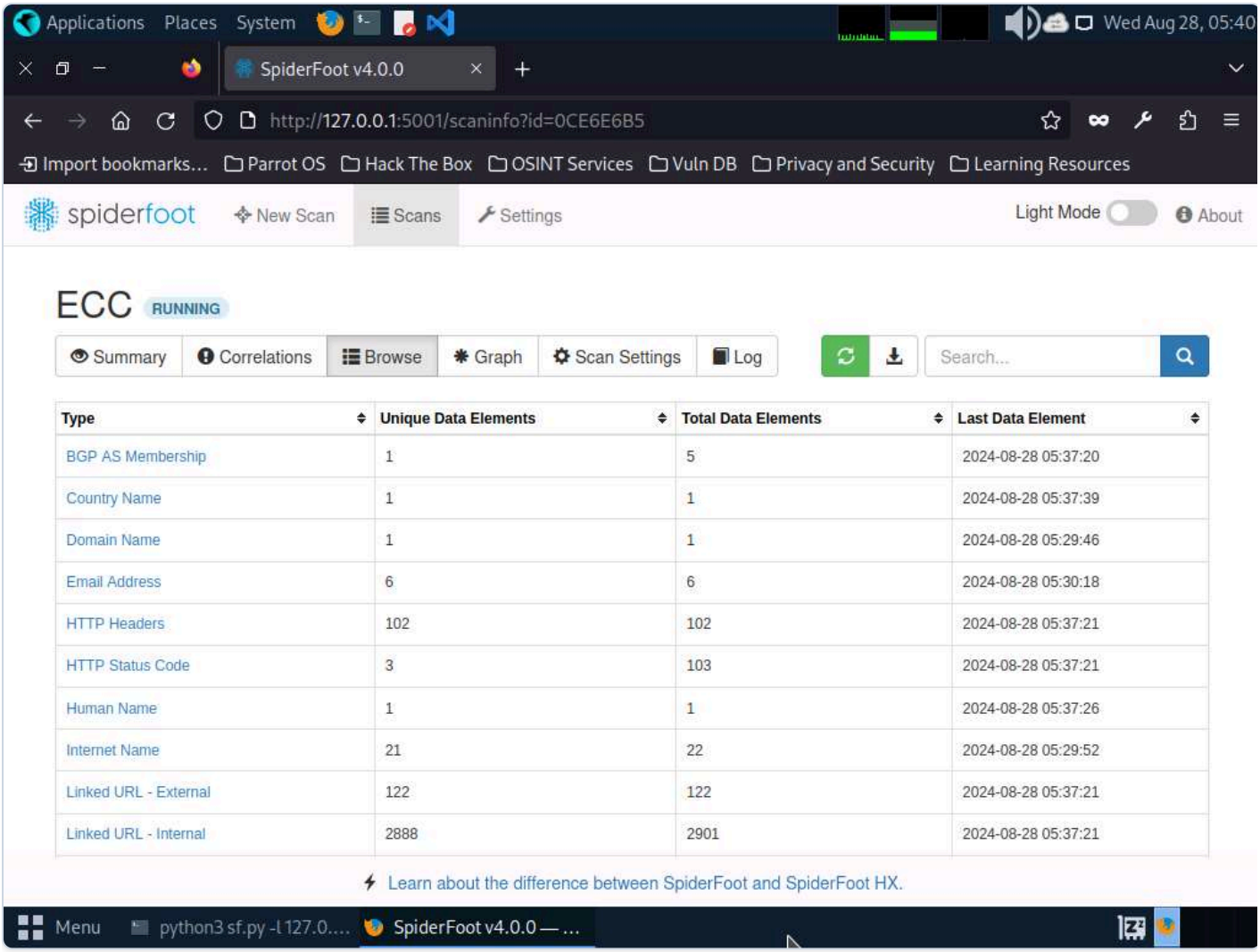

1. Take a few minutes and review the different settings of the interface. There are a lot of things that you can extract here, and you are encouraged to explore. We will look at a few of them here. Select **Footprint**, enter a scan name of **ECC**, and then enter the target of **eccouncil.org** and click **Run Scan Now**.




1. You can view the loading of the scan in the terminal window, or you can observe the GUI.




1. Take a few minutes and review the data. For example, you can view the following as shown in the screenshot.




If you have time, enter some domains that are of interest to you. As with many of these tools, it is public information, but some data will only be accessible after you enter an API key. This tool has a lot of features for you to explore and is recommended for OSINT.

---

> **IMPORTANT:** ❓ **Question 3.4.2.1** On the Parrot Security machine, use SpiderFoot to gather open-source intelligence on **eccouncil.org**. Record the Domain Registrar name identified during the scan. [!SUCCESS] ✅
> **Answer:** **NETWORK SOLUTIONS, LLC**

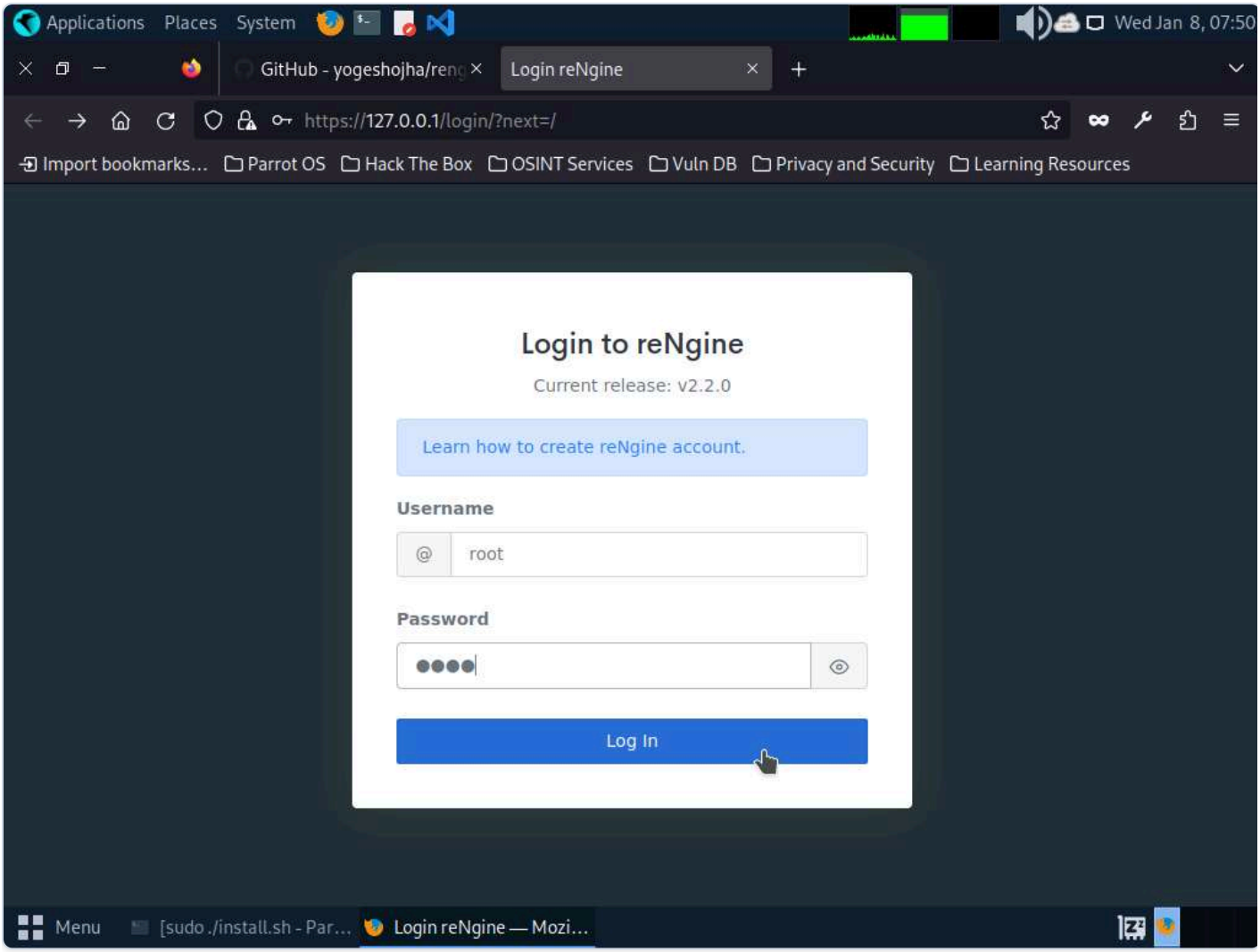
---

## Task 3: Performing Web Reconnaissance using reNgine

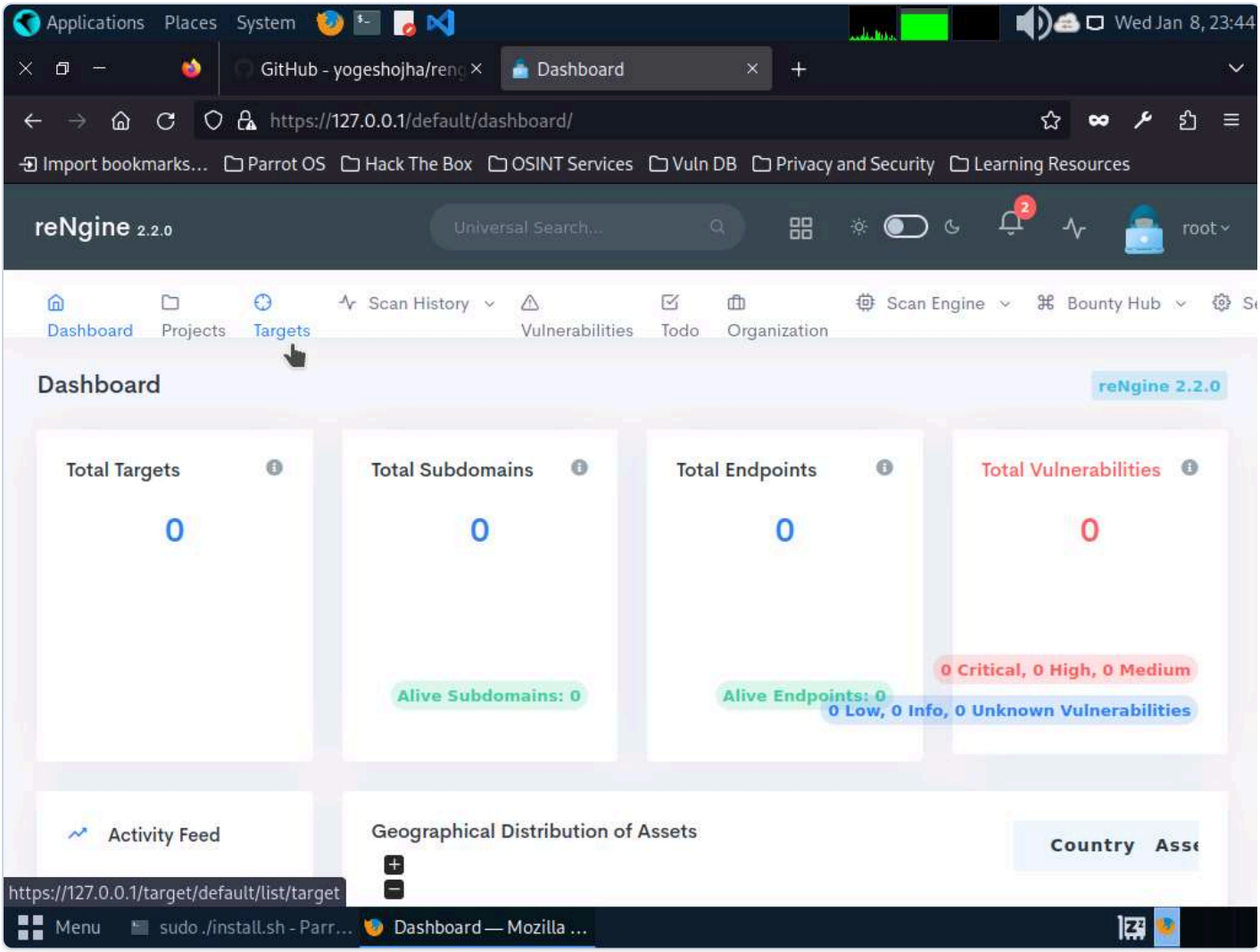
In this lab, you will learn to perform Web Reconnaissance using reNgine on a target domain. You will configure the tool, initiate scans, analyze subdomains, identify potential vulnerabilities, and document findings through an interactive dashboard.

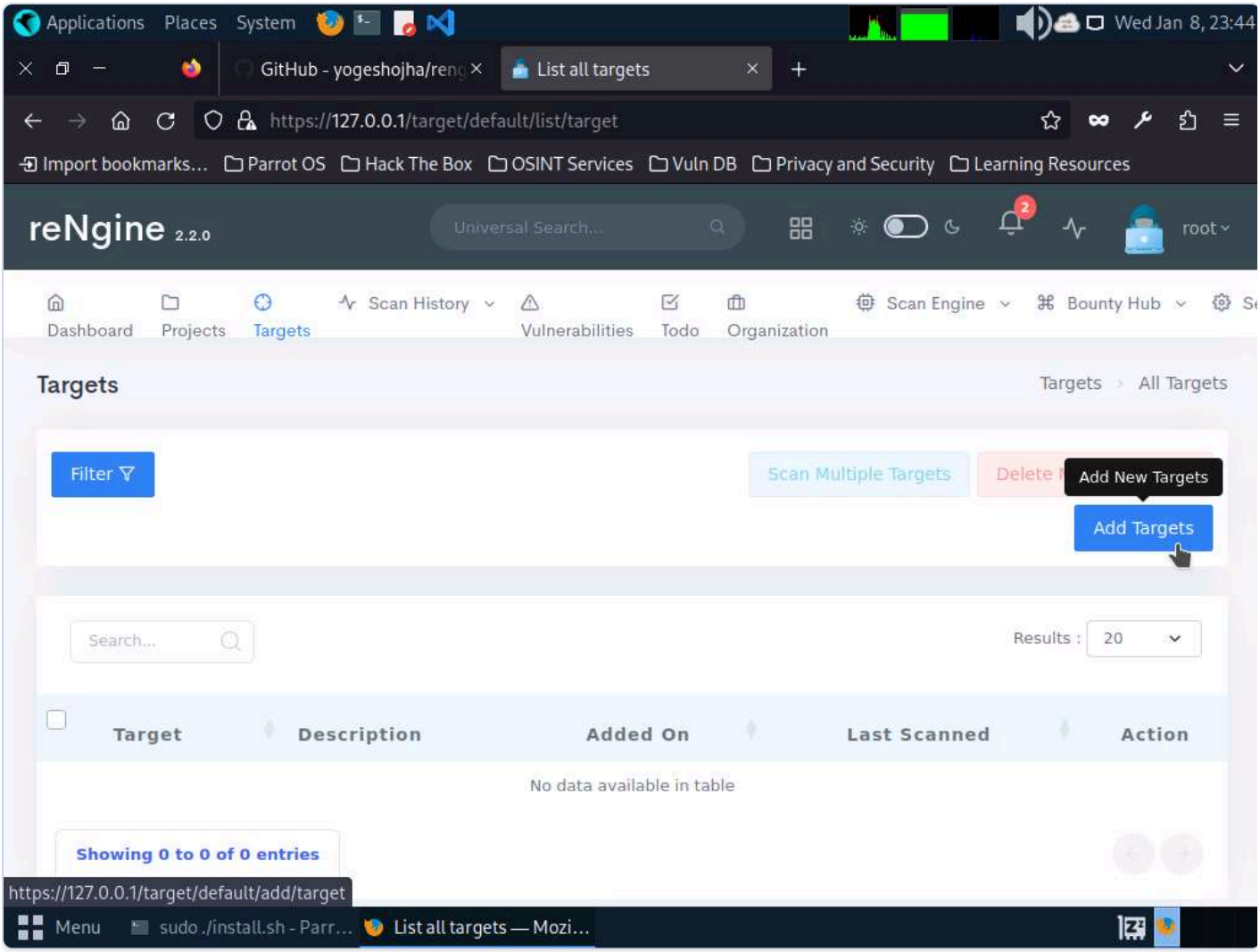
### Lab Tasks

1. Click **Parrot Security** to switch to the Parrot Security machine.
2. Open a browser and enter the link **http://127.0.0.1**. You will be redirected to the login page. Enter the username **root** and password **toor**, then click on **Login**.
3. *(If a Warning window appears, click on Advanced.. and click on Accept the risk and continue.)*

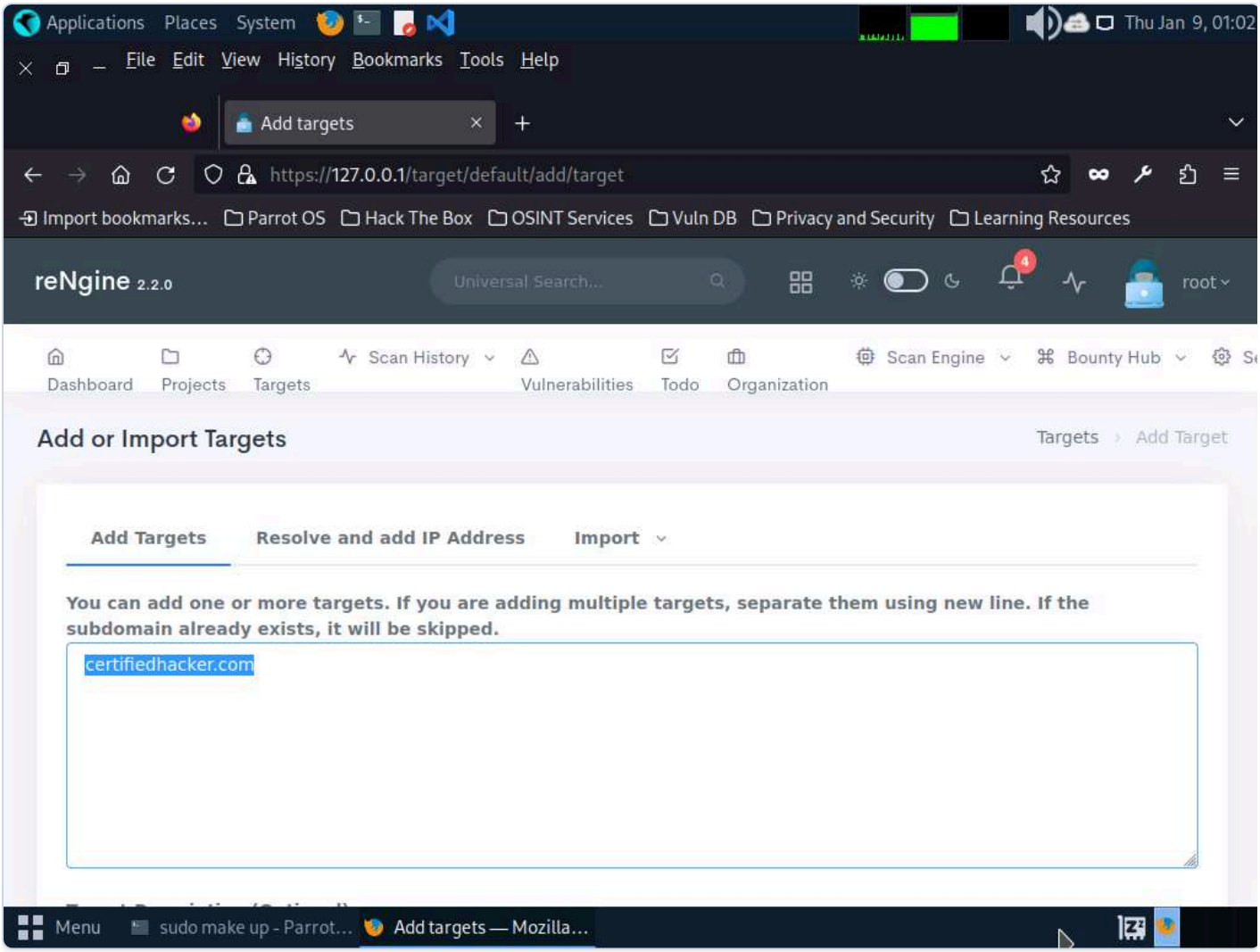


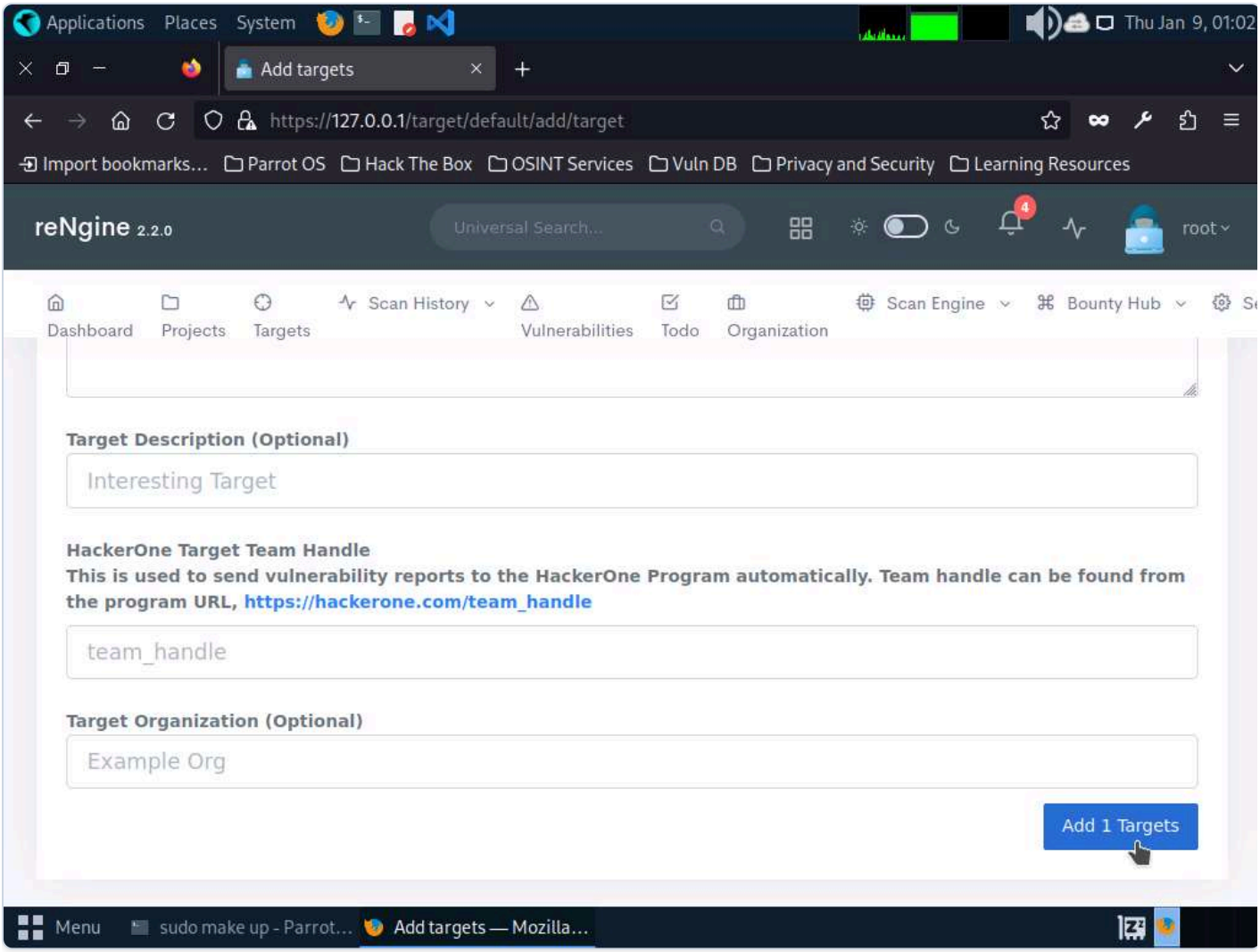

1. In the Welcome to reNgine window, enter a Project name, scroll down, and click on **Complete Setup**.
2. In the dashboard, click on **Targets** from the top menu, and then click on **Add Targets** to add a target domain address.


Applications Places System
Wed Jan 8, 23:44
GitHub - yogeshojha/reng
Dashboard
https://127.0.0.1/default/dashboard/
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
reNgine 2.2.0
Universal Search...
root
Dashboard
Projects
Targets
Scan History
Vulnerabilities
Todo
Organization
Scan Engine
Bounty Hub
Dashboard
reNgine 2.2.0
Total Targets
0
Total Subdomains
0
Alive Subdomains: 0
Total Endpoints
0
Alive Endpoints: 0
Total Vulnerabilities
0
0 Critical, 0 High, 0 Medium
0 Low, 0 Info, 0 Unknown Vulnerabilities
Activity Feed
Geographical Distribution of Assets
Country
https://127.0.0.1/target/default/list/target
Menu
sudo ./install.sh - Parr...
Dashboard — Mozilla ...

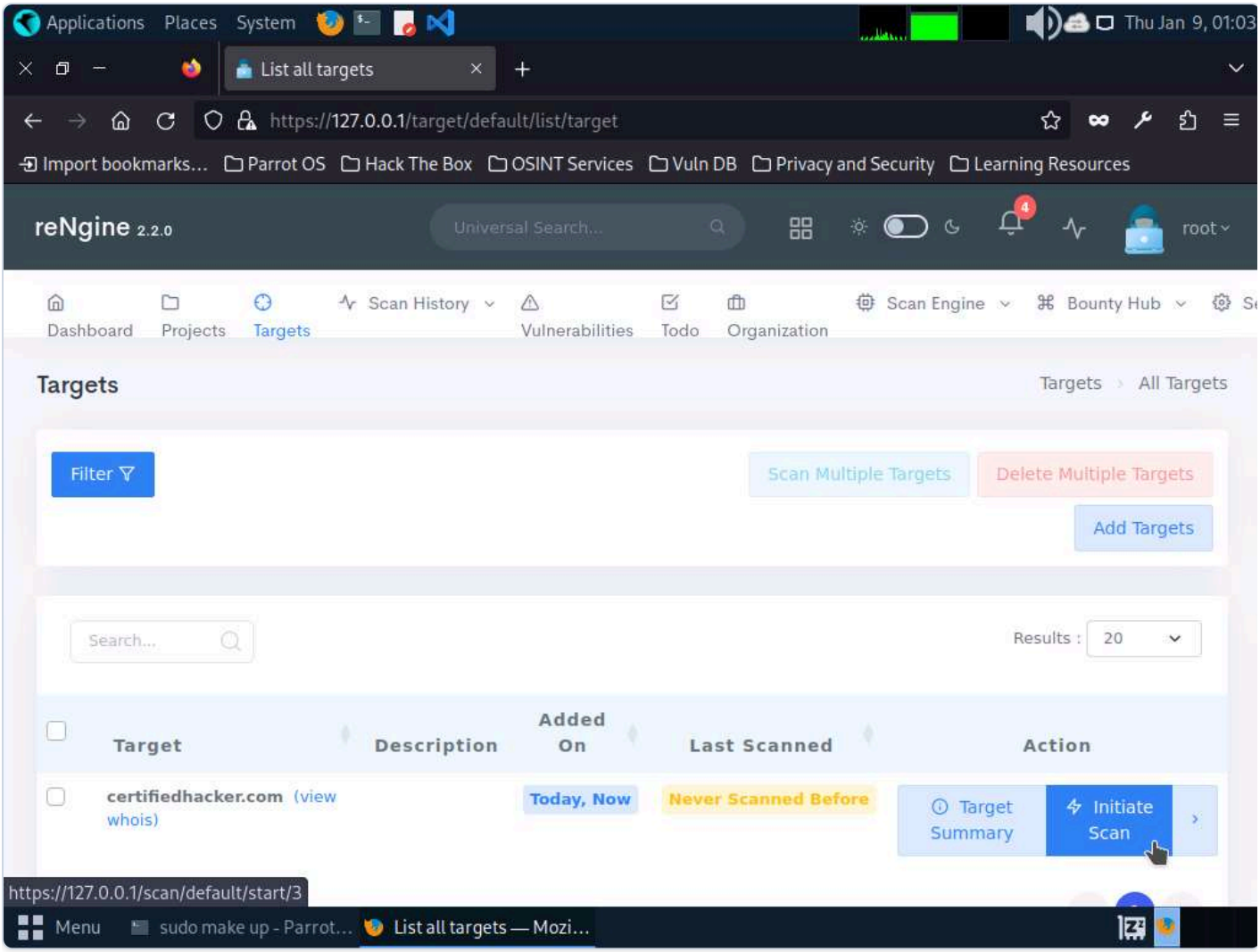



1. In the Add or Import Targets window, type the target domain name under Add Targets (**certifiedhacker.com**). Then scroll down and click on **Add 1 Targets**.

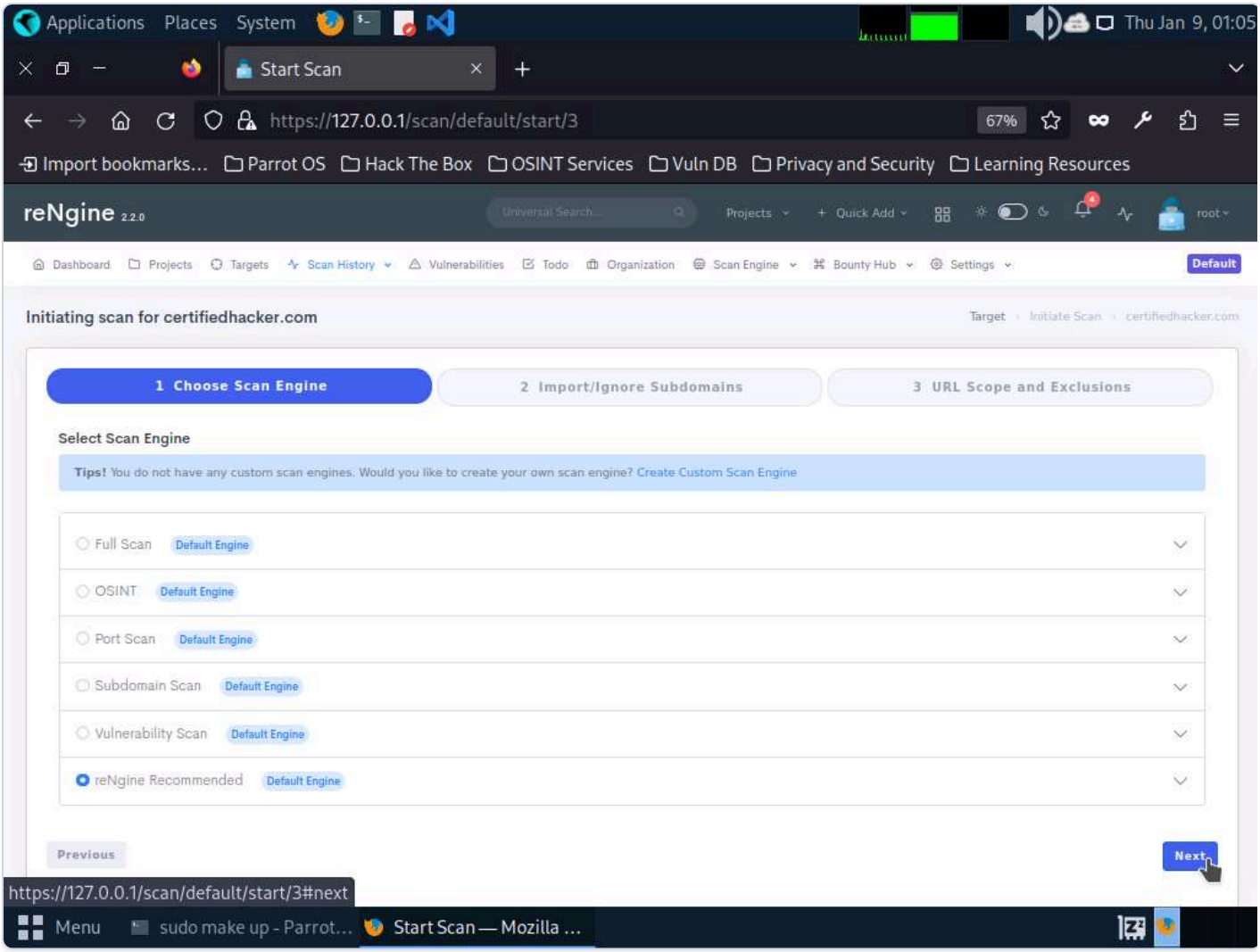

Applications Places System
Thu Jan 9, 01:02
File Edit View History Bookmarks Tools Help
Add targets
https://127.0.0.1/target/default/add/target
Import bookmarks... Parrot OS Hack The Box OSINT Services Vuln DB Privacy and Security Learning Resources
reNgine 2.2.0
Universal Search...
root
Dashboard Projects Targets Scan History Vulnerabilities Todo Organization Scan Engine Bounty Hub
Add or Import Targets
Targets › Add Target
Add Targets
Resolve and add IP Address
Import
You can add one or more targets. If you are adding multiple targets, separate them using new line. If the subdomain already exists, it will be skipped.
certifiedhacker.com
Menu
sudo make up - Parrot...
Add targets — Mozilla...



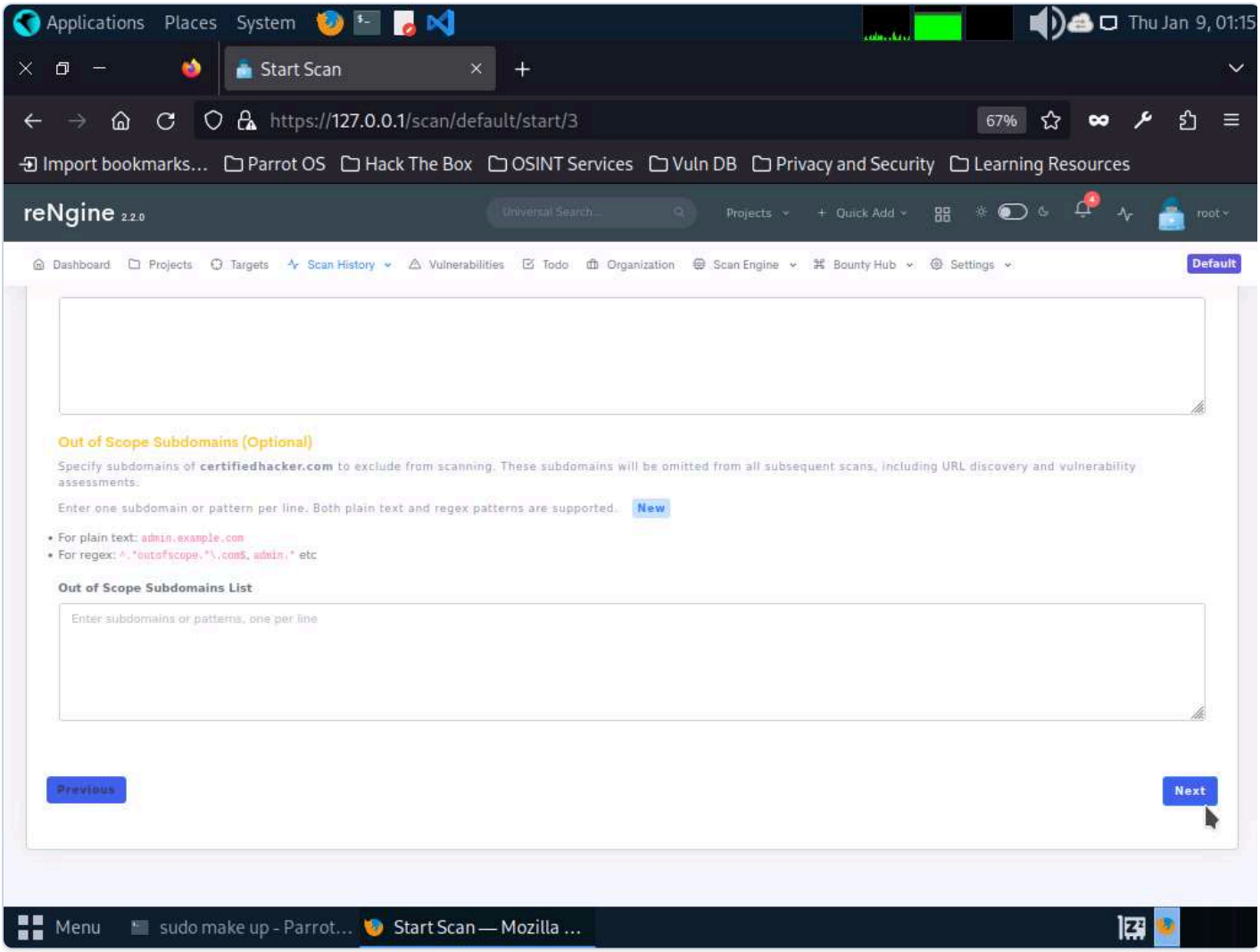

1. You will see the Target window with the added target domain. Click on **Initiate Scan**.



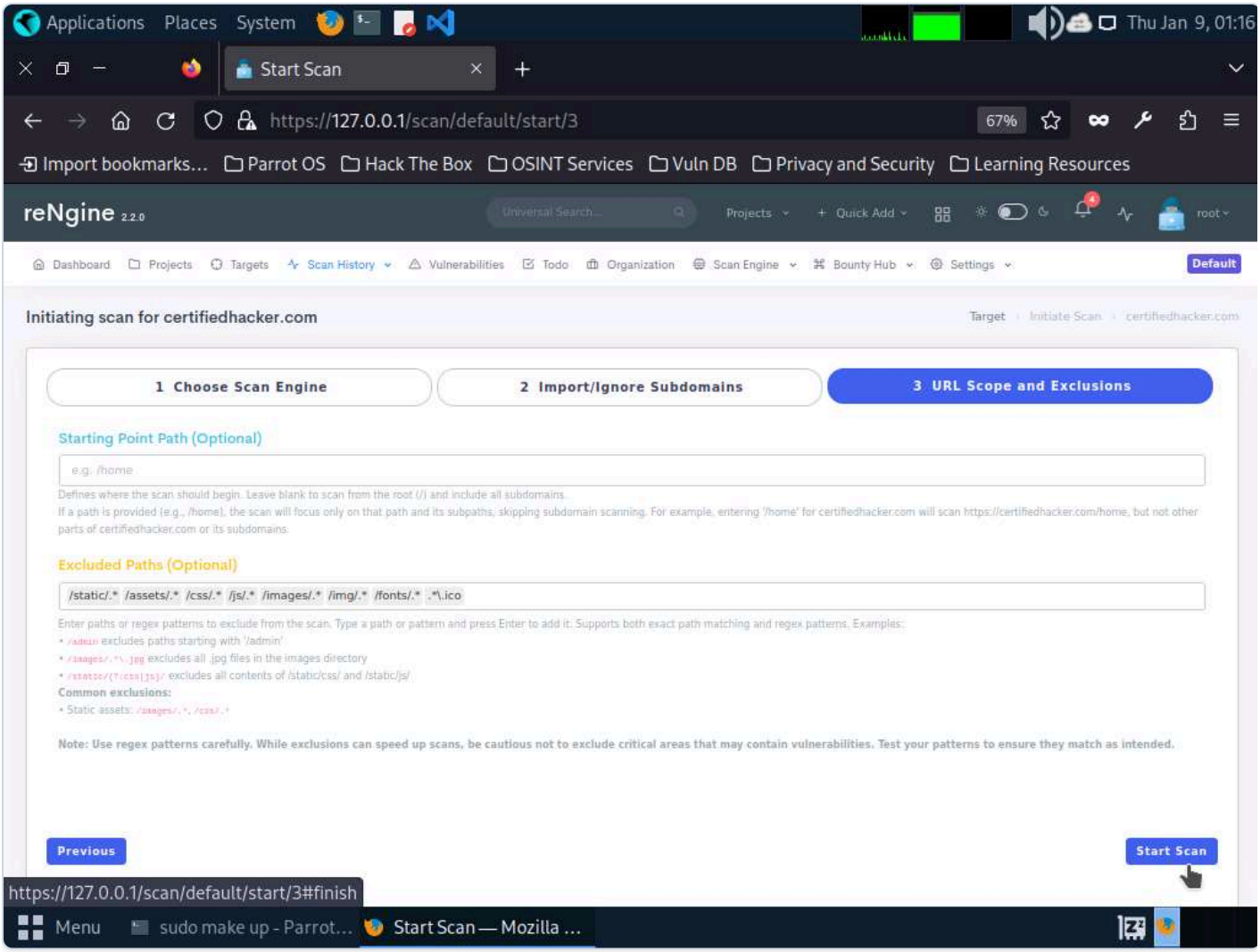

1. In the next tab Initiating scan for **certifiedhacker.com**, under **1 Choose Scan Engine**, select a scan engine according your requirement. (Here we are selecting **reNgine Recommended**). Then click on **Next**.



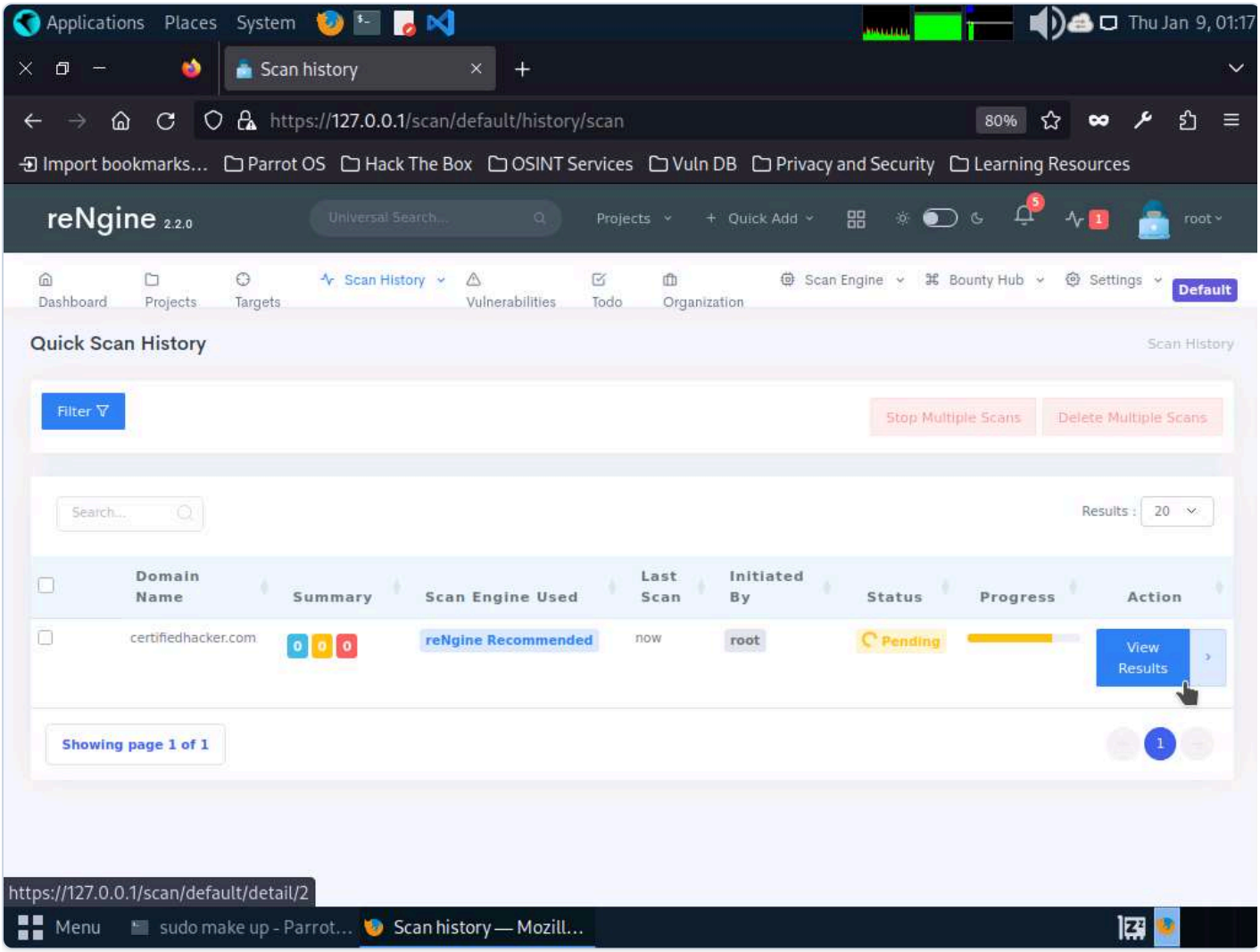

1. In the next tab, **2 Import/Ignore Subdomains**, scroll down and click **Next**.



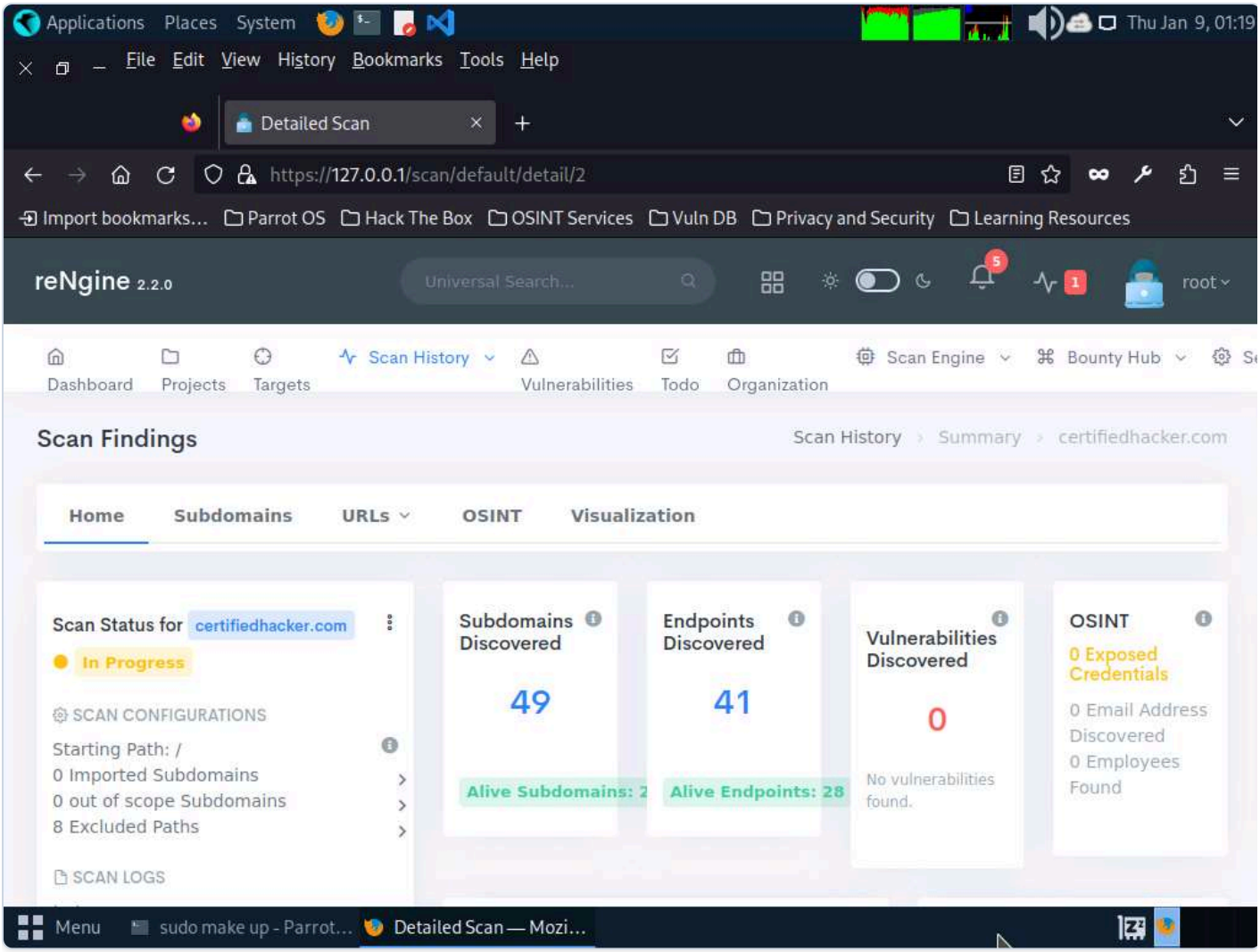

1. In the next tab, **3 URL Scope and Exclusions**, scroll down and click **Start Scan**.




1. You can view the scan status in the Quick Scan History tab. The scan may take 10 minutes or more. You don't need to wait for completion, after a few minutes, click **View Results** to see partial findings.




1. The scan results will be displayed in the Scan Findings window as shown in the screenshot:




Explore all other options in the Scan Findings tab and analyze the data. Close all tabs after documenting the findings.

---

**IMPORTANT:** ❓ **Question 3.4.3.1** On the Parrot Security machine, utilize reNgine to conduct a comprehensive scan to identify subdomains, endpoints, and vulnerabilities associated with **certifiedhacker.com**. Record the Nginx version detected on the **demo.certifiedhacker.com** subdomain. [!SUCCESS] ✅ **Answer:** **1.29.8**